



Digital Operational Resilience Act

VMware Cloud Foundation 9.1

June 23, 2026

Table of Contents

Disclaimer.....3

Version.....4

Introduction.....4

Additional Resources4

Third Party Identifiers and Mappings4

Coverage Levels4

Controls..... 6

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Version

910-20260623-01

Introduction

This document describes how VMware Cloud Foundation (VCF) 9.1 and the separately licensed advanced services assessed alongside it, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, and VMware Avi Load Balancer, can support organizations working toward compliance with the Digital Operational Resilience Act (DORA), formally Regulation (EU) 2022/2554. DORA establishes requirements for ICT risk management, incident reporting, resilience testing, and third-party risk management across the EU financial sector. Each assessed product is reported separately for every control, with VCF covering the full platform, including its consumption services and Private AI Services capabilities. The responsibility for assessing and achieving compliance with DORA remains with the regulated organization.

<https://www.digital-operational-resilience-act.com/>

This guidance evolves. Please check the current revision at: <https://bcm.tech/vcf-compliance>

Additional Resources

This is one of a library of companion guides that map VMware Cloud Foundation and its advanced services to security and compliance frameworks. For each framework, the guide is published as a spreadsheet, a CSV data file, a Markdown document, and a PDF, together with a Security Configuration Guide crosswalk that identifies the VCF technical hardening settings relevant to that framework. The companion guide library, the VMware Cloud Foundation Security Configuration Guide, and related security documentation, sample scripts, and Q&A are available at <https://bcm.tech/vcf-security>.

Third Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the Secure Controls Framework, version 2026.1, under the terms of the Creative Commons Attribution-NoDerivatives 4.0 International Public License. No modifications have been made to the control identifier numbers under the terms of the license.

<https://securecontrolsframework.com/>

Coverage Levels

Each control entry below carries the framework control text, the SCF control or controls it maps to, and an Aggregate Coverage line showing the strongest position any one of the assessed products holds for that control. Products that meet or contribute to the control follow as subsections, each with its own coverage level and response. Products the control does not apply to are listed together at the end of the entry, with a brief explanation. The coverage levels are:

- **Meets** -- the product directly provides the capability described in the control. No additional organizational process, external product, or human activity is needed beyond configuring the product itself.
- **Contributes** -- the product provides technical capabilities that help satisfy the control, but the control also requires something outside the product to be fully met, such as an organizational process, human activity, or an additional tool.
- **Not Applicable** -- the control does not apply to the product. Physical facility controls, staffing decisions, organizational governance processes, and domains the product does not operate in fall here.

- **Not Supported** -- the control is relevant to the product's domain (infrastructure, networking, security), but the product lacks the specific capability the control requires.
- **Not Assessed** -- the control has not yet been evaluated against the product.

Controls

Control 4.1

Financial entities shall implement the rules in Chapter II in accordance with the proportionality principle, considering their size and overall risk profile, and the nature, scale and complexity of their services, activities and operations.

SCF Controls: CPL-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 4.2

The application of Chapters III, IV and V (Section I) by financial entities shall be proportionate to their size, overall risk profile, and the nature, scale and complexity of their services, activities and operations, as specifically provided for in those Chapters.

SCF Controls: CPL-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 4.3

Competent authorities shall consider the proportionality principle when reviewing the consistency of the ICT risk management framework based on reports submitted under Article 6(5) and Article 16(2).

SCF Controls: CPL-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.1

Financial entities shall have an internal governance and control framework that ensures effective and prudent management of ICT risk to achieve a high level of digital operational resilience.

SCF Controls: GOV-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.2

The management body shall define, approve, oversee, and be responsible for the implementation of all arrangements related to the ICT risk management framework.

SCF Controls: GOV-01.1, GOV-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.2(a)

Bear the ultimate responsibility for managing the financial entity's ICT risk.

SCF Controls: GOV-01.1, GOV-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.2(b)

The management body shall put in place policies that aim to ensure the maintenance of high standards of availability, authenticity, integrity and confidentiality, of data.

SCF Controls: GOV-01.1, GOV-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.2(c)

The management body shall set clear roles and responsibilities for all ICT-related functions and establish appropriate governance arrangements.

SCF Controls: GOV-01.1, GOV-04, HRS-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.2(d)

The management body bears the overall responsibility for setting and approving the digital operational resilience strategy (Article 6(8)), including determining the appropriate risk tolerance level for ICT risk and analyzing the impact tolerance for ICT disruptions.

SCF Controls: GOV-01.1, GOV-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.2(e)

The management body shall approve, oversee and periodically review the implementation of the financial entity's ICT business continuity policy (Article 11(1)) and ICT response and recovery plans (Article 11(3)).

SCF Controls: GOV-01.1, GOV-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.2(f)

The management body shall approve and periodically review the financial entity's ICT internal audit plans, ICT audits and material modifications to them.

SCF Controls: GOV-01.1, GOV-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.2(g)

The management body shall allocate and periodically review the appropriate budget to fulfil digital operational resilience needs, including security awareness programmes, training, and ICT skills for staff.

SCF Controls: GOV-01.1, GOV-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.2(h)

The management body shall approve and periodically review the financial entity's policy on arrangements regarding the use of ICT services provided by ICT third-party service providers.

SCF Controls: GOV-01.1, GOV-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.2(i)

The management body shall put in place, at corporate level, reporting channels to be duly informed of ICT third-party arrangements, material changes, and major ICT-related incidents.

SCF Controls: GOV-01.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.2(i)(i)

The reporting channels shall cover arrangements concluded with ICT third-party service providers on the use of ICT services.

SCF Controls: GOV-01.1, GOV-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.2(i)(ii)

The reporting channels shall cover any relevant planned material changes regarding the ICT third-party service providers.

SCF Controls: GOV-01.1, GOV-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.2(i)(iii)

The reporting channels shall cover the potential impact of such changes on critical or important functions, including a risk analysis summary, and at least major ICT-related incidents and their impact, response, recovery and corrective measures.

SCF Controls: GOV-01.1, GOV-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.3

Financial entities, other than microenterprises, shall establish a role in order to monitor the arrangements concluded with ICT third-party service providers on the use of ICT services, or shall designate a member of senior management as responsible for overseeing the related risk exposure and relevant documentation.

SCF Controls: GOV-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5.4

Members of the management body shall actively keep up to date with sufficient knowledge and skills to understand and assess ICT risk and its impact, including by following specific regular training.

SCF Controls: CPL-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.1

Financial entities shall have a sound, comprehensive and well-documented ICT risk management framework as part of their overall risk management system to address ICT risk quickly, efficiently, and comprehensively.

SCF Controls: RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.2

The framework shall include at least strategies, policies, procedures, ICT protocols and tools necessary to duly and adequately protect all information assets and ICT assets and relevant physical components/infrastructures from risks, damage, and unauthorized access/usage.

SCF Controls: GOV-02, OPS-01.1, RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.3

Financial entities shall minimize the impact of ICT risk by deploying appropriate strategies, policies, and tools and shall provide complete and updated information on ICT risk and their framework to competent authorities upon request.

SCF Controls: RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.4

Financial entities, other than microenterprises, shall assign the responsibility for managing and overseeing ICT risk to a control function and ensure appropriate independence to avoid conflicts of interest; they must ensure appropriate segregation and independence of functions according to the three lines of defence model or an internal risk management and control model.

SCF Controls: RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.5

The ICT risk management framework shall be documented and reviewed at least once a year (periodically for microenterprises), upon major ICT-related incidents, and following supervisory instructions or audit/testing conclusions, and continuously improved. A report on the review shall be submitted to the competent authority upon request.

SCF Controls: RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.6

The ICT risk management framework of financial entities, other than microenterprises, shall be subject to internal audit by auditors possessing sufficient knowledge, skills, expertise, and independence, commensurate to the ICT risk.

SCF Controls: RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.7

Based on internal audit conclusions, financial entities shall establish a formal follow-up process for timely verification and remediation of critical ICT audit findings.

SCF Controls: RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.8

The ICT risk management framework shall include a digital operational resilience strategy setting out how the framework shall be implemented.

SCF Controls: PRM-01.1, RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.8(a)

The strategy shall explain how the ICT risk management framework supports the financial entity's business strategy and objectives.

SCF Controls: PRM-01.1, RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.8(b)

The strategy shall establish the risk tolerance level for ICT risk, in accordance with the risk appetite, and analyze the impact tolerance for ICT disruptions.

SCF Controls: PRM-01.1, RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.8(c)

The strategy shall set out clear information security objectives, including key performance indicators and key risk metrics.

SCF Controls: PRM-01.1, RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.8(d)

The strategy shall explain the ICT reference architecture and any changes needed to reach specific business objectives.

SCF Controls: PRM-01.1, RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.8(e)

The strategy shall outline the different mechanisms put in place to detect ICT-related incidents, prevent their impact and provide protection from it.

SCF Controls: PRM-01.1, RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.8(f)

The strategy shall evidence the current digital operational resilience situation based on the number of major ICT-related incidents reported and the effectiveness of preventive measures.

SCF Controls: PRM-01.1, RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.8(g)

The strategy shall address implementing digital operational resilience testing.

SCF Controls: PRM-01.1, RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.8(h)

The strategy shall outline a communication strategy in the event of ICT-related incidents requiring disclosure (Article 14).

SCF Controls: PRM-01.1, RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.9

Financial entities may define a holistic ICT multi-vendor strategy (group or entity level) showing key third-party dependencies and explaining the rationale behind the procurement mix.

SCF Controls: RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6.10

Financial entities may, in accordance with Union and national sectoral law, outsource the tasks of verifying compliance with ICT risk management requirements to intra-group or external undertakings. In case of such outsourcing, the financial entity remains fully responsible for the verification of compliance with the ICT risk management requirements.

SCF Controls: RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 7

Financial entities shall use and maintain updated ICT systems, protocols and tools that are:

SCF Controls: GOV-15

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 7(a)

Appropriate to the magnitude of operations, in accordance with the proportionality principle (Article 4).

SCF Controls: GOV-15, GOV-15.1, GOV-15.2, GOV-15.3, GOV-15.4, GOV-15.5, PRM-01, PRM-02, PRM-03, PRM-04, PRM-05, PRM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 7(b)

Reliable.

SCF Controls: GOV-15, GOV-15.1, GOV-15.2, GOV-15.3, GOV-15.4, GOV-15.5, PRM-01, PRM-02, PRM-03, PRM-04, PRM-05, PRM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 7(c)

Equipped with sufficient capacity to accurately process data and timely provide services, and deal with peak volumes, including when new technology is introduced.

SCF Controls: GOV-15, GOV-15.1, GOV-15.2, GOV-15.3, GOV-15.4, GOV-15.5, PRM-01, PRM-02, PRM-03, PRM-04, PRM-05, PRM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 7(d)

Technologically resilient to adequately deal with additional information processing needs as required under stressed market conditions or other adverse situations.

SCF Controls: GOV-15, GOV-15.1, GOV-15.2, GOV-15.3, GOV-15.4, GOV-15.5, PRM-01, PRM-02, PRM-03, PRM-04, PRM-05, PRM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 8.1

Financial entities shall identify, classify and adequately document all ICT supported business functions, roles, responsibilities, information assets and ICT assets supporting those functions, and their roles and dependencies in relation to ICT risk. This shall be reviewed at least yearly.

SCF Controls: PRM-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 8.2

Financial entities shall, on a continuous basis, identify all sources of ICT risk, and assess cyber threats and ICT vulnerabilities relevant to their ICT supported functions and assets, and review risk scenarios regularly, at least yearly.

SCF Controls: RSK-01.1, RSK-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 8.3

Financial entities, other than microenterprises, shall perform a risk assessment upon each major change in the network and information system infrastructure, processes or procedures affecting their ICT supported functions or assets.

SCF Controls: RSK-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 8.4

Financial entities shall identify all information assets and ICT assets (including remote sites, network resources, hardware) and shall map those considered critical. They shall map the configuration of assets and the links and interdependencies between them.

SCF Controls: AST-02, AST-04, BCD-02, TPM-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that support the identification and documentation of critical technology assets, applications, services, and data within a virtualized infrastructure.

VMware vCenter maintains a real-time inventory of all managed objects, including hosts, VMs, clusters, datastores, and networks, and supports linking multiple vCenter instances for centralized inventory management. The vCenter inventory tracks multiple instances of ClusterComputeResource, ComputeResource, Datacenter, Datastore, DistributedVirtualSwitch, and Folder objects, providing a structured view of all infrastructure components. VCF Operations can export lists of resources, such as powered-off virtual machines, to CSV files for offline documentation and review.

VCF Operations includes a Business Applications feature that allows administrators to group related infrastructure objects and assign business criticality classifications. Each Business Application can be tagged with a criticality level of Critical, Medium, or Low, with Medium as the default. The Object Summary card within VCF Operations displays details including the application's source, application tag, environment, and business criticality rating. This classification capability allows infrastructure teams to maintain a structured view of which applications and their underlying resources are most important to the organization.

VCF Operations Service Discovery automatically detects running services across the environment. Service Discovery displays a list of all supported services that can be discovered and those currently discovered on VMs once configured. It also discovers performance metrics for individual service objects and service type objects, maintaining a catalog of known services and their relationships to underlying infrastructure. This automated discovery reduces manual effort in maintaining an accurate asset inventory.

VCF Operations also provides alert definitions with configurable Impact and Criticality metadata. The Impact setting can be configured to values such as Risk to indicate potential problems, while the Criticality setting can be set to values like Immediate for proper alert prioritization. Alert notifications can be filtered by impact category and criticality level, helping teams classify infrastructure resources by their importance and focus attention on the most important infrastructure components. VCF Operations Insights data tracks resource capacity and can notify project owners of changes affecting their assets.

VCF Automation provides complementary asset identification capabilities through its resource discovery and tagging system. The discovery process automatically identifies machines, storage volumes, networks, load balancers, and security groups for each cloud account region that has been added. Once discovered, these resources can be organized using tags that facilitate search and identification. Tags placed on cloud zones, network profiles, storage profiles, and individual infrastructure resources function as capability tags that define desired capabilities and support governance by expressing capabilities and constraints. Using logical, human-readable tags for storage, network, and infrastructure items is recommended to facilitate search and identification functions.

VCF Automation organizes infrastructure through projects, which link users, catalog items, and IaaS resources to the locations where items are deployed. The Overview tab displays infrastructure and consumption metrics, providing a consolidated view of resource usage. Resource details views support filtering based on attributes such as project membership, enabling administrators to locate and review specific subsets of the infrastructure.

Blueprints in VCF Automation allow users to model complex IT services by visually designing infrastructure components such as VMs, networks, storage, and software components. Resource objects in blueprints represent the infrastructure components and services that are provisioned and managed, providing an architectural record of how assets support business functions.

Together, these inventory, discovery, classification, tagging, and visualization capabilities give operations teams the tools to identify, classify, and document the technology assets that support essential business functions. However, VCF provides the technical tooling for asset identification and classification rather than the organizational processes needed to define which assets are critical to the business mission. Establishing criticality criteria, maintaining asset documentation, and conducting periodic reviews of critical asset designations require organizational processes that operate alongside the platform's capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to identifying and documenting critical technology assets through the Security Services Platform (SSP) and its Security Intelligence feature, which provide asset inventory, classification, and visualization capabilities oriented toward network security segmentation planning.

Security Services Platform maintains a Platform Inventory of infrastructure assets, collecting status information for each asset including identification of assets that are timed out or out of sync. The inventory view provides filtering by Name and Status to locate specific infrastructure assets and identify their operational state. Tags assigned to each infrastructure asset are displayed for verification of tag assignments.

Security Intelligence gathers infrastructure services and servers from CSV files and discovers additional services and servers based on traffic flows analyzed from ESX hosts. During CSV import, Security Intelligence parses and validates the content format and inventory asset data. Security Intelligence also maps discovered unique assets during segmentation analysis, including workloads, groups, IP addresses, distributed virtual port groups (DVPGs), segments, tiers, infrastructure services, and infrastructure servers.

Security Services Platform identifies and publishes application assets, classifying them as either critical or regular applications. This criticality classification supports the identification of mission-critical technology assets within the environment. The inventory hierarchy spans regions, zones, environments, applications, and tiers, with each level displaying the total number of assets within its scope.

Security Intelligence organizes discovered and imported assets into structured Asset Collections: groups, infrastructure assets, environments (such as Production, Non-Prod, DMZ, PCI, and Development), applications, and application tiers. The Environment Asset Collection maps security zones to the operational contexts that support business functions. Application Asset Collections group workloads that provide enterprise functionalities, linking infrastructure resources to the business services they support. The Infrastructure Asset Collection node covers core networking services that enterprise workloads depend on, including LDAP, DNS, NTP, and DHCP. An Unknown Asset Collection surfaces compute entities that are not in the NSX inventory but are present in the data center and communicating to NSX entities, supporting discovery of assets that should be formally inventoried.

Security Intelligence Workload Classification can be set to "Infrastructure Service" to indicate that a compute entity provides infrastructure services such as DNS, DHCP, LDAP, and Syslog. Inferred infrastructure classifications for compute entities can be reviewed, accepted, or modified through the Monitor & Plan > Security Explorer interface.

These capabilities contribute to the control but do not fully satisfy it. vDefend's asset identification is scoped to network security segmentation planning rather than the enterprise-wide technology asset catalog this control requires. Identifying all critical technology assets, applications, services, and data across an organization requires broader inventory and configuration management capabilities within VCF, such as VCF Operations business application views, VMware vCenter inventory exports, and VCF Automation project tagging, which provide the enterprise-wide asset catalog that vDefend's security-focused inventory complements.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) organizes its protection model around identifying which assets are critical enough to warrant disaster recovery protection. Protection groups are an explicit declaration of critical assets, organizing virtual machines into logical units based on their replication and recovery requirements. Placing a workload in a protection group is a deliberate act of classifying it as essential to business operations.

Inventory mappings document how each protected-site asset (resource pools, folders, networks, datastores) corresponds to recovery-site resources, creating a structured record of the infrastructure that supports critical workloads. Site-wide inventory mappings apply defaults across all protected VMs, while per-VM customizations document specific recovery configurations for workloads with unique requirements.

The Protection and Recovery Configuration Import/Export Tool exports a complete record of the DR asset inventory, including site names, inventory mappings, placeholder datastores, advanced settings, array managers with SRA information, protection groups, and recovery plans. This export provides a structured, portable document of which assets are protected and how they are configured for recovery. The export is produced in XML format, enabling automated processing and retention as a configuration record.

PNR generates and exports reports documenting each run of a recovery plan, each test of a recovery plan, and each test cleanup operation. These reports provide an auditable record of which recovery plans executed and which protected workloads were involved.

PNR tracks site metrics including paired sites, pair names, vCenter addresses, site connectivity status, and counts of protection groups, recovery plans, protected virtual machines, and array managers. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, providing consolidated visibility into the DR infrastructure as a class of managed assets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an allowedInfrastructurePolicies list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 8.5

Financial entities shall identify and document all processes that are dependent on ICT third-party service providers, and shall identify interconnections with providers supporting critical or important functions.

SCF Controls: AST-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 8.6

For the purposes of paragraphs 1, 4 and 5, financial entities shall maintain relevant inventories and update them periodically and every time a major change (paragraph 3) occurs.

SCF Controls: AST-02, AST-02.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. `ResourceAttribute` elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization

maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure

state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator

creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 8.7

Financial entities, other than microenterprises, shall on a regular basis, and at least yearly, conduct a specific ICT risk assessment on all legacy ICT systems and before and after connecting technologies, applications or systems.

SCF Controls: RSK-04, SEA-02.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 9.1

Financial entities shall continuously monitor and control the security and functioning of ICT systems and tools and shall minimize the impact of ICT risk through the deployment of appropriate ICT security tools, policies and procedures.

SCF Controls: OPS-01, OPS-02, OPS-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 9.2

Financial entities shall design, procure and implement ICT security policies, procedures, protocols and tools that aim to ensure the resilience, continuity and availability of ICT systems (especially for critical/important functions), and to maintain high standards of availability, authenticity, integrity and confidentiality of data.

SCF Controls: OPS-01, OPS-01.1, OPS-02, OPS-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 9.3

Financial entities shall use appropriate ICT solutions and processes that:

SCF Controls: GOV-15

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 9.3(a)

Ensure the security of the means of transfer of data.

SCF Controls: CFG-01, CFG-02, SEA-01, SEA-02, SEA-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 9.3(b)

Minimize the risk of corruption or loss of data, unauthorized access and technical flaws.

SCF Controls: CFG-01, CFG-02, SEA-01, SEA-02, SEA-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the `Security.PasswordQualityControlPwquality` setting on ESX hosts, including parameters such as `minlen=15`, `maxrepeat=3`, `maxclassrepeat=4`, `difok=4`, and `enforce_for_root`. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 9.3(c)

Prevent the lack of availability, the impairment of the authenticity and integrity, the breaches of confidentiality and the loss of data.

SCF Controls: CFG-01, CFG-02, SEA-01, SEA-02, SEA-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 9.3(d)

Ensure that data is protected from risks arising from data management (e.g., poor administration, processing risks, human error).

SCF Controls: CFG-01, CFG-02, SEA-01, SEA-02, SEA-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 9.4

As part of the ICT risk management framework, financial entities shall:

SCF Controls: GOV-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 9.4(a)

Develop and document an information security policy defining rules to protect the availability, authenticity, integrity and confidentiality of data, information assets and ICT assets.

SCF Controls: GOV-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 9.4(b)

Following a risk-based approach, establish a sound network and infrastructure management structure using appropriate techniques, methods and protocols that may include implementing automated mechanisms to isolate affected information assets in the event of cyber-attacks.

SCF Controls: IRO-01, IRO-02, IRO-02.1, IRO-02.6

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several mechanisms for automatically disabling technology assets, applications, and services upon detection of incidents, while preserving the ability to perform forensic analysis.

VMware vCenter alarms can be configured to trigger automated actions when specific conditions are detected on infrastructure objects. When an alarm fires, it can execute scripts, send SNMP traps, or invoke API-driven workflows. The AlarmSpec data object lets administrators define trigger conditions and associate them with actions that run automatically when the alarm becomes active. This allows organizations to build automated responses that power off, suspend, or isolate VMs based on their own criteria.

VCF Operations extends this with automated remediation tied to alert definitions. When an alert's first-priority recommendation is an action, VCF Operations can execute that action automatically. Automation Central provides built-in vCenter adapter actions including Power Off VM, Suspend VM, Power On VM, and Reboot Guest OS, which can be scheduled or triggered as part of automated jobs. The Management Pack for Automation Orchestrator allows custom workflows to be mapped to alert actions, so that when VCF Operations detects a condition, it can trigger an Orchestrator workflow that performs any sequence of operations on the affected assets. Orchestrator policies can also trigger predefined workflows or scripts in response to events, providing another path for automated incident response. Administrators can build workflows that suspend a VM, take a snapshot for forensic preservation, and then isolate the workload from the network, all without manual intervention. When an application service is identified as compromised or suspect, VCF Operations can deactivate the application service to stop monitoring data collection from that service, which can be part of an automated response to isolate affected components. Maintenance schedules can be configured to account for assets intentionally taken offline during incident response, preventing misleading monitoring data from generating false alerts during forensic analysis activities.

VCF Automation includes a policy enforcement engine that allows organization administrators to configure and enforce IaaS resource policies across various namespaces. These policies can automatically disallow provisioning of VM resources using out-of-the-box policy templates such as the disallow-vm-resource template. When an incident is detected or a policy condition is triggered, these enforcement rules restrict further resource creation without manual intervention, containing the scope of a potential incident. Organization administrators can configure these policy rules across namespaces to control whether users can create resources for all services or limit them to specific service subsets such as VM Service or Kubernetes Service.

VCF Automation blueprints support a metadata specification with deploymentSettings that can disable or hide day-2 operations for users on affected deployments. This allows administrators to lock down operational actions on compromised or suspect resources, preserving their state for forensic examination. Deployment-level actions can also be used to power off or delete affected deployments when an incident warrants taking resources offline. VCF Automation organizations can be disabled entirely when a broader containment response is needed, and organizations must be disabled before they can be deleted, providing a controlled decommissioning path. VCF Automation for VM Apps also supports day-2 resource actions including Power Off, Suspend, Delete, Create Snapshot, and Reboot, which can be invoked programmatically through the Automation API to disable or preserve assets as part of an automated incident response workflow.

At the Kubernetes workload layer, VMware Kubernetes Service (VKS) and vSphere Supervisor provide API-accessible mechanisms for disabling workloads and services in response to detected incidents. Kubernetes Deployments can be scaled to zero replicas through the Kubernetes API, stopping all running pod instances while preserving the Deployment object and its configuration for forensic review and later restoration, which is preferable to outright deletion when evidence preservation

is required before shutdown. NetworkPolicy and Antrea NetworkPolicy objects can be applied to restrict ingress and egress traffic to a specific namespace or set of pods, isolating a workload from the network without terminating it to support forensic capture of running process state. Supervisor administrators can deactivate Supervisor Services, which blocks DevOps teams from deploying or consuming specific service versions while leaving existing instances available for investigation. For cluster-level incidents, a TanzuKubernetesCluster can be retired by setting the annotation `kubernetes.vmware.com/retire-tkc=force`, bypassing pre-checks when immediate action is needed. ArgoCD, when deployed as a Supervisor Service, supports disabling an ApplicationSet by setting `spec.applicationSet.enabled` to false, halting GitOps-driven deployments into the affected environment. All of these operations are available through the Kubernetes API and can be invoked programmatically by an external security monitoring system, SIEM, or security orchestration platform that detects the triggering incident. Supervisor's Kubernetes RBAC model supports creating service accounts with narrowly scoped permissions for incident response automation, so the automated system performs only the operations needed for disabling affected assets without broader administrative access. The Kubernetes API server records all API calls, including caller identity, the resource acted upon, and the action taken, in its audit log, creating a durable forensic trail of all disabling operations.

At the hypervisor layer, the VMware ESX Agent Manager provides programmatic methods for disabling ESX agencies. The `Agency.disable()` method disables the ESX agency and powers off the ESX agent virtual machines without undeploying them, preserving the agent VM state for forensic analysis while stopping the agency from executing. vSphere also provides the `isolation.device.edit.disable` setting, which restricts modification of devices on virtual machines, helping to preserve the state of potentially compromised workloads during an investigation.

For forensic preservation, vCenter supports VM snapshots that capture memory, disk, and configuration state at a point in time. Reverting to a snapshot returns all memory, disk, and settings to the state they were in when the snapshot was taken. vSAN provides immutable snapshots, which are read-only copies of data that cannot be modified or deleted, even by an administrator with elevated privileges. These immutable snapshots help protect forensic evidence from tampering during investigation.

VMware vDefend (Contributes)

VMware vDefend contributes to the automatic disabling and isolation of technology assets upon incident detection through automated response mechanisms that operate at the network layer. VM-level disabling actions such as power off, suspend, and snapshot are handled by VMware vCenter and VCF Operations rather than by vDefend directly.

The vDefend Distributed IDS/IPS provides automated traffic blocking when configured in Detect and Prevent mode. When intrusions are detected against known signatures, the IDS/IPS engine automatically drops or rejects the offending packets depending on the signature configuration, stopping malicious traffic from reaching or leaving affected workloads without requiring manual intervention. Administrators can configure signature actions to Alert (detection only), Drop (silently discard packets), or Reject (discard packets and send TCP reset), allowing granular control over which detected threats trigger automatic blocking. IDS/IPS event monitoring records the Signature Type for each detected event, distinguishing between System and Custom signatures, which supports post-incident investigation of the detection chain. vDefend IDS/IPS can also store matched files to disk for forensic analysis, preserving evidence of the file transfers that triggered detection.

IDS/IPS rate filters provide threshold-based automatic escalation. When a source IP address triggers a rule more than a configurable number of times within a defined time window (default: 10 matches within 60 seconds), the rate filter automatically switches the rule action to Drop for future matching traffic. The rate filter remains active for a configurable timeout period of up to 3600 seconds before reverting. This mechanism provides automatic escalation from alerting to blocking when repeated malicious activity is detected, effectively disabling network access for the offending source without manual intervention.

The vDefend distributed firewall and Gateway Firewall both support an Emergency rule category designed for quarantine and incident response scenarios. Administrators pre-configure quarantine rules in the Emergency category that can isolate compromised workloads by restricting their network connectivity. The Emergency category takes the highest precedence in the DFW rule table, so quarantine rules in this category override all other firewall policies when triggered. These rules restrict a workload's ability to communicate on the network while preserving the workload for forensic analysis.

Intelligent Assist automates the creation of remediation policies in response to detected security events. When IDS/IPS, malware, or network anomaly events are detected, Intelligent Assist can automatically generate vDefend policies. For non-IDS/IPS events such as malware detections, Intelligent Assist creates policies and rules in the Emergency section of the DFW rule table. The Comprehensive remediation strategy creates DFW policies that provide broader protection against similar attacks, reducing the time between detection and network-level isolation of affected workloads.

The Malware Prevention Service inspects files and assigns verdicts with risk scores, blocking malicious files from being transferred across the network. When configured on the Distributed Firewall, the service intercepts file transfers and subjects them to static and dynamic analysis, blocking files determined to be malicious. The service logs the full file analysis lifecycle to syslog, recording file intercepted, verdict cache hit, file sent for local static analysis, file sent for cloud dynamic analysis, verdict obtained, and policy enforced events. This chain of logged events supports audit trails and forensic investigation following a malware detection. Analysis reports categorize suspicious behaviors detected during artifact inspection into structured behavioral classifications, including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced categories, providing structured evidence of how a detected artifact behaved.

These capabilities provide the automated network-level isolation and traffic blocking components of an incident response workflow. The broader asset disabling actions described in this control, such as powering off VMs, suspending workloads, and creating forensic snapshots, are handled by vCenter alarms and VCF Operations automated remediation actions working with vDefend's detection and network isolation capabilities.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides automated mechanisms at the application delivery layer that contribute to the incident handling process. The Avi Controller's Alert and ControlScript framework is the primary automation vehicle: when system events occur (pool health changes, Service Engine state transitions, WAF rule matches, or traffic anomalies), Avi processes those events and metrics against user-defined rules, generating alerts that initiate configured actions such as

sending an email, a syslog message, or an SNMP trap. These events serve as the building blocks of configuration automation and can trigger ControlScripts without manual administrator intervention.

ControlScripts are Python or shell scripts executed in response to alert conditions, configured through the Avi Controller's Alert Actions settings. They support several automated response patterns relevant to incident handling: modifying pool priority to initiate failover when a pool goes down, adding or removing routes based on VIP attachment and detachment events, and performing CRUD operations against Avi infrastructure through the Avi APIs and SDKs. The SE-Log-Agent within each Service Engine maintains a queue for logs, batches them from all Service Engine processes, and forwards them to the log manager in the Avi Controller, providing a continuous log stream that underpins these automated workflows.

At the application security layer, the Avi Web Application Firewall (WAF) feeds the incident detection pipeline. The Avi Service Engine logs events when WAF matches a transaction, and WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, including an assisted workflow for reviewing and applying those exceptions. Bot Management adds a Consolidator agent that evaluates results across all detection components, inspecting data for contradictions and irregularities, and classifies client types to provide automated threat classification that can inform incident response workflows.

For incident documentation and external integration, the Avi Controller provides Syslog-Audit-Persistence for streaming audit compliance events to external syslog servers, supporting integration with centralized logging and SIEM platforms. Python with the Avi SDK can be integrated into CI/CD pipelines and event-driven workflows to provision Avi infrastructure, monitor load balancer events, analyze logs, and trigger alerts based on specific Avi events. Ansible modules for Avi automatically handle error reporting and retries, logging failures for graceful management within automation workflows.

Broader incident orchestration, case management, and cross-domain response coordination depend on integrations with external SIEM, ITSM, and security orchestration platforms, and on VCF platform-level automation capabilities. Organizations are responsible for defining the ControlScript workflows, alert thresholds, and external integration endpoints that activate these automated mechanisms.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 9.4(c)

Implement policies that limit the physical or logical access to information assets and ICT assets to what is required for legitimate and approved functions and activities only.

SCF Controls: IAC-21

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces least privilege through a granular role-based access control (RBAC) model that spans all major platform components. Permissions are scoped both by function and by inventory location, so users can perform only the activities specified by the role assigned to them on the specific object to which that role is assigned.

VMware vCenter implements a privilege model where privileges are system-defined requirements associated with vSphere managed objects. These privileges are defined by VMware and cannot be changed by client applications, which means the privilege boundaries are enforced at the platform level. Privileges are fine-grained access controls that can be grouped into roles, providing precise control over what actions each user can perform. Users are granted access through roles, which are predefined sets of privileges mapped to users or groups on specific objects.

vCenter ships with several built-in roles that enforce varying levels of access restriction. The three permanent system roles, Administrator, Read Only, and No Access, cannot be deleted or edited; new users and groups are assigned the No Access role by default, so access must be explicitly granted before a user can view or change any object. The Read Only role grants only three system-defined privileges: System.Anonymous, System.View, and System.Read. The Operator role is the most restricted authorization level available, allowing users to view information about vCenter but not alter its configuration. For cryptographic operations, a dedicated No Cryptography Administrator role provides all Administrator privileges except Cryptographic Operations, so that only users explicitly assigned the Cryptographic Operations privileges can perform encryption-related tasks. If a predefined role does not meet specific needs, administrators can create custom roles containing only the minimum set of required privileges. For users who require administrative access to virtual machine configuration but should not be able to run commands inside a guest operating system, the platform supports creating a custom role that excludes the Virtual machine > Guest operations privilege.

vCenter also provides a privilege check recording feature that monitors which privileges are checked during vCenter operations. The PrivilegeChecks service interface provides operations for retrieving a list of the latest privilege checks along with the corresponding sessions, users, managed objects, and operation IDs. Administrators can use this capability to identify which privileges are actually exercised during a workflow and build roles with only the minimum privileges needed for specific operations.

VCF Operations implements its own RBAC system where users can only perform the actions that their permissions allow. The ReadOnly role provides read-only access, allowing users to perform read operations but restricting write actions such as create, update, or delete. The VCF Operations documentation recommends that the administrators role be assigned only to specific users who must access objects and perform actions across the entire environment. Local VCF Operations users and vCenter users should be configured with the specific privileges required for their role to avoid unexpected access from overly permissive role assignments. Even integration adapters follow least privilege principles: the Management Pack for Oracle Database, for example, requires creation of a least-privileged user with minimum database user privileges. The Management Pack for Kubernetes similarly requires that user-defined custom roles provide read-only access to all cluster resources and the Kubernetes API.

VCF Automation supports organization-specific roles that can be assigned only to users within the organization to which they belong. Organization users can use only those rights from their roles that are published to their organizations. Organization administrators can create custom roles to grant selected users permissions to perform specific tasks or access content outside of their default organization roles, enabling precise scoping of access. System administrators manage access to projects and catalog items through entitlement policies using user criteria, providing another layer of access control that restricts what

resources users can request and consume. The `cloud_admin` service role satisfies the minimum service role requirement for VCF Automation API access, and the `Cloudadmin` role provides host switch-level permissions within VCF Automation.

At the Consumption layer, VMware Kubernetes Service (VKS) and vSphere Supervisor implement two complementary tiers of least privilege: namespace-level permissions and Kubernetes RBAC within clusters. vSphere Namespace permissions for VCF SSO users and groups are assigned through three roles: Can View (read-only access to VKS cluster objects provisioned in the namespace, with no permissions mapped to Kubernetes roles within those clusters), Can Edit (modification rights), and Owner (full administrative control). The VCF Consumption CLI enforces these role assignments at the API boundary; VCF SSO users who lack sufficient permissions on a vSphere Namespace receive an "Error from server (Forbidden)" response and cannot connect to Supervisor or VKS clusters. Administrative operations on Supervisor Services require a discrete "Manage Supervisor Services" privilege on VMware vCenter, scoped separately from general vSphere Administrator access. Content library administration similarly requires specific permissions beyond the vSphere Administrator role, with individual permissions assignable through custom roles when the full Administrator role is not appropriate.

Within VKS clusters, Kubernetes RBAC provides fine-grained access control through Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings. RBAC rules are expressed in terms of specific resource types and verbs (get, list, create, delete, and so on), with guidance that specific resources and verbs be used rather than wildcard entries, so only the permissions required for a workload to function correctly are applied. Platform Operators and DevOps users are assigned non-admin or custom roles scoped to their responsibilities; Developer users receive read-only or no roles by default. Kubernetes RBAC supports least privilege for ServiceAccounts as well: by creating ServiceAccounts with narrow RBAC bindings and attaching them to workloads, pods operate with only the permissions they require rather than inheriting broad cluster-level access. Separating ServiceAccount creation from human user onboarding makes it practical to maintain least privilege for automated workloads independently of human access management. RBAC should be used to enforce least-privilege access to Secret objects specifically, given the sensitive nature of credential material. Administrators can use `kubectl auth can-i` with user impersonation to verify what actions other users can perform, supporting least privilege verification without requiring direct credential access. IAM role trust policies in the Consumption layer should be scoped to specific service accounts and namespaces to enforce least privilege boundaries at the identity-to-workload level. Kubernetes RBAC enforces binding constraints: a user creating or updating a RoleBinding or ClusterRoleBinding can only grant permissions they themselves hold, and a user creating or updating a Role or ClusterRole cannot add permissions beyond their own. Where limited delegation is needed, the `bind` verb can be scoped to specific named roles, so administrators cannot delegate access beyond what they are themselves authorized to grant. Periodic review of RBAC settings for redundant entries and potential escalation paths supports ongoing least-privilege hygiene.

VKS clusters apply least privilege at the workload level through Pod Security Admission (PSA). PSA supports three profiles: Privileged (unrestricted, permits known privilege escalations), Baseline (minimally restrictive, blocks known privilege escalation vectors while allowing the default minimal pod configuration), and Restricted (a hardened profile that follows least privilege, requiring non-root execution and restricting Linux capabilities). The Restricted profile is the recommended target for workloads that should operate with least privilege. Kubernetes also allows granting specific Linux capabilities to a container process without granting all privileges of the root user, enabling capability-level access scoping for workloads that require specific kernel permissions without full privilege. The Supervisor secret injection agent runs with `allowPrivilegeEscalation` set to false, blocking privilege escalation at the platform component level. Cluster administrators should understand privilege escalation paths introduced by create and update permissions on workloads that can reference arbitrary ServiceAccounts, and should restrict those permissions accordingly.

Centralized authentication through VCF SSO means that privilege assignments are consistently enforced across vCenter, VMware ESX, NSX, and VCF Operations. VCF Operations integrates with VCF SSO for centralized user and group authentication and management, and supports single sign-on to enable secure user login.

The platform documentation explicitly recommends that user accounts be given the minimal number of privileges required to perform their assigned tasks. When predefined roles are too permissive for a given use case, custom roles should be created containing only the minimum set of required privileges. For Kubernetes environments, administrators are directed to use a least-privileged `kubeconfig` for routine operations and to reserve break-glass access only for emergency situations.

VMware Private AI Services (PAIS) supports the concept of least privilege through a layered set of access controls that scope permissions to specific roles, groups, and project membership across the AI platform.

PAIS access is controlled through OIDC group-based authorization. The `authorizedGroups` configuration specifies which OIDC groups may access PAIS endpoints, and only user accounts that are members of those groups can reach the service. The same model applies whether activation is performed through the VCF Automation UI (via the `oidc-authorized-groups` setting) or through `kubectl`. PAIS activation requires coordination with the OIDC provider administrator to define identity and access management before users can be granted access.

Access to AI catalog items in VCF Automation is gated by explicit permission grants. DevOps engineers and other consumers must receive permission from an organization administrator before they can request GPU-accelerated VMware Kubernetes Service (VKS) clusters or deep learning VM catalog items. When importing PAIS namespaces from VMware VCF Automation 8.18 into VCF Automation, users with the Project Viewer role must be reassigned the Project Auditor role, scoping read-only access to the new tenancy model.

For ML model storage in Harbor, PAIS scopes access at the project level. Harbor project read-write permissions are required to store models, restricting access to sensitive training and tuning data by Harbor project role. Only users with assigned project roles can push or pull model artifacts.

Role assignment for AI workload deployment is explicit and requires an authorized administrator. The organization administrator must assign the required user role before users can deploy deep learning VMs, and VI administrators must have appropriate permissions on the underlying vSphere cluster to deploy DL VM templates. VCF Automation uses separate scoped tokens for provider-level and tenant-level operations: a `PROVIDER_ADMIN_ACCESS_TOKEN` for provider scope and a `TENANT_ADMIN_ACCESS_TOKEN` for organization administrator scope, keeping administrative privileges partitioned by function.

The Grafana observability layer for PAIS supports role-based access through OIDC group mapping. The `grafana-oidc-role-mapping` configuration assigns the Admin role to users matching a designated OIDC group attribute and the Viewer role to other authenticated users, scoping write access to the observability platform to a named administrator group.

Deep Learning VM deployment uses restricted cloud-init file permissions to control access to initialization and workload execution code, with executable permissions (0755) for application scripts and restricted permissions (0600) for network configuration files. When configuring external data sources for Knowledge Bases, PAIS specifies that the integration service account should be created with no assigned roles as its starting state, and Google Drive folders used as data sources must be shared with the service account using view-only permissions.

Tenant isolation extends to compute allocation: organization region quotas in PAIS can be assigned from single or multiple supervisors, with CPU and memory limits and reservations configured per zone, scoping resource consumption to the limits set by the provider administrator.

VMware vDefend (Contributes)

VMware vDefend implements the principle of least privilege at two levels: network access control for workloads and role-based access control for its own administrative interfaces.

At the network layer, the vDefend distributed firewall (DFW) restricts workload-to-workload communication to only those flows explicitly permitted by policy. Default-deny rule bases mean no network path is open unless a rule specifically allows it. Microsegmentation policies can be scoped to individual workloads, security groups, or application tiers, so each workload receives only the network access required to function. Governance guidance in the 9.1 documentation advises administrators to avoid overly permissive rules such as "ANY/ANY/ANY ALLOW" and to define rules that permit only the specific protocols, ports, and source-destination pairs each application needs.

A new capability in 9.1, Privileged Labels, strengthens workload-level least privilege by anchoring firewall rules to immutable, organization-defined labels that namespace users cannot remove from virtual machines. This mechanism keeps workloads within their assigned security groups so they remain subject to the applicable firewall policies regardless of attempts by lower-privileged namespace users to move them out of scope.

For administrative access to vDefend itself, Security Services Platform (SSP) enforces role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Role permissions are differentiated by operation: the Enterprise Admin role holds Full Access (FA) to deploy, manage, upgrade, configure authentication and authorization, perform server configuration, and activate Security Intelligence for SSP. The Security Operator role holds Restricted (R) permissions covering Security Intelligence data collection configuration, infrastructure and environment monitoring, and segmentation policy publication, without access to service activation or administrative configuration. Enterprise Administrator privileges are specifically required for high-privilege operations including activating the Malware Prevention Service, deleting Malware Prevention Service features, and accessing User Management to modify role assignments. Administrative privileges are also required to administer compute entity classifications in Security Intelligence. The same five-role structure governs Security Intelligence and Rule Analysis operations within SSP, with each role receiving only the permissions appropriate to its function.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports least privilege through role-based access control with a defined set of predefined roles and the ability to clone and customize roles for narrower operational scope. The 9.1 release consolidates Site Recovery Manager and vSphere Replication management under a single permissions model where PNR augments vCenter roles and permissions with additional permissions that allow detailed control over PNR-specific tasks and operations. PNR also verifies permissions on the remote vCenter instance as part of its access control validation, so privilege assignments are evaluated at both sites.

By default, PNR restricts login access to vCenter administrators; other users must be explicitly granted access by an administrator through the PNR interface. Users or user groups assigned a PNR role who are not vCenter administrators do not obtain vSphere Replication privileges, because PNR roles do not include the privileges of vSphere Replication roles. A user who is not a vCenter administrator but requires privileges to perform both PNR and vSphere Replication operations should be added to two user groups, one for each role type, to avoid granting vCenter administrator privileges.

vSphere Replication uses role-based access control with predefined roles that can be cloned and customized by adding or removing privileges based on organizational needs. PNR supports role propagation to child objects in the inventory hierarchy, allowing administrators to extend privileges from parent objects such as folders to all virtual machines within them, or to assign permissions at specific inventory levels without propagation when narrower scope is required. When permissions are assigned without propagation, users must have at least Read-only permission on all parent objects in the vCenter inventory.

PNR for VCF Automation access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, aligning RBAC with VCF Automation tenancy boundaries. Namespace unpair operations require Organization Administrator role authorization. In shared recovery site configurations, PNR restricts users from changing roles or assigning permissions for objects not dedicated to their own use, which helps prevent unauthorized privilege escalation across tenants, and the vCenter administrator manages PNR permissions so that each user has sufficient privileges to configure and use PNR but no user has access to resources belonging to other tenants.

PNR requires separate privilege assignment for testing a recovery plan and running a recovery plan, which helps prevent unintended changes at both sites that would require significant time and effort to reverse. PNR roles that allow users to run commands on PNR Server should be assigned to trusted administrator-level users only, and PNR server access should be limited to administrators to reduce the number of accounts available to an attacker. PNR administrators can assign SrmAdministrator or SrmProtectionGroupsAdministrator roles to the automatic protection user or user groups for managing automatic protection permissions.

For the 9.1 Clean Room Orchestrator, at least one user must be assigned the Organization Owner role to enable administrative access to all resources in the Organization, with additional roles available for narrower delegation. VCF Operations orchestrator workflows for PNR require administrator credentials to access and execute, which restricts non-administrative users from performing sensitive recovery operations through the orchestration interface.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) implements least privilege across its two primary user roles: Admin and User. The separation is enforced at the platform level and reflected throughout the console interface.

Users assigned to the DSM User role can view and manage only the database objects they own. They cannot access or modify objects belonging to other users or manage platform-wide configuration. The DSM console restricts the views and actions available based on the assigned role, so User-role accounts see only the subset of the interface relevant to their scope. Administrators have access to the full environment and can create, monitor, and manage all data services, but this elevated scope is reserved for accounts explicitly assigned to the Admin role.

User and role management is performed through the vSphere Client Permissions interface under the Data Services Manager Configure tab. Administrators can create local users through the DSM UI and assign namespace access through the Permissions view. DSM also supports LDAPS-sourced identities, allowing organizations to map directory service groups to DSM roles and manage access centrally. DSM clears the VMware vCenter administrator credentials secret after successful registration, limiting credential exposure during the initial configuration process.

DSM applies least privilege at the database level across all supported database engines. PostgreSQL database instances support the GRANT command to assign specific privileges on databases and schemas to individual database users. LDAPS-authenticated PostgreSQL users can be granted specific privileges, including database-level and schema-level access, through explicit GRANT assignments. MySQL LDAPS-authenticated users can be granted specific privileges using the GRANT command to restrict access to designated databases. The default MySQL database user is not a MySQL superuser; it is granted a defined set of privileges for data and schema operations, limiting access to what is required for typical database management. Only the database owner can perform administrator password changes on a given instance, restricting credential management to the party responsible for that database.

For SQL Server instances, DSM creates a cluster administrator login that does not receive full sysadmin privileges. Instead, DSM grants this login restricted server-level privileges for server management and auditing operations, such as the ability to alter connections and view server state. DSM maintains a separate `dsm_mgmt` internal management login that restricts user access to system-level objects, keeping administrative operations within an isolated context. SQL Server instance provisioning and server-level configuration management, including Active Directory integration and high availability settings, is restricted to DSM administrators only.

VCF Automation namespaces that are externally managed in DSM are treated as read-only, restricting modifications to objects whose lifecycle is governed outside DSM. Infrastructure policy configuration requires that the responsible administrator hold the appropriate DSM permissions. These constraints limit what each actor in the system can modify based on their role and the ownership of the resources involved.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides native role-based access control (RBAC) at the Avi Controller level, covering administrative access to all Avi-managed resources including virtual services, pools, application profiles, certificates, and GSLB configuration. The RBAC framework supports four access types per resource: Write (full create, read, modify, and delete access), Read (view-only access to configuration, health, and analytics data without modification capability), No Access (complete exclusion, including inability to read or list the resource), and Assorted (a mixture of different privilege levels for different resources within a system area). These types are assigned per resource, so a given role can combine read-only access to some areas with full write access to others. The Avi Controller enforces these constraints at runtime; users can access resources only to the extent their assigned role permits.

When predefined privilege levels do not match the access needs of a particular user account, the Avi Controller supports custom role creation. Administrators create roles that specify a targeted combination of write, read, no-access, or assorted permissions for each resource area. This is configured in the Avi Controller UI under User Authentication and Authorization > User Roles. The Avi documentation recommends creating custom users and roles with limited privileges when the use case does not require System-admin or admin access, rather than assigning broad administrative rights.

The Extended Granular RBAC feature adds label-based scoping to access control. The `allow_unlabelled_access` parameter on a role object controls whether users assigned that role can see resources that have not been tagged with labels, enabling

access to be scoped to specific application groups or object subsets rather than the entire Controller inventory. Certain permissions classified under Operations and Administration are not supported for role-based access control per application using labels; those must be managed at the global role level. For Auth Mapping Profile configurations, the role and tenant configured for the Any Group or Any Attribute rule should be set to least privilege, as the least-privileged access takes effect after login when no specific group match exists.

Certificate and key management access is subject to RBAC restrictions. The Avi Controller documentation specifies that the ability to export certificates and keys must be restricted to the fewest number of administrators possible using role-based access control. Write access to Virtual Service, Application Profile, SSL/TLS Certificates, and Certificate Management Profile objects can be scoped to specific roles without granting broader administrative rights.

GSLB administration is covered separately within Avi's RBAC. Roles can be created that grant write access only to GSLB service resources without providing broader Controller-level access. For GSLB scenarios that do not require System-admin or admin user privileges, Avi's documentation recommends creating a custom user and role with limited permissions rather than assigning the full System-Admin role. Avi GSLB supports creation of non-admin users with assigned roles for granular access control.

In VCF deployments using organization-managed mode, Avi Load Balancer applies a tiered administrative model. The Provider or Load Balancer Administrator manages resource assignments to organizations and enforces quotas and resource boundaries. An organization administrator must be logged in to edit a Service Engine Group. Project Administrators can deploy and manage load balancing for their applications without waiting for organization administrator intervention, while being restricted from altering Service Engine Group properties such as capacity and placement. This model maps load balancing management authority to the appropriate organizational scope.

At the integration boundary with VMware vCenter, the Avi Cloud Connector uses a vCenter user account that must have only the minimal set of permissions Avi requires. Two roles must be created for the vCenter Cloud Connector integration: one with global privileges (Avi-Global-Role) and another with folder-level privileges (Avi-Folder-Role). The Avi-Global-Role must be assigned with the Propagate to children option selected to apply permissions to all child objects. The vCenter account user must be assigned the Avi-Folder-Role to the folders containing Service Engine VMs in the vCenter inventory. vCenter cloud access modes include no-access (Avi Controller has no access to vCenter resources), read-access (integration with read-only access), and write-access (full automation of Service Engine creation and placement), allowing deployments to operate with the minimum vCenter access level needed for the deployment scenario.

Least privilege for the compute, storage, and network fabric underlying the Avi Controller and Service Engine virtual machines is a VCF platform responsibility. Organizations must design Avi role assignments that correspond to job functions and apply them to user accounts for this control to take full effect across the environment.

Control 9.4(d)

Implement policies and protocols for strong authentication mechanisms and protection measures of cryptographic keys.

SCF Controls: GOV-02, IAC-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory.

Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within

the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 9.4(e)

Implement documented policies, procedures and controls for ICT change management that are based on a risk assessment approach.

SCF Controls: CHG-01, CHG-02, GOV-02, OPS-01.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support an organization's change management program, though the program itself must be established and governed through organizational policy and process.

VCF Operations is the central lifecycle management engine for the platform. It coordinates updates across the full stack and requires a precheck before applying any update to verify that the environment is ready. Lifecycle management tools within VCF Operations support planning updates so that administrators can schedule maintenance windows and make changes with minimal disruption to services. When updates are available, VCF Operations Fleet Management displays them through its Lifecycle view, where administrators can select a VCF instance and review pending VCF Operations updates.

vSphere Lifecycle Manager (vLCM) provides centralized lifecycle management for ESX hosts, drivers, firmware, and add-on software. vLCM uses desired-state configuration with a single image per cluster to maintain consistency across infrastructure components. Upon remediation, the image is installed on all hosts in the cluster, replacing the older baseline and baseline group approach from Update Manager. vLCM synchronizes to its download sources, including VCF Operations, on a regular and automatic basis. The Update Manager module provides PowerCLI cmdlets for downloading patches, creating and modifying baselines, and scanning and remediating hosts and virtual machines. Together, these components provide a structured, repeatable process for applying changes to the infrastructure.

VCF Operations extends change management support through configuration drift detection and source control integration. The Configuration Drifts feature tracks changes in product configurations over time and compares them against assigned desired values, providing scheduled drift detection for VMware vCenter and cluster objects to proactively detect configuration deviations from the desired state. Configuration Drifts Templates can be integrated with a source control repository (GitHub or GitLab), which enables versioning, auditing, and management of configuration templates. This integration supports change control with reviews and can be incorporated into continuous integration and continuous deployment pipelines for automated testing and validation of configuration changes. VCF Operations orchestrator also supports pushing local change sets to a Git repository, where each change set can consist of one or more modified orchestrator objects, providing a traceable record of automation changes. VCF Operations audit logging tracks each configuration change to the authenticated user who initiated the change or scheduled the job that performed it, allowing data center administrators to determine who changed what and when.

VCF Automation includes workflow capabilities with approval policies that require project administrators to review changes to deployed catalog instances before they take effect. This allows organizations to integrate change approval into their operational workflows. For organizations that use ServiceNow for IT service management, the ServiceNow ITSM Plug-in for VCF Automation integrates deployment lifecycle actions (such as power operations, lease changes, ownership transfers, and deployment edits) with ServiceNow change workflows. This allows VCF operational changes to be routed through an organization's existing ITSM change approval processes. Policy management capabilities within VCF Automation allow Organization Administrators to create, update, and manage policy definitions, providing a governance layer for controlling what changes are permitted within the platform.

NSX Global Manager provides change validation by checking proposed configuration changes against both Global Manager and Local Manager configurations before they are applied, reducing the risk of conflicting or disruptive network changes in federated environments.

Role-based access control across VCF components restricts who can make configuration changes. Audit logging across the platform captures change activity for review, including vDefend firewall audit logs that capture both old and new values for

modified security policies and VCF Operations audit events that record interactions such as configuration modifications, logins, and capability checks.

VMware vDefend (Contributes)

VMware vDefend provides configuration change control mechanisms within its network security policy domain, contributing to governance of technical configuration changes for firewall rules, IDS/IPS settings, and microsegmentation policies.

Security Services Platform includes a deployment wizard that conducts thorough validations before implementing any configuration changes, verifying that configurations are correct and compatible before they take effect. This pre-deployment validation reduces the risk of misconfigurations that could disrupt network security enforcement or create unintended policy gaps. Security Intelligence extends this with staged policy enforcement, where initial policy recommendations can be deployed while traffic is allowed but monitored. Administrators can verify that recommended rules do not disrupt legitimate operations before enabling full enforcement, providing a controlled transition path for firewall policy changes.

Security Intelligence includes a Monitoring capability that checks for changes in the scope of input entities every hour when enabled. This change detection helps administrators understand when underlying conditions have shifted and policies may need updating. Security Intelligence also tracks the number of new configurations per configuration type on an hourly basis, providing visibility into the rate and scope of policy changes across the security environment.

In multi-site deployments, vDefend enforces a hierarchical configuration model through the Global Manager and Local Manager architecture. In federated environments, the Global Manager centrally manages IDS/IPS signatures, profiles, Distributed Firewall (DFW) and Gateway Firewall (GFW) policies, oversubscription settings, and syslog settings across all mapped Local Managers. Settings configured on a Local Manager remain local to that site and are not propagated to other managers, supporting site-specific change control while preserving global policy consistency.

vDefend provides a draft-based publishing model that gives administrators explicit control over when policy changes take effect. Administrators can create manual drafts of firewall configurations, save them as new configurations or updates to existing ones, and lock them with a required comment before publishing. When a draft is published, vDefend automatically saves an auto draft that captures the configuration state immediately before the publish operation. This auto draft is a rollback mechanism, allowing administrators to restore the previous firewall policy state by republishing it if an applied change produces unintended results. Auto drafts and manual drafts can also be cloned and saved for additional change management flexibility.

vDefend IDS/IPS provides a bulk edit feature for system signatures that includes a Reset action, allowing administrators to restore default signature configurations when changes need to be reversed.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides role-based access controls, audit logging, and operational safeguards that contribute to change management programs for disaster recovery configurations.

PNR separates change authority through role-based access that restricts who can modify DR infrastructure. The Protection and Recovery Appliance Management Interface requires admin credentials to access reconfiguration and service management functions, controlling administrative-level changes to the appliance itself, including hostname changes, certificate changes, and patch application. In VCF Automation deployments, namespace network mappings can only be edited by an Organization Administrator in the VCF Automation Organization UI. Provider Administrators with the system administrator predefined role install PNR in regions, pair regions, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. These access controls restrict modification of DR infrastructure to authorized personnel.

PNR logs configuration change events to support traceability. Array Manager reconfiguration events are recorded when a user edits Array Manager properties, capturing changes to storage replication infrastructure. The Appliance Management Interface provides an authenticated path for appliance-level configuration changes, requiring admin credentials for all reconfiguration and service management operations.

Recovery plans in PNR support structured and auditable change to DR workflows. Plans can be edited to modify the recovery site, protection groups, and test network selection, and can be organized into folders and edited from either the protected site or the recovery site. Recovery plan steps run in a specific order that cannot be changed, but custom steps that display messages and run commands can be added to extend the workflow. Array managers can be edited to modify settings such as IP address, user name, and password without rebuilding dependent protection groups.

A configurable setting, `replication.updateVmProtectionOnPlacementChange`, controls whether VM protection is updated automatically when VM placement changes. Setting this to false prevents infrastructure placement operations from triggering protection reconfigurations outside of an intentional change workflow.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides technical mechanisms that support configuration change control for managed database infrastructure. System-wide settings are accessible only to DSM administrators through the Settings view in the Provider interface and the Dashboard, which restricts who can initiate configuration changes. This role-based access model limits changes to infrastructure policies, VM class definitions, network settings, and directory service configuration to authorized personnel.

DSM supports controlled change scheduling through its Maintenance Policy, which allows administrators to configure a start date and duration window for applying software updates to DSM appliances and the DSM plug-in. The Maintenance Policy editor is accessible from the Version & Upgrade section under the DSM System tab in both the vSphere Client and the DSM UI. The policy cannot be modified while a Provider Appliance software update is in progress, preventing changes to the update schedule during active operations. For database minor-version upgrades, DSM provides a separate maintenance window setting with a default configuration of six hours beginning each Saturday at 23:59, giving administrators control over when updates are applied to individual database instances.

DSM's Operations tab provides visibility into the progress of database configuration changes as they are applied. System configuration is managed through a `dsmsystemconfig` Custom Resource within the gateway that can be inspected via SSH access to the appliance VM, allowing administrators to review applied settings and verify configuration state.

Certain configurations are intentionally protected from modification after initial deployment. The Management Network for the Provider VM cannot be changed after deployment. Infrastructure policies actively in use by a database cannot have existing settings modified, though new compute resources can be added to them. Policies not currently assigned to any database can have settings changed at any time. Certain MySQL parameters are restricted from user modification by design. System-level settings cannot be modified when applying DSM system settings fails, providing a safety constraint against partial configuration changes.

DSM does not provide a formal change management workflow with approval routing, change ticketing, or mandatory review steps. Satisfying this control fully requires organizations to establish governance procedures that operate alongside DSM's technical controls, including formal change authorization processes, documentation requirements, and post-change verification practices that DSM itself does not enforce.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer includes several mechanisms that support change management practices for application delivery configurations.

The Avi Controller generates configuration event codes for all changes: `CONFIG_CREATE`, `CONFIG_UPDATE`, and `CONFIG_DELETE`. `CONFIG_UPDATE` events capture the resource name, status, and prior resource data, giving administrators and auditors a traceable record of changes to virtual services, pools, WAF policies, Service Engine Groups, and other Avi-managed objects. These events are accessible via Operations > Events > Config Audit Trail. Administrators can also use the Config Events overlay in Service Engine analytics to correlate traffic behavior changes with specific configuration modifications, identifying whether a shift in traffic was caused by a change to virtual service security settings, pool membership, or other configuration parameters.

Configuration changes made through the web interface, CLI, or REST API are automatically propagated to all Controller cluster members, so all nodes maintain a consistent and current configuration state.

Avi supports infrastructure-as-code tooling for controlled deployment workflows. Terraform integration includes a plan phase that shows administrators what changes will be made to Avi Controller deployment before they are applied, allowing review and approval prior to execution. Ansible can be integrated with CI/CD pipelines to trigger automated, repeatable Avi Controller deployments, supporting consistent and auditable change procedures. In VCF environments, new Avi installations must be performed through VCF Lifecycle Management, adding a structured change governance layer to the deployment lifecycle itself.

The Avi CLI provides a `configure upgrade profile` command for setting parameters that govern Controller and Service Engine upgrade sequencing, and a rollback capability allows reverting to a prior state if a change introduces problems.

Avi Contributes rather than Meets because the control asks whether the organization facilitates a change management program. A program of this kind includes formal approval workflows, change advisory processes, scheduling policies, and governance documentation that Avi does not provide independently. The configuration audit trail and automation integrations support the technical aspects of change traceability, but the governance program itself must be established and operated by the organization.

Control 9.4(f)

Have appropriate and comprehensive documented policies for patches and updates.

SCF Controls: GOV-02, VPM-01, VPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 9 (end)

For the purposes of the first subparagraph, point (b), financial entities shall design the network connection infrastructure in a way that allows it to be instantaneously severed or segmented in order to minimise and prevent contagion, especially for interconnected financial processes. For the purposes of the first subparagraph, point (e), the ICT change management process shall be approved by appropriate lines of management and shall have specific protocols in place.

SCF Controls: SEA-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 10.1

Financial entities shall have in place mechanisms to promptly detect anomalous activities, in accordance with Article 17, including ICT network performance issues and ICT-related incidents, and to identify potential material single points of failure. All detection mechanisms referred to in the first subparagraph shall be regularly tested in accordance with Article 25.

SCF Controls: MON-16

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that contribute to anomalous behavior detection and user activity monitoring, though it does not include a dedicated User & Entity Behavior Analytics (UEBA) or User Activity Monitoring (UAM) solution.

VCF Operations includes anomaly detection capabilities that use both dynamic and static thresholds to identify when metrics deviate from normal operating behavior. Dynamic thresholding is enabled by default and uses historical data analysis to establish baselines for each monitored object. The Smart Early Warning feature analyzes the number of applicable metrics that violate the dynamic threshold determining normal operating behavior, triggering alerts when the number of anomalies on an object exceeds a trending threshold. When an anomalous entity is detected, VCF Operations generates an outlier violation alert (vmwAnalyticsOutlierEvent, OID 37002), notifying administrators of unexpected behavior. A Critical threshold violation alert is also generated when anomalous entities are detected.

The Anomalies widget displays detected anomalies for a resource over the past six hours at configurable time intervals, with color-coded criticality indicators. The Anomaly Breakdown widget shows likely root causes for symptoms on a selected resource, helping operators triage issues. The Troubleshooting Workbench includes an Anomalous Metrics card that surfaces metrics exhibiting drastic changes within a selected scope and time window, ranked by degree of change with the most recent anomaly given the highest weighting. Administrators can also examine outlier VMs detected by VCF Operations to identify unexpected behavior and take corrective actions. VCF Operations supports outbound SNMP trap notifications, enabling alert delivery to external SNMP management systems with up to four configurable trap destinations.

For user activity monitoring, VCF Operations provides a User Activity Audit report that offers traceability of user actions including logging in, operations on clusters and nodes, changes to system passwords, certificate activation, and logging out. Each audit event has a detailed view containing information that supports analysis of events in the virtual infrastructure for suspicious user actions or system issues. Event auditing across the VCF platform provides visibility into platform interaction changes and surfaces suspicious access events and policy violations. Administrators should continuously monitor user security aspects to detect security risks early and respond to potential threats. VCF SSO maintains a dedicated audit log that captures user management events, including account creation, modification, deletion, and activation or deactivation, as well as changes to account credentials and profile information. The vSphere Client's Advanced Export feature allows administrators to export tasks performed by a specific user during a specified time range, providing targeted audit data for investigating suspicious activity.

Audit logging extends across VCF components. NSX Manager generates audit log messages that record user operations with fields for UserName, ModuleName, Operation, and Operation status, along with detailed resource change information and timestamps. NSX Manager audit logs also record failed login attempts with username and timestamp information, enabling tracking of access patterns across the environment. VCF Operations for Networks captures audit logs of administrative actions, including CRUD operations and login/logout events.

VCF Operations supports forwarding user activity audit logs to an external syslog server, enabling integration with dedicated SIEM or UEBA platforms for broader correlation and behavioral analysis. VCF Log Management includes content packs that offer pre-built dashboards, alerts, and queries for VCF components. These content packs support security monitoring use cases such as tracking failed login attempts and privilege escalations.

VCF's built-in anomaly detection is primarily oriented toward infrastructure metrics and operational health rather than user behavior profiling. A dedicated UEBA or UAM solution consuming VCF's audit data would be needed to establish user behavior baselines, detect credential compromise through behavioral deviation, and provide the full scope of analytics this control requires. For organizations requiring deeper behavioral analysis, VMware vDefend extends VCF's monitoring foundation with IDS/IPS, network traffic inspection, and threat intelligence integration.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer anomaly detection mechanisms that contribute to meeting this control. The Anomalies Overlay feature, available in Virtual Service Analytics, Service Engine Analytics, and Pool Analytics, flags statistical deviations in traffic metrics as anomaly events when a specific metric deviates from the historical norm by more than four sigma during the anomaly period. Monitored metrics include CPU utilization, bandwidth, disk I/O, server response time, and connection rates. Each anomaly event is identified by entity name, entity type (Virtual Machine, Virtual Service, or Service Engine), and metric value, with a timestamp indicating when the deviation occurred. Anomaly detection operates against a moving-average baseline calculated from recent historical traffic. The Pool Anomalies Overlay also displays prediction interval upper and lower bounds alongside the anomalous value. Administrators can adjust detection granularity by changing the statistics time interval, and can configure alert filter sensitivity to tune the threshold for new alert generation. Note that anomaly recording is disabled when the statistics interval is set to Real Time; a non-real-time statistics interval is required for anomaly capture to function.

The Bot Management module adds a behavioral detection layer focused on credential stuffing and web attack patterns at the application proxy boundary. Bot Management detects malicious bots responsible for online fraud and credential stuffing attacks. The IP Reputation service extends detection by maintaining a database of categorized IP addresses and identifying anomalous traffic patterns, including DoS and DDoS activity and anomalous SYN floods.

For authentication-related anomalous behavior, Avi provides the `AUDIT_COMPLIANCE_EVENT` mechanism to log authentication failures for audit purposes, persisting them via the alerts infrastructure. The Web Application Firewall (WAF) App Log Analytics component captures events whenever a WAF application rule is triggered, recording the type of attack detected. Service Engines generate `DOS_ATTACK` alert events that include attack type, source IP addresses, virtual service UUID and name, and a report timestamp, supporting audit and forensic analysis of detected attacks. Avi also supports DataScripts for custom identification of suspicious traffic and execution of appropriate mitigation actions, enabling organizations to define custom behavioral detection logic beyond the built-in statistical baselines.

Avi monitors over 500 real-time metrics to support DDoS detection and attack visibility. Alerts from any of these mechanisms can be forwarded proactively to email, syslog, SNMP, or custom APIs, enabling integration with a central SIEM or security operations platform. Avi integrates with Splunk via the Avi Load Balancer Splunk Add-on, generating events that serve as an audit trail for user logins, configuration changes, and runtime state changes.

These capabilities operate at the application delivery and load balancing layer. An organization requires a dedicated UEBA or UAM platform to fulfill the full scope of this control, including identity-level behavioral baselines, user session correlation, and cross-system entity analytics that extend beyond application traffic visible to Avi.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 10.2

The detection mechanisms referred to in paragraph 1 shall enable multiple layers of control, define alert thresholds and criteria to trigger and initiate ICT-related incident response processes, including automatic alert mechanisms for relevant staff in charge of ICT-related incident response.

SCF Controls: NET-08

Aggregate Coverage: Meets

VMware vDefend (Meets)

VMware vDefend provides network intrusion detection and prevention capabilities that directly address this control. vDefend with Advanced Threat Prevention combines multiple detection technologies, including Intrusion Detection/Prevention System (IDS/IPS), Network Detection and Response (NDR), and Network Traffic Analysis (NTA), with aggregation, correlation, and context engines to detect and prevent network intrusions.

vDefend Distributed IDS/IPS operates at the hypervisor level, inspecting both north-south and east-west traffic.

Administrators configure and manage intrusion detection and prevention policies through the NSX Manager interface, where they create IDS/IPS profiles, organize signature-based detection policies, and apply them through distributed firewall rules. The distributed architecture places IDS/IPS inspection at the vNIC level on every protected workload, providing visibility into lateral traffic between VMs that traditional perimeter-based NIDS/NIPS cannot see. IDS/IPS can be deployed in Detect Only mode or in Detect and Prevent mode, giving administrators control over enforcement posture.

Signature management is automated. vDefend IDS/IPS downloads the latest intrusion detection signatures automatically, either directly from the Internet or through a proxy server. Signatures are bundled with custom detection logic that can be updated without recompiling or modifying the IDS engine itself, allowing signature updates to take effect immediately. System Signatures are managed through the Local Manager interface under Security > IDS/IPS & Malware Prevention > Signature Management > System Signatures. When building IDS/IPS profiles, administrators filter included signatures by Intrusion Severities, Attack Types, CVSS scores, Attack Targets, and Products Affected, allowing precise tuning of the detection scope. Administrators can also configure thresholds for individual signatures to control how frequently a signature generates an IPS event, and rate filters that dynamically adjust a rule's action when specific traffic conditions are met. Profiles can also enable packet capture for later analysis of matched traffic.

Beyond automatic signature bundles, administrators can create custom signatures to detect malicious traffic specific to custom applications or to address zero-day vulnerabilities. Custom signatures support specific alert conditions, content matching, thresholds, and metadata, and can be included in IDS/IPS profiles applied to both the Distributed Firewall and Gateway Firewall. In multi-site environments, custom signatures can be managed from Global Manager. Network Detection and Response also consumes IDPS detections generated from custom IDS signatures, surfacing them alongside other detection events within the NDR interface.

NDR extends detection beyond signature matching. Network Detection and Response detects IDS events through signature matches against network traffic in the protected network and integrates with Distributed IDS/IPS to display IDS event details within the NDR interface. NDR Sensor IDS monitors network traffic for suspicious activities or known threat signatures, alerting on potential security breaches. NDR Sensor IDS Packet Capture records raw network packets associated with detected intrusion events, supporting forensic analysis and incident response.

Security Intelligence provides operational visibility into intrusion activity. Intrusion history can be filtered by action, attacker IP, attacker port, PCAP UUID, profile, rule, target IP, target port, and detection location. The IDS/IPS monitoring dashboard allows filtering of intrusion events by multiple criteria to support security event triage and analysis. Per-workload visibility includes impact scoring, signature details, and detection status for each protected VM. Each intrusion event is tagged with a Signature ID and associated protocol information, supporting precise identification and correlation during incident analysis.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to network intrusion detection and prevention at the application delivery layer through IP Reputation-based threat classification, automated DDoS detection and response, bot management, and an Application Rules service.

The IP Reputation service classifies source IP addresses across a wide range of threat categories, including DoS and DDoS attack sources, malware-infected hosts, phishing sites, proxy services, network scanners, and botnets. When an IP address falls into a relevant threat category, administrators configure Network Security Policies on virtual services to identify and block connections from those addresses. Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited, including dropping TCP SYN packets from flagged addresses. Shared IP groups allow a single blocklist to be referenced across multiple virtual service policies, so a flagged address can be blocked consistently across the application delivery tier.

For volumetric and protocol attacks, Avi Service Engines detect and mitigate DDoS attacks across Layer 4 through Layer 7, including DNS amplification attacks, DNS Reflection Ingress attacks, and NXDOMAIN attacks. Avi can also report or actively block attackers performing port scans as part of DDoS detection. DDoS attack mitigation mechanisms support IPv6 addresses, including mitigation for Neighbor Discovery Protocol (NDP) attacks. The Avi Controller monitors denial-of-service attack events with configurable alert levels and thresholds, tracking attack count metrics and generating alerts at configurable severity levels. When a SYN flood or other volumetric attack is detected, alert actions can automatically invoke ControlScripts that add the offending source IP address to a blocklist IP group attached to a network security policy, providing automated blocking in response to detected attack events. The Avi Security Manager creates network security rules and DNS rules for Service Engines to block the attacker's IP address, source port, and DNS record request types.

The Application Rules service, available through Avi Cloud Console, provides automatically updated rules specifically designed to block attacks on known application vulnerabilities, including those with published CVE identifiers. These rules extend the detection and prevention surface to application-layer attack patterns beyond IP reputation filtering.

The Bot Management capability identifies bot traffic intent, distinguishing benign bots from malicious actors such as scrapers, spam sources, click fraud engines, bot impersonators, and botnets. The IP Reputation service is also used as a source for bot detection and classification, combining IP-reputation detection, user-agent detection, and IP-location detection through the Bot Decision Component.

For Kubernetes environments, the Avi Kubernetes Operator (AKO) supports L4 Rule CRDs that express custom security policies applied to virtual service traffic, specifying configuration for DDoS attack detection and mitigation. These CRDs can also allow, deny, or rate-limit connections from individual or grouped IP addresses. HostRule CRDs can reference network security policy objects for consistent policy application across ingress resources.

These capabilities address intrusion detection and prevention at the application ingress path. Network-layer intrusion detection and prevention covering east-west and north-south traffic flows across the broader VCF environment is provided by VMware vDefend with IDS/IPS capabilities, which is a separate product and carries the Meets rating for this control. Full satisfaction of the control requires NIDS/NIPS deployment at multiple network layers.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 10.3

Financial entities shall devote sufficient resources and capabilities to monitor user activity, the occurrence of ICT anomalies and ICT-related incidents, in particular cyber-attacks.

SCF Controls: MON-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides enterprise-wide monitoring through integrated tools that span infrastructure health, performance metrics, compliance assessment, log analysis, and alerting.

VCF Operations continuously monitors the operational state of all VCF components to detect conditions that may affect availability or compliance. It collects metrics across compute, storage, and networking resources, and correlates them over time to identify trends that may lead to potential failures. VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. Platform operators can configure alerts, perform log analysis, run infrastructure diagnostics, and review VCF health from a unified interface.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status. Compliance-related alerts are triggered on objects and displayed through a dedicated compliance alert subtype.

The alerting subsystem in VCF Operations supports the full lifecycle of alert management. Administrators can configure and manage alert definitions to monitor infrastructure events and conditions, including performance metrics, log events, and custom conditions configured through the Management Pack Builder. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention. Administrators can create policies to govern how alert definitions are evaluated, including which objects to monitor and what thresholds to apply, and can apply consistent practices to optimize alert behavior across monitored objects.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

VCF Log Management provides centralized log collection and analysis. It ingests logs from VMware vCenter, VMware ESX hosts, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture. The platform provides dashboards and analytics for troubleshooting and security investigation. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log forwarding to external SIEM or syslog targets is configurable, with support for TLS encryption to protect log data in transit. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS and requires port 6514 for encrypted log transmission.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters to provide real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The vSphere Client provides direct visibility into tasks and events for change tracking and troubleshooting. VCF ships with preconfigured vSphere alarms that are active by default and monitor specific components including the Identity Management Service, Message Bus Configuration Service, ESX

Agent Manager, VMware Service Control Agent, vSphere HA host status, and host connection and power state. The vCenter Management Interface provides appliance-level health visibility through an Overall Health badge that reflects one of five states (Good, Warning, Alert, Critical, or Unknown) across all vCenter components, and notifies administrators of available security patches through Critical or Alert badge indicators when automatic patch checks are enabled.

When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The VCF Automation Monitor tab surfaces deployment health information sourced from VCF Operations, and deployment cards display Last Request Status information that tracks the most recent operation on each deployment (Create, Update, or Delete) and its outcome (Successful, In Progress, or Failed). The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Management Packs extend monitoring to network devices, including sensor monitoring for devices such as switches and routers. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

The VMware Kubernetes Service (VKS) layer of VCF extends enterprise monitoring to container workloads and Kubernetes infrastructure. VKS clusters support MachineHealthCheck objects for both control plane nodes and worker node deployments; administrators manage these through the VCF CLI `vcf cluster machinehealthcheck` command, which supports configuration of unhealthy-condition definitions, maximum unhealthy thresholds (expressed as an absolute number or a percentage), and label selectors to target specific machines. The VCF CLI `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands retrieve node and control plane health status on demand. VKS cluster health conditions, including the Ready and ControlPlaneReady status indicators, reflect the operational state of each cluster and are accessible via `kubectl` and the VCF CLI. The VCF Automation Provider Management UI includes a Services overview interface that exposes VKS cluster management functions and the health status of all cluster elements, giving platform operators a centralized view of the VKS tier. The Kubernetes API server within VKS clusters exposes diagnostic and health check endpoints (`/healthz`, `/livez`, `/readyz`, `/statusz`, and `/metrics`) that external monitoring systems can scrape to track API server availability and readiness; the `kube-apiserver` also emits the `kubernetes_healthchecks_total` counter and `kubernetes_healthcheck` gauge metric, which report structured health check status for components including `etcd` and `autoregister-completion`. Access to these monitoring endpoints is governed by the built-in Kubernetes `system:monitoring` RBAC group, which grants read access to liveness, readiness, and metrics endpoints while restricting broader cluster access. The Kubernetes Watch API allows monitoring tools to track changes to any API object as a live stream, supporting event-driven monitoring without continuous polling. The Node Problem Detector monitors node health and surfaces node-level problems as Kubernetes events and node conditions that external monitoring systems can consume via the event stream.

For workload-level monitoring within VKS clusters, Prometheus Operator is available as a standard package and defines custom resource definitions to deploy and manage Prometheus and Alertmanager StatefulSets, enabling high-availability alerting configurations. The Prometheus Alertmanager custom resource definition configures alert grouping, inhibition, and routing to external notification systems. The Istio service mesh, also available as a standard package on VKS clusters, provides service-level monitoring alongside its traffic management capabilities. The Dynatrace Operator can be deployed on VKS clusters to automate the deployment, scaling, and maintenance of the Dynatrace monitoring stack. Historical analysis, dashboarding, and alerting on cluster-level metrics require a dedicated monitoring solution configured to scrape the VKS metrics endpoints and subscribe to the Kubernetes event stream. The `vcf cluster support-bundler create` command gathers diagnostic information from Supervisor and VKS clusters when troubleshooting is needed.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as activity success counts. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.

VMware Private AI Services (PAIS) includes a built-in observability stack that supplies monitoring data for AI infrastructure and AI workloads. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the `pais-controller-manager` service, allowing collection by monitoring systems and visualization in observability platforms such as Grafana. Observability is activated by updating the `PAISConfiguration` custom resource with optional sections for Prometheus metrics collection and LLM trace forwarding. The Prometheus runtime can be configured with a specified storage class policy and a configurable metrics retention period, giving administrators control over how long monitoring data is stored. A Prometheus server pod must be in a ready and running state for observability to function.

LLM trace data from PAIS can be forwarded to an OpenTelemetry Collector endpoint over `http/protobuf` or `gRPC`, providing distributed tracing for AI model inference activity. The `observability.llmTraces` configuration governs trace forwarding and works alongside the Prometheus metrics pipeline to produce two signals: metrics for health and performance, and traces for inference-level behavior. PAIS Controller metrics include the Model Endpoint Controller and PAIS Configuration Controller, giving monitoring platforms component-level visibility into PAIS operations.

In 9.1, PAIS adds direct integration with VCF Operations. The `controller-pod-metrics-streaming` setting activates streaming of PAIS controller pod metrics from the Supervisor cluster to VCF Operations, allowing administrators to view PAIS metrics alongside other VCF infrastructure metrics. A Telegraf deployment in the `vmware-system-monitoring` namespace uses a `telegraf-user-config` ConfigMap to manage user-configured monitoring endpoints for PAIS. The VCF Consumption CLI connects to the Supervisor endpoint and enables VI administrators to stream metrics from the PAIS controller pod. DevOps engineers can visualize health and performance metrics for PAIS components running in a VCF Automation namespace using Grafana, and MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications and the models used in agents through the same observability platforms.

PAIS supplies the technical monitoring mechanisms this control requires. Enterprise-wide orchestration of monitoring controls, including alert threshold definition, escalation procedures, and integration with a centralized monitoring or log management platform, remain organizational responsibilities.

VMware vDefend (Contributes)

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports suspicious traffic detector execution status after each run, with values such as `SUCCESS`, `NOT_ENOUGH_BASELINE`, and `FAILURE`.

The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

Control 11.1

Financial entities, other than microenterprises, shall report to the competent authorities, upon their request, an estimation of aggregated annual costs and losses caused by major ICT-related incidents.

SCF Controls: BCD-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 11.2

Financial entities shall implement the ICT business continuity policy through dedicated, appropriate and documented arrangements, plans, procedures and mechanisms aiming to:

SCF Controls: BCD-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations.

HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 11.2(a)

Ensure the continuity of the financial entity's critical or important functions.

SCF Controls: BCD-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations. HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting

both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 11.2(b)

Quickly, appropriately and effectively respond to, and resolve, all ICT-related incidents in a way that limits damage and prioritises the resumption of activities and recovery actions.

SCF Controls: BCD-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations.

HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 11.2(c)

Activate, without delay, dedicated plans that enable containment measures, processes and technologies suited to each type of ICT-related incident and prevent further damage.

SCF Controls: BCD-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations.

HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 11.2(d)

Estimate preliminary impacts, damages and losses.

SCF Controls: BCD-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 11.2(e)

Set out communication and crisis management actions (in accordance with Article 14) and report to the competent authorities (in accordance with Article 19).

SCF Controls: BCD-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 11.3

Financial entities shall implement associated ICT response and recovery plans which, for entities other than microenterprises, shall be subject to independent internal audit reviews.

SCF Controls: BCD-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations.

HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 11.4

Financial entities shall put in place, maintain and periodically test appropriate ICT business continuity plans, notably with regard to critical or important functions outsourced or contracted through arrangements with ICT third-party service providers.

SCF Controls: BCD-01, BCD-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted

vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations. HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 11.5

Financial entities shall conduct a business impact analysis (BIA) of their exposures to severe business disruptions, assessing the potential impact using quantitative and qualitative criteria. The BIA must consider the criticality of identified functions, processes, and dependencies, and ensure ICT assets and services are designed for redundancy.

SCF Controls: BCD-01, RSK-08

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations. HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable

BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 11.6

Financial entities shall, as part of their comprehensive ICT risk management:

SCF Controls: RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 11.6(a)

Test the ICT business continuity plans and the ICT response and recovery plans in relation to ICT systems supporting all functions at least yearly.

SCF Controls: BCD-01, BCD-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several infrastructure-level capabilities that support an organization's contingency plan testing and exercise program, though the planning, scheduling, execution, and evaluation of formal contingency tests remains an organizational responsibility.

VCF includes built-in recovery and high-availability mechanisms that organizations can exercise during contingency tests. vSAN stretched clusters can be exercised by simulating site failures through host maintenance mode operations, validating that the surviving availability zone continues storage and compute operations. A vSAN stretched cluster continues to function if a failure or scheduled maintenance occurs at one zone, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSphere HA can be tested by deliberately failing hosts to observe VM restart behavior and confirm that admission control policies reserve sufficient capacity. vSphere HA uses admission control so that a cluster has sufficient resources to support virtual machine recovery when a host fails.

VCF Operations HCX supports workload migrations between sites through Mobility Groups, allowing organizations to exercise mobility procedures and validate that workloads can be moved to alternate processing locations. Migration activity, progress, and history are tracked through the Migration Planning interface, providing visibility into the results of migration exercises.

Management component backup and restore procedures can be tested by performing restore operations for VCF Operations, VMware vCenter, and NSX components. VCF documents the prerequisites and sequencing for file-based restore of these components, allowing organizations to validate their recovery procedures against documented expectations. Changed Block Tracking (CBT) enables incremental backups through VADP-integrated solutions that can be tested independently, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

VCF Operations includes a What-If Analysis capability under its capacity planning module that allows administrators to model hypothetical scenarios against current infrastructure. Administrators can create, save, and run scenarios cumulatively to evaluate the demand and supply for capacity on resources and assess potential risk to current capacity. This supports both Traditional and Hyperconverged deployment models. Scenarios can be committed as planning tools for capacity analysis, helping organizations with separate capacity management and operations teams understand current capacity and upcoming capacity requirements. These what-if scenarios can be used as part of contingency testing to model failover capacity needs, validate that sufficient resources exist to absorb relocated workloads, and verify that planned recovery configurations are viable before an actual event occurs.

To support the separation of test and production environments during contingency exercises, VCF Operations allows administrators to configure custom groups with differentiated alert thresholds and capacity calculations. This allows a test environment to operate under different operational policies than production, which is useful when conducting DR drills or failover exercises that temporarily shift workloads between sites or clusters.

VCF also provides built-in pre-check and validation capabilities that verify component connectivity, version compatibility, and component status among other environment readiness checks. These pre-checks run automatically during lifecycle operations such as upgrades and remediation, and they help confirm that the environment is in a known-good state before changes are applied. While these are not contingency plan tests in themselves, they contribute to readiness assessment by confirming that infrastructure components are healthy and correctly configured before and after contingency exercises.

Organizations deploying VCF should establish a formal contingency plan testing program that includes scheduled DR drills, failover exercises, backup restoration validation, and tabletop exercises. VCF's recovery mechanisms, what-if analysis, and

pre-check capabilities can inform and support these activities, but the test plan itself, its schedule, success criteria, scenario design, evaluation criteria, and after-action review process must be defined and managed by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides non-disruptive testing of disaster recovery plans as a core operational capability. Recovery plans organize protected workloads into sequenced, dependency-aware execution groups, and these plans can be tested without affecting production operations on either the protected or recovery site.

Testing a recovery plan in PNR validates that virtual machines recover correctly to the recovery site and exercises nearly every aspect of a recovery plan to validate disaster recovery readiness. Testing has no lasting effects on either the protected or recovery site, which means exercises can be repeated at any frequency without risk to production workloads. PNR requires that recovery plans be tested before use for planned migration or disaster recovery operations. Recovery plan tests can be canceled at any time; however, a successful cleanup operation must be completed before running a failover or initiating another test.

Recovery plan test execution is tracked through the Test task in Recent Tasks, which monitors overall progress of the test operation. Recovery plans support two types of custom steps: Test Steps that run during recovery plan testing, and Recovery Steps that run during planned migration or disaster recovery operations. The Configure Test Networks step in the recovery plan workflow supports using a separate test network at the recovery site to keep test VMs isolated from production network segments during testing.

Recovery plan testing can be automated through the VCF Operations orchestrator Plug-In for Protection and Recovery. The Initiate Test Recovery Plan workflow starts a test of a selected recovery plan and performs a state check to verify the recovery plan is in ready state before allowing test execution. The Initiate Cleanup Recovery Plan workflow cleans up a test when the recovery plan is in needsCleanup state.

The organizational elements of contingency plan testing, including exercise scheduling, scenario design, evaluation criteria, and after-action reviews, are outside PNR's scope. Recovery plan testing supports two distinct pre-production rehearsal modes: test recovery, which validates failover into an isolated environment without disrupting production, and planned

migration, which performs an orderly, validated move of workloads. Tests can be used to verify that recovery time and recovery point objectives are met, and can be run unattended through the VCF Operations Orchestrator plug-in and the REST API for scheduled or scripted execution.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 11.6(b)

Test the crisis communication plans established in accordance with Article 14.

SCF Controls: BCD-01, BCD-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 11.6 (end)

For the purposes of the first subparagraph, point (a), financial entities, other than microenterprises, shall include in the testing plans scenarios of cyber-attacks and switchovers between the primary ICT infrastructure and the redundant capacity, backups and redundant facilities necessary to meet the obligations set out in Article 12. Financial entities shall regularly review their ICT business continuity policy and ICT response and recovery plans, taking into account the results of tests carried out in accordance with the first subparagraph and recommendations stemming from audit checks or supervisory reviews.

SCF Controls: BCD-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several infrastructure-level capabilities that support an organization's contingency plan testing and exercise program, though the planning, scheduling, execution, and evaluation of formal contingency tests remains an organizational responsibility.

VCF includes built-in recovery and high-availability mechanisms that organizations can exercise during contingency tests. vSAN stretched clusters can be exercised by simulating site failures through host maintenance mode operations, validating that the surviving availability zone continues storage and compute operations. A vSAN stretched cluster continues to function if a failure or scheduled maintenance occurs at one zone, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSphere HA can be tested by deliberately failing hosts to observe VM restart behavior and confirm that admission control policies reserve sufficient capacity. vSphere HA uses admission control so that a cluster has sufficient resources to support virtual machine recovery when a host fails.

VCF Operations HCX supports workload migrations between sites through Mobility Groups, allowing organizations to exercise mobility procedures and validate that workloads can be moved to alternate processing locations. Migration activity, progress, and history are tracked through the Migration Planning interface, providing visibility into the results of migration exercises.

Management component backup and restore procedures can be tested by performing restore operations for VCF Operations, VMware vCenter, and NSX components. VCF documents the prerequisites and sequencing for file-based restore of these components, allowing organizations to validate their recovery procedures against documented expectations. Changed Block Tracking (CBT) enables incremental backups through VADP-integrated solutions that can be tested independently, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

VCF Operations includes a What-If Analysis capability under its capacity planning module that allows administrators to model hypothetical scenarios against current infrastructure. Administrators can create, save, and run scenarios cumulatively to evaluate the demand and supply for capacity on resources and assess potential risk to current capacity. This supports both Traditional and Hyperconverged deployment models. Scenarios can be committed as planning tools for capacity analysis, helping organizations with separate capacity management and operations teams understand current capacity and upcoming capacity requirements. These what-if scenarios can be used as part of contingency testing to model failover capacity needs, validate that sufficient resources exist to absorb relocated workloads, and verify that planned recovery configurations are viable before an actual event occurs.

To support the separation of test and production environments during contingency exercises, VCF Operations allows administrators to configure custom groups with differentiated alert thresholds and capacity calculations. This allows a test environment to operate under different operational policies than production, which is useful when conducting DR drills or failover exercises that temporarily shift workloads between sites or clusters.

VCF also provides built-in pre-check and validation capabilities that verify component connectivity, version compatibility, and component status among other environment readiness checks. These pre-checks run automatically during lifecycle operations such as upgrades and remediation, and they help confirm that the environment is in a known-good state before changes are

applied. While these are not contingency plan tests in themselves, they contribute to readiness assessment by confirming that infrastructure components are healthy and correctly configured before and after contingency exercises.

Organizations deploying VCF should establish a formal contingency plan testing program that includes scheduled DR drills, failover exercises, backup restoration validation, and tabletop exercises. VCF's recovery mechanisms, what-if analysis, and pre-check capabilities can inform and support these activities, but the test plan itself, its schedule, success criteria, scenario design, evaluation criteria, and after-action review process must be defined and managed by the organization.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides non-disruptive testing of disaster recovery plans as a core operational capability. Recovery plans organize protected workloads into sequenced, dependency-aware execution groups, and these plans can be tested without affecting production operations on either the protected or recovery site.

Testing a recovery plan in PNR validates that virtual machines recover correctly to the recovery site and exercises nearly every aspect of a recovery plan to validate disaster recovery readiness. Testing has no lasting effects on either the protected or recovery site, which means exercises can be repeated at any frequency without risk to production workloads. PNR requires that recovery plans be tested before use for planned migration or disaster recovery operations. Recovery plan tests can be canceled at any time; however, a successful cleanup operation must be completed before running a failover or initiating another test.

Recovery plan test execution is tracked through the Test task in Recent Tasks, which monitors overall progress of the test operation. Recovery plans support two types of custom steps: Test Steps that run during recovery plan testing, and Recovery Steps that run during planned migration or disaster recovery operations. The Configure Test Networks step in the recovery plan workflow supports using a separate test network at the recovery site to keep test VMs isolated from production network segments during testing.

Recovery plan testing can be automated through the VCF Operations orchestrator Plug-In for Protection and Recovery. The Initiate Test Recovery Plan workflow starts a test of a selected recovery plan and performs a state check to verify the recovery plan is in ready state before allowing test execution. The Initiate Cleanup Recovery Plan workflow cleans up a test when the recovery plan is in needsCleanup state.

The organizational elements of contingency plan testing, including exercise scheduling, scenario design, evaluation criteria, and after-action reviews, are outside PNR's scope. Recovery plan testing supports two distinct pre-production rehearsal modes: test recovery, which validates failover into an isolated environment without disrupting production, and planned migration, which performs an orderly, validated move of workloads. Tests can be used to verify that recovery time and recovery point objectives are met, and can be run unattended through the VCF Operations Orchestrator plug-in and the REST API for scheduled or scripted execution.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 11.7

Financial entities, other than microenterprises, shall have a crisis management function, which, in the event of activation of their ICT business continuity plans or ICT response and recovery plans, shall, inter alia, set out clear procedures to manage internal and external crisis communications in accordance with Article 14.

SCF Controls: BCD-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 11.8

Financial entities shall keep readily accessible records of activities before and during disruption events when their plans are activated.

SCF Controls: BCD-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 11.9

Central securities depositories shall provide the competent authorities with copies of the results of the ICT business continuity tests, or of similar exercises.

SCF Controls: BCD-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 11.10

Financial entities, other than microenterprises, shall report to the competent authorities, upon their request, an estimation of aggregated annual costs and losses caused by major ICT-related incidents.

SCF Controls: BCD-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 11.11

The ESAs, through the Joint Committee, shall by 17 July 2024 develop common guidelines on the estimation of aggregated annual costs and losses referred to in paragraph 10.

SCF Controls: BCD-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 12.1

For the purpose of ensuring the restoration of ICT systems and data with minimum downtime, limited disruption and loss, as part of their ICT risk management framework, financial entities shall develop and document:

SCF Controls: BCD-01, BCD-11

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on

VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds. VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS

cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VCF Protection and Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a

minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period. PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Control 12.1(a)

Backup policies and procedures specifying the scope of the data that is subject to the backup and the minimum frequency of the backup, based on the criticality of information or the confidentiality level of the data.

SCF Controls: BCD-01, BCD-11

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on

VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds. VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS

cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VCF Protection and Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the

backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages, including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period. PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the `export` command), or REST API (using the `/api/scheduler/` endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the `keep_uuid` option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control 12.1(b)

Restoration and recovery procedures and methods.

SCF Controls: BCD-01, BCD-11

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds.

VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a

separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VCF Protection and Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages,

including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period. PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30

minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the `export` command), or REST API (using the `/api/scheduler/` endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage

target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the `keep_uuid` option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control 12.2

Financial entities shall set up backup systems that can be activated in accordance with the backup policies and procedures, as well as restoration and recovery procedures and methods. The activation of backup systems shall not jeopardise the security of the network and information systems or the availability, authenticity, integrity or confidentiality of data. Testing of the backup procedures and restoration and recovery procedures and methods shall be undertaken periodically.

SCF Controls: BCD-11, BCD-11.1, BCD-11.5

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware

vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds. VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For

on-demand backups outside a scheduled window, the velero backup create command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VCF Protection and Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes.

Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages, including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period. PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the `export` command), or REST API (using the `/api/scheduler/` endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the `keep_uuid` option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control 12.3

When restoring backup data using own systems, financial entities shall use ICT systems that are physically and logically segregated from the source ICT system. The ICT systems shall be securely protected from any unauthorised access or ICT corruption and allow for the timely restoration of services making use of data and system backups as necessary. For central counterparties, the recovery plans shall enable the recovery of all transactions at the time of disruption to allow the central counterparty to continue to operate with certainty and to complete settlement on the scheduled date. Data reporting service providers shall additionally maintain adequate resources and have back-up and restoration facilities in place in order to offer and maintain their services at all times.

SCF Controls: BCD-11.2, BCD-11.6

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple built-in mechanisms for storing backup copies of critical software and configuration data at locations separate from the systems being backed up.

VCF's core management components all support file-based backup methods that can direct backup data to remote storage. VMware vCenter supports both file-based and image-based backup, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. Backup destinations are specified as remote servers accessible over FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB, and backup data is written to the remote server rather than retained on the vCenter appliance itself. File-based backup supports optional encryption using a password that must be provided to complete the restore procedure; because backup files contain the Key Derivation Key used by vSphere Native Key Provider, storing them in a secure, separate location is particularly important. VCF Operations automatically configures NSX Manager backup during the initial bring-up process, while file-based backup jobs for VCF Operations and vCenter must be configured separately. Scheduled backups should be implemented to prepare for critical failures of management components, upgrades, or certificate updates. The guidance for VCF Operations backups specifically recommends copying the backup zip file to a secure location from which it can be retrieved if a failure of the appliance occurs. The vSphere Supervisor control plane can also be backed up using vCenter file-based backup and restore from the Workload Management UI.

VCF supports exporting the configuration of vSphere Distributed Switches, producing a configuration file that captures validated network configurations. The exported file can be used to restore switch and port group settings. The guidance recommends retaining the last three configurations and storing them separately from the appliance.

VCF Operations for Networks supports storing backups on local storage (retaining up to five recent backup files) or uploading backups to SSH or FTP servers. This remote upload capability allows administrators to direct backup data to storage infrastructure that is physically separate from the VCF environment.

vSAN stretched clusters distribute data across two physically separated data sites with a witness host at a third location. This architecture maintains copies of data at a geographically distinct facility by design. vSAN Data Protection uses native snapshots stored on vSAN Express Storage Architecture (ESA) clusters, managed through the Snapshot Service appliance. The Snapshot Service supports protection groups with snapshot policies, and immutability mode can create read-only snapshots that cannot be modified or deleted even by an attacker with administrative privileges.

Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups when integrating with third-party backup solutions through VMware vSphere Storage APIs for Data Protection (VADP). VADP-based backup partner solutions can automatically perform backup, full restore, and registration of VMs, including VM Service VMs on a Supervisor. Third-party backup solutions integrated through VADP can direct backup data to separate storage infrastructure managed outside VCF.

For Kubernetes workloads running on VMware Kubernetes Service (VKS), the backup infrastructure supports specifying a target backup location separate from the cluster storage. Backup targets can include AWS S3 or S3-compatible storage, allowing backup data to reside on a completely different storage platform from the one backing the Kubernetes volumes. VKS supports both File System Backup (FSB) and Container Storage Interface (CSI) snapshot methods. FSB is not tied to a specific storage platform, so backup data can be saved to different storage infrastructure. CSI snapshot data can similarly be moved to a separate backup storage location, which is particularly useful for on-premises data centers where the primary storage does not support durable snapshots.

To satisfy this control fully, the organization must ensure that backup destinations configured within VCF are hosted on storage infrastructure located in a separate facility or housed in appropriately rated containers that are not collocated with the production VCF environment. VCF provides the technical mechanisms to transmit and store backup data on remote targets, but the physical separation, facility selection, and fire-rating requirements are organizational and facilities management decisions that fall outside the product's scope.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for its own critical configuration and security policy data, supporting the organizational requirement to maintain backup copies in a location separate from the operational system.

SSP backup captures a broad set of security-critical information: the platform configuration, feature configurations, NSX Manager connection information, user accounts and roles, security policies, and the state of installed features. Tokens, Bare Metal servers, and Bare Metal server interfaces are included as part of the full inventory backup. This backup data is written to a designated backup server, which can be provisioned on infrastructure separate from the SSP deployment itself. The backup produces a duplicate copy of information that can be restored in case of system failure from hardware malfunctions, software malfunctions, data corruption, malware incidents, or unintentional data deletion.

The backup server target is configurable, meaning organizations can direct SSP backups to storage infrastructure located in a separate facility or on a physically distinct storage system from the SSP cluster nodes. Adequate storage on the server must be verified before activating recurring backups. SSP must be in a healthy state to perform backup operations; backup and restore are prevented when the platform is unhealthy or when the SSP Installer has lost connectivity or cannot access Helm or Docker repositories. Backup and restore operations are accessible through the System > Backup and Restore interface. SSP's csi-snapshotter container also interacts with the CSI snapshot API to create, delete, and restore Persistent Volume snapshots, providing an additional data recovery mechanism for platform storage volumes.

In addition, vDefend configurations can be exported in published, auto-saved, or manually saved states, providing a separate mechanism for capturing firewall policy data in files that can be stored independently of the operational environment.

While vDefend provides the backup mechanism and allows the backup destination to be a separate server, the actual placement of that backup server in a separate facility or fire-rated container is an infrastructure and operational decision outside the product's direct control. The platform enables separate storage but does not enforce geographic or physical separation of backup media.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the replication and recovery mechanisms that enable organizations to store protected workloads at a physically separate site, directly addressing the technical requirements for separate storage of critical information.

PNR is an extension to VMware vCenter (vCenter) that delivers business continuity and disaster recovery capabilities for planning, testing, and running recovery of vCenter virtual machines. PNR supports multiple replication methods, each of which stores data at a separate recovery facility. Array-based replication replicates entire datastores to a target storage array at the recovery site. Organizations can configure separate storage arrays for each PNR instance to achieve full logical isolation of replicated data. Virtual Volumes integration allows PNR to offload intensive storage operations such as snapshot, cloning, and replication to the storage system.

Protection groups in PNR enumerate all storage containers within a selected fault domain and collect all replication groups and virtual machines from those containers, defining which workloads are protected and replicated to the separate recovery site. Placeholder datastores at the recovery site store configuration metadata for protected virtual machines; PNR requires these datastores to reside on the recovery site and identification of a separate datastore to hold placeholder virtual machine files when using array-based replication, Virtual Volumes replication, vSAN snapshots and replication, or vSphere Replication. PNR also requires a non-replicated datastore at the recovery site with at least 6 GB of free capacity for vCLS agent virtual machines.

PNR enforces a requirement that different datastores be used for disaster recovery replication and cyber recovery replication. This architectural constraint maintains separation between the two recovery paths, keeping disaster recovery replicas and cyber recovery copies on independent storage at the recovery site.

PNR's cyber recovery capability supports topology options including a shared vault and clean room alongside an existing disaster recovery site, a fully isolated and dedicated cyber recovery site, or a local vault and clean room deployment. These options allow organizations to establish geographically or logically separate storage for cyber recovery workloads based on their recovery architecture requirements.

PNR's backup configuration supports setting a datastore path, enabling or disabling a backup scheduler, configuring a retention period, and scheduling backup frequency and time. This mechanism allows organizations to direct PNR configuration data backups to a designated datastore, providing separate storage for management configuration data alongside the separate storage for replicated workloads.

In shared recovery site configurations, PNR isolates customer resources by mapping resources, networks, folders, and datastores on protected sites to separate datacenters, networks, folders, and placeholder datastores on the shared recovery site. Customer resources can be placed in individual folders within a common target datastore or fully isolated by selecting a different datastore for each customer.

After a failover, PNR's reprotect capability reverses the direction of protection and forces synchronization of storage from the new protected site to the new recovery site, maintaining separate storage copies in both directions once production is restored.

Organizations must provision and maintain the recovery site infrastructure and designate which workloads require replication protection. PNR provides the mechanisms to replicate and recover those workloads once the organizational architecture decision has been made.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports sending both control plane and database backups to S3-compatible object storage that can be hosted separately from the systems being backed up. The Provider Backup Repo is configured on the DSM Provider VM as an S3-compatible bucket to receive backups of the DSM control plane, and DSM Provider VM recovery from backup requires that the Provider Backup repository has been configured in the DSM installation. DSM documentation directs administrators to send provider backup and WAL files to a remote S3-compatible storage location for long-term retention, disaster recovery, or replication. Because the backup destination is specified by the administrator rather than fixed to local storage, backup data can reside in a facility that is separate from the DSM deployment. Control plane system database backups are written to S3 object storage with a unique control plane identifier embedded in the backup path, which separates backup artifacts from the primary Provider VM.

At the database level, DSM allows configuration of storage repositories and object storage buckets to store backups of the Provider internal database, generated log bundles, and database backups. DSM consumption clusters support a list of backup locations that must be identified during configuration, and on-demand PostgreSQL backups can be written to any storage destination available for the data service policies governing the namespace. Administrators can edit the backup location for individual databases to specify where backups are stored. DSM restores a backup to a newly created database VM with a user-specified name and datastore location, confirming that backup destinations are independent of the primary database infrastructure.

DSM also requires that any data service policy that allows automated backups have at least one backup location configured with a trusted root certificate, and DSM supports Trust On First Use to extract and trust certificates for specific backup locations. DSM raises global alerts when the backup storage repository connection or operational status degrades and when available space on the backup repository falls below configured thresholds, supporting operational verification that the remote storage target remains reachable. DSM infrastructure policies determine datastore placement for database VMs through storage policies, separating where live database data resides from where backup data is stored in the configured S3 repository.

Satisfying this control fully requires organizational decisions about where the S3-compatible storage targets are hosted. DSM provides the mechanism to direct backups to remote, external storage endpoints, but the physical separation of the storage facility, including geographic location and fire-rated container requirements, is determined by how the organization provisions and configures those storage targets.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer includes a native backup and restore system for the Avi Controller configuration that supports both local storage on the Controller and remote delivery to an external server separate from the Controller cluster. Configuration backups can be created and managed through the UI, CLI, or API, and can be scheduled for automated periodic execution or triggered on demand.

For remote backup delivery, Avi Load Balancer supports Secure Copy Protocol (SCP) or Secure File Transfer Protocol (SFTP) to transfer backup files to an external server. Backup files can also be stored in Amazon S3 buckets, expanding the range of remote destinations available. The documentation explicitly recommends designating a remote backup destination to protect against disasters that could destroy the entire Avi Controller cluster, and for single-node Controller deployments, enabling periodic external configuration backups is described as mandatory to handle recovery from complete VM or disk failure.

In VCF-integrated deployments, VCF Operations is used to configure the external backup server and storage path for Avi Load Balancer backups. By default, Avi Load Balancer backups are stored on the same server where VCF Operations appliance backups are stored; the recommendation is to configure an external SFTP server as the backup destination rather than relying on this default. Backups should be stored with clear labeling such as version and date to support identification during recovery.

Backup files can be encrypted using a passphrase that protects all sensitive fields within the backup. The passphrase is configured through the backup configuration and is required during restore operations via the CLI or REST API. Backup and restore operations also verify that the FIPS mode of the backup configuration matches the Controller environment, which helps maintain consistency across recovery scenarios.

To configure remote backup storage in a standalone deployment: navigate to Controller Operations > Backup and Restore in the Avi Controller UI, specify the SCP or SFTP target host, credentials, and destination directory, and set the backup scheduler frequency. The CLI provides export and import commands for backing up and restoring the system configuration or individual virtual service configurations. Local backups can be retained on the Controller independently, with a configurable retention count.

The decision about where to physically locate the remote backup server, including whether it sits in a geographically separate facility or a fire-rated container not collocated with the Controller, is an organizational siting and infrastructure decision that Avi Load Balancer does not govern.

Control 12.4

Financial entities, other than microenterprises, shall maintain redundant ICT capacities equipped with resources, capabilities and functions that are adequate to ensure business needs. Microenterprises shall assess the need to maintain such redundant ICT capacities based on their risk profile.

SCF Controls: BCD-11.7, BCD-12.2

Aggregate Coverage: Meets

VCF (Meets)

VCF provides failover capabilities across compute, storage, network, and management layers that can be deployed at sites separate from the primary infrastructure, maintaining operations with minimal data loss and disruption.

At the compute layer, vSphere High Availability (HA) automatically restarts virtual machines on surviving hosts after a host failure. Admission control policies reserve sufficient capacity for restart operations, and dedicated failover hosts can be reserved exclusively for this purpose. For workloads requiring zero downtime, vSphere Fault Tolerance maintains a live shadow instance of a virtual machine on a separate host, providing continuous availability with no data loss during a hardware failure. Proactive HA integrates with hardware health providers to detect degrading components and place hosts into maintenance mode before a failure occurs, with vSAN supporting Proactive HA using maintenance mode as the remediation method for all failure types.

The primary mechanism for site-level failover is vSAN stretched clusters, which extend a single vSAN cluster across two geographically separated sites with a witness host at a third location. vSAN stretched clusters use a site mirroring storage policy that maintains synchronized copies of data at both sites. When a site failure occurs, vSphere HA restarts affected virtual machines on the remaining active site. The site disaster tolerance storage policy rule, configured to "Site mirroring - stretched cluster," allows the cluster to tolerate both a site failure and a witness host failure simultaneously. To support failover with minimal resource contention, vSphere HA admission control can be configured to reserve 50% of the cluster's aggregate CPU and memory resources, so that all virtual machines from one site can be restarted on the other site during a site failure. The host failure cluster tolerates setting should be updated to reflect the number of hosts in each availability zone after cluster expansion. For network partition detection, administrators should specify two additional site-specific isolation response addresses, one in each site, so that vSphere HA can validate host isolation even when the inter-site network link fails.

Within vSAN clusters, fault domains provide an additional layer of resilience by grouping hosts according to their physical location. Storage policies reference fault domains to distribute data replicas across separate failure boundaries, so that a failure in one physical location does not result in data loss. vSAN storage policies allow administrators to define the level of data redundancy, from no redundancy to full site mirroring, based on availability requirements.

VCF supports an Availability Zone fault tolerant deployment model that distributes workloads across availability zones for resilience. This model requires the physical fabric to extend uplink VLANs, edge TEP VLANs, and edge management VLANs across zones. When stretching a cluster in a workload domain, the default management vSphere cluster must already be stretched, establishing a foundation of cross-site redundancy before extending it to additional workload domains. For Kubernetes workloads, vSphere HA can be configured for a Supervisor running on a vSAN stretched cluster, providing high availability for containerized applications.

VMware Kubernetes Service (VKS) running on the VCF platform extends these availability principles to containerized workloads through vSphere Zone-based failure domain separation. In a zoned Supervisor deployment, Supervisor stretches across three vSphere clusters, each assigned to a distinct vSphere Zone that represents an independent failure domain, and vSphere HA and fully-automated DRS are prerequisites for all Supervisor deployments. VKS cluster control planes are configured with three replicas distributed across these failure zones so that a single zone outage does not interrupt cluster scheduling or operations. Node auto-placement provisions worker nodes across zones using failureDomain specifications in the cluster topology, distributing workloads so that a zone failure does not take an application entirely offline; zone evacuation procedures support relocating control plane nodes from a zone before it is removed from service, allowing planned maintenance without disruption. During version updates, the VKS rolling update model updates control plane nodes first, then

rolls worker nodes one at a time starting with the Zone-A node pool, limiting the number of nodes simultaneously unavailable. At the application layer, Kubernetes PodDisruptionBudget (PDB) resources protect deployed workloads by specifying the minimum number of pods that must remain available during voluntary disruptions, and cluster operators are required to respect these budgets; ReplicaSets, Deployments, and StatefulSets distribute application replicas across nodes and zones to tolerate individual node failures. Persistent volumes for VKS workloads are provisioned through the vSphere CSI driver and can be protected using vSphere Plugin Snapshot, CSI Snapshot, or File System Backup methods, providing crash-consistent recovery points for stateful applications.

For disaster recovery scenarios beyond stretched clusters, VCF provides Application Disaster Recovery, which supports failover to a secondary site to maintain operations during major disruptions. vSphere Replication supports configurable Recovery Point Objective (RPO) settings that define the maximum acceptable data loss window during failover. VCF Operations HCX provides workload mobility services including Bulk Migration, Replication Assisted vMotion, cross-cloud vMotion, and OS Assisted Migration for moving workloads to remote sites. HCX Network Extension High Availability creates redundant pairs of network extension appliances that automatically fail over, maintaining extended network connectivity. Network Extension HA protects against individual appliance failures within an HA group, and after recovery, appliances renegotiate roles and the group returns to a healthy state.

Network resilience is built through multi-NIC teaming, Link Aggregation Control Protocol (LACP), and failover policies that maintain connectivity during link failures. Network adapter teaming provides redundancy such that if a NIC fails, the remaining NICs in the team continue to pass traffic. NSX tier-0 gateways support active-active and active-standby high availability modes, with services such as SNAT, DNAT, load balancing, and VPN supported in active-standby mode. Storage multipathing provides failover for storage connectivity, including NFS 4.1 datastores that support multipathing for redundant storage paths.

VCF Operations supports a Continuous Availability deployment model that provides a highly available cluster with data redundancy across different availability zones. In this architecture, each object is stored on two nodes (primary and replica) distributed across fault domains, providing redundancy in the event of a fault domain failure. VMware vCenter itself also supports a High Availability deployment, in which an Active node, Passive node, and Witness node form a three-node cluster; the Passive node receives continuous configuration replication from the Active node and automatically takes over the active role if the Active node fails, providing management plane continuity without manual intervention.

VCF's identity infrastructure also supports failover through secondary domain controllers that act as a backup for the VCF Identity Broker when the primary domain controller is not reachable.

VMware vDefend (Contributes)

VMware vDefend includes high availability and failover capabilities for its own security services, helping maintain network security enforcement during site failures and infrastructure disruptions.

Security Services Platform (SSP), which hosts vDefend's centralized security functions including Security Intelligence, Network Detection and Response, and Malware Prevention, has high availability capabilities enabled by default. For production deployments, a minimum of three controller nodes and four worker nodes is required. Enabling vSphere HA on the cluster hosting SSP is recommended; when vSphere HA is configured and a host becomes unhealthy, it migrates the affected virtual machines to healthy hosts in the cluster. Admission Control should be configured with sufficient resources for recovery operations. SSP's internal infrastructure runs distributed instances of MinIO for object storage and Kafka for event streaming, providing in-cluster redundancy for the analytics pipeline.

In vSAN stretched cluster configurations, SSP replicates data across two physically distinct sites to maintain continuity during a site failure. A vSAN stretched cluster allows a single cluster to span two physically distinct sites and requires a minimum of two sites, each with a high-bandwidth or low-latency inter-site link for effective data replication, along with a witness host to resolve network partition conflicts. Control plane and worker node VMs are distributed across primary and secondary VM groups aligned to their respective sites. Stretched configurations also protect data from multiple host failures within a single site.

The vDefend gateway firewall supports primary-passive and secondary-active high availability modes with non-preemptive failover. When the active gateway node fails, the standby assumes the active role and continues enforcing gateway firewall

policies. Edge node failover is triggered when all uplink routing links are down on the active node; the new active Edge node takes over all existing flows because flows are synchronized between both nodes, preserving connection state through the transition.

The vDefend distributed firewall enforces security policy at the vNIC level on every ESX host and is inherently distributed, with no single point of failure for policy enforcement. Each host maintains its own firewall rules and continues enforcing them independently even if management plane connectivity is temporarily lost. This distributed architecture means that when host-level failover occurs through vSphere HA, Distributed Firewall policy enforcement continues on surviving hosts. One operational characteristic to note: when VMs are restarted on a recovery host, the Distributed Firewall reinspects all flows from those VMs because Flow Table contents cannot be moved during host recovery. Policy enforcement is continuous, but established session state is not carried over across host failovers.

SSP supports backup and restore functionality, allowing recovery of a platform instance to its previous configuration when the current instance is in a non-recoverable state. Administrators should back up SSP before maintenance operations such as scale-out.

When VCF infrastructure is configured for cross-site failover, vDefend's security enforcement survives the failover along with the workloads it protects, maintaining network security posture at the secondary site.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) is the product that provides geographically separate failover capabilities for virtual infrastructure within VCF environments. PNR orchestrates both planned migration and disaster recovery failover between a protected site and a non-collocated recovery site. Single-fleet, single-instance deployment configurations are documented as appropriate only for testing and evaluation where reduced resilience to disaster events is acceptable, not for production disaster recovery.

PNR supports multiple replication methods to maintain synchronized data between sites. vSphere Replication provides individual virtual machine replication and supports up to 200 point-in-time recovery instances using the Latest instances option; these instances are presented as standard snapshots on the recovered virtual machine, allowing administrators to choose a specific recovery point. Recovery point objective configuration balances storage consumption against snapshot consolidation time after recovery and should be set to the lowest value that satisfies business requirements. Array-based replication is also supported and enables automated failback.

vSphere Replication provides an option to synchronize recent changes from the source site to the target site before recovering a virtual machine, which reduces data loss during the recovery operation. If an error occurs on the protected site during recovery plan execution, PNR's disaster recovery failover continues without failing, allowing recovery operations to proceed even when the primary site is experiencing disruptions. Recovery plans automate the failover sequence, including virtual machine power-on ordering and dependency sequencing.

For stretched storage configurations, PNR's failover command isolates devices at the recovery site to prevent file lock conflicts during virtual machine failover. Failover and failback can be performed independently on each site, allowing isolated recovery operations without affecting other recovery sites. After failover, PNR reverses the roles of the recovery and protected sites to enable reprotection and restoration of bidirectional protection.

PNR includes a VCF Operations orchestrator plug-in that provides API workflows to initiate failover to a recovery site, enabling integration with broader automation frameworks.

vSphere Replication is compatible with vSphere High Availability; replication continues at the defined recovery point objective after HA restarts a virtual machine, providing an additional layer of within-site resilience. Recovery capabilities can be validated through non-disruptive test failover before an actual disaster event.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides database replication and high availability topologies that contribute to maintaining a redundant secondary system, though the full requirement for a non-collocated, activatable failover capability also depends on how administrators plan and deploy the underlying infrastructure.

DSM offers two high availability topologies for managed databases. The Single vSphere Cluster HA topology deploys a primary database, a synchronous database-level replica, and a monitor node within a single vSphere cluster, with database nodes protected through vSphere HA, Distributed Resource Scheduler, and underlying storage redundancy. The monitor node orchestrates automatic failover so that a replica is promoted without manual intervention when the primary fails. DSM requires vSphere HA to be active on VMware vCenter (vCenter) clusters as a condition of infrastructure policy compliance, and the documentation specifies that vSphere HA and DRS should be enabled on all clusters used in infrastructure policies.

The Cross vSphere Cluster HA topology distributes database nodes across three separate vSphere clusters. For PostgreSQL, this places the primary, database-level replica, and monitor across three distinct clusters. For MySQL, the primary and two database-level synchronous replicas are distributed across three clusters. This topology provides resilience against the failure of any single vSphere cluster and is the highest-availability configuration available within a DSM deployment.

DSM adds SQL Server cluster support, with three-node High Availability configurations that use Microsoft Always On availability groups for data redundancy and automatic failover. Both Single vSphere Cluster HA and Cross vSphere Cluster HA topologies are available for SQL Server, configured with two synchronous replicas and one configuration-only replica. In the Cross vSphere Cluster HA topology for SQL Server, each replica node runs in a separate vSphere cluster. After a SQL Server failover, the new primary instance maintains the security and management configurations from the previous primary. HA clusters require automated backups to be enabled in order to provision databases.

For geographically distributed disaster recovery, DSM supports a multi-site deployment model for PostgreSQL. A secondary PostgreSQL instance at a separate site maintains continuous replication from the primary, and administrators can promote the secondary to primary status using DSM's switchover workflow; the promoted instance becomes a standalone primary with independent read and write capabilities. DSM also provides a fallback workflow to reverse the roles of primary and secondary instances once the original site is restored, and a demoted primary can rejoin the topology as a read-only secondary. DSM also integrates with VCF Automation as a tenant, allowing PostgreSQL and MySQL databases with high availability topologies to be created and cloned through VCF Automation self-service workflows.

Several limitations apply to these failover capabilities. The Single vSphere Cluster HA topology keeps all nodes within the same availability zone and does not address geographic non-collocation on its own. The Single Server topology has no secondary instance to take over and experiences brief downtime during maintenance operations and updates. During a SQL Server failover, the system does not protect new writes with a second copy until the failed node rejoins the cluster. If a secondary PostgreSQL instance was created using the Consumption Operator, manual trust establishment between the primary and secondary instances is required for multi-site disaster recovery.

To satisfy this control, organizations must make architectural decisions about the physical location of secondary vSphere clusters or multi-site secondary instances so that they are genuinely not collocated with the primary. DSM provides the technical framework for synchronous replication, automatic promotion within a cluster, and manual switchover across sites. The organizational process for selecting, configuring, and testing the secondary site, and for coordinating a failover when needed, remains an administrative responsibility.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides multiple layers of real-time and near-real-time failover mechanisms for application delivery. These operate at the Service Engine data plane, at the load balancing pool level, and at the Controller management plane, working in conjunction with the availability capabilities of the VCF platform.

At the data plane, Avi's Elastic High Availability (Elastic HA) mode provides fast recovery for individual virtual services following Service Engine failure. Elastic HA supports both Active-Active and N+M configurations, giving administrators a choice of redundancy model suited to their requirements. When a virtual service is already scaled across multiple Service Engines and one fails, the virtual service switches over to the remaining available Service Engines; this recovery occurs before

vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines. The switchover time for Service Engines in vSphere HA failover scenarios is configurable per virtual service requirements.

For deployments requiring active/standby behavior, Avi supports Legacy Active/Standby High Availability mode, where a pair of Service Engines share a floating interface IP address for transparent failover. By default, the standby Service Engine sends health checks to pool members so that server health state is already known at the time a failover occurs, reducing recovery latency. For Layer 4 connections, enabling connection mirroring on Avi provides seamless failover and avoids disruption of existing connections during failover events.

The Autoreistribute Load option on Service Engine groups can be enabled to make fail-back automatic when load is concentrated on the failover Service Engine after a recovery event.

At the pool level, Avi implements priority-based pool failover logic. The `deactivate_primary_pool_on_down` setting enables automatic deactivation of the primary pool when it becomes unavailable, triggering automatic failover to a designated secondary pool. The Avi Controller ControlScript can also execute failover operations on pool groups triggered by Pool Up and Pool Down events.

For cross-fault-domain resilience, Availability Zone support enables spreading Service Engines across transport nodes that do not share common failure points, such as shared power supplies or shared networking devices. Defining Availability Zones based on fault domains helps keep virtual services available across fault conditions that affect a single zone. At the Controller plane, Controller cluster deployments can span two availability zones with defined failure scenarios and recovery actions for each configuration.

For global application availability across data centers, Avi GSLB supports Active-Active configuration where applications are deployed in multiple data centers and instances in remaining data centers can take over user traffic if a data center becomes unavailable.

Service Engine VM-level recovery in host failure scenarios depends on vSphere HA from the underlying VCF platform. Avi documentation recommends enabling vSphere HA on the vSphere clusters where Service Engine VMs are deployed. In VCF-integrated deployments, vSphere DRS and HA must be enabled on each vSphere cluster used with Avi, with vSphere DRS configured in Fully Automate mode. VMware HA provides failure protection for a single-node Avi Controller by dynamically migrating and restarting the virtual machine on another server in the event of server failure; enabling vSphere HA is similarly recommended for the vSphere cluster where Avi License Hub is deployed. Administrators should note that if all Service Engines are placed on a single host and that host fails, there is no high availability or immediate failover, making host distribution a deployment planning consideration. Administrators must configure both Avi HA policies and the vSphere cluster settings to fully address this control.

Control 12.5

Central securities depositories shall maintain at least one secondary processing site endowed with adequate resources, capabilities, functions and staffing arrangements to ensure business needs.

SCF Controls: BCD-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several infrastructure capabilities that support the establishment and operation of alternate processing sites with consistent security and operational controls, though the organizational decisions around site selection, physical facility provisioning, and operational procedures fall outside the platform's scope.

VCF supports stretched compute clusters across two geographically separated sites. This architecture allows workloads to run across both locations simultaneously, providing a foundation for alternate site processing. Administrators configure a stretched compute cluster when hosts are available at two sites, with hosts placed in separate sites. Both availability zones must contain an equal number of hosts to allow failover if either zone goes down. vSAN stretched clusters extend a single logical cluster across the two sites, with data mirrored between them. When the site disaster tolerance storage policy is configured for site mirroring, the cluster can tolerate a complete site failure while keeping data accessible. A witness host provides quorum for split-brain scenarios when one site becomes unavailable.

For workload mobility between sites, VCF Operations HCX provides bi-directional migration technologies that move virtual machines between data centers. Workloads can be migrated between private and public cloud sites depending on the deployment model. HCX establishes site pairs where both the source and destination sites work together to provide migration and network extension services, and the destination site can also act as the source of a site pair in bi-directional installations. This allows flexible failover and failback workflows. The HCX Compute Profile configuration with a dedicated Deployment Cluster provides control over site-to-site migration egress traffic, and administrators can customize services between paired sites through the Compute Profile. VMware vMotion provides live migration of powered-on virtual machines to new hosts without service interruption, supporting workload redistribution within and between sites.

NSX Federation provides centralized network configuration across multiple locations. A Global Manager component manages multiple locations, propagating configurations to Local Managers at each site while allowing overrides at individual locations when needed. Active and Standby Global Manager clusters at separate locations synchronize network configuration across sites. In a disaster recovery deployment, NSX at the primary site handles networking for the enterprise, and the secondary site stands by to take over if a catastrophic failure occurs at the primary site. NSX Federation supports recovery of stretched tier-0 and tier-1 gateways to a secondary site using a network recovery workflow. NSX Edge Availability Zone fault-tolerant configurations provide fast network failover across availability zones with no dependency on the physical fabric.

To help maintain consistent security posture across multiple sites, VCF Operations supports single-source configuration for identity and access management across VCF components and multiple geolocations. This capability allows organizations to apply uniform authentication and authorization policies at both primary and alternate sites, reducing the risk of configuration drift between locations. The VCF security baseline can be applied to both default and non-default configurations at any site, helping organizations maintain equivalent security measures across deployments. VCF Operations also includes compliance and security dashboard capabilities that surface core aspects of VCF security in a centralized view. These tools can be used to monitor and compare the security posture of primary and alternate sites, helping administrators identify discrepancies in configuration or policy enforcement. vSphere Host Profiles allow administrators to capture a reference host's configuration, including storage, networking, and security settings, and apply it consistently to all hosts across both sites, so that any drift from the security baseline can be detected and remediated.

vSphere HA with admission control policies helps ensure that clusters have sufficient resources to recover virtual machines when a host fails. For vSAN stretched clusters, admission control should be configured with CPU and memory reservations set to 50% each, reserving capacity at each site to accommodate workload restart during a site failure. Network redundancy through NIC teaming and LACP load balancing provides resilient connectivity at both sites.

VCF provides the infrastructure capabilities for running workloads at alternate sites with consistent security configurations and automated failover, but establishing the physical alternate processing facility, selecting the site, and defining the associated operational agreements remain organizational responsibilities.

VMware vDefend (Contributes)

VMware vDefend (DFW) with Federation supports scoping security and network policies across multiple locations using Security Services Platform (SSP) region-based grouping. In a multi-site deployment, SSP regions can be associated with Security and Network policies to control policy scope across those locations, and each location can belong to one customized region. This allows consistent DFW policy enforcement at both primary and alternate processing sites as workloads operate or migrate across them.

When SSP flow processing capacity at a site is insufficient, administrators can scale out worker nodes based on available storage capacity, or add control plane and worker node resources to the deployment, supporting capacity planning for alternate site configurations. These mechanisms allow the vDefend network security layer to be sized appropriately at the alternate site so that distributed firewall, IDS/IPS, and related enforcement operate with equivalent policy coverage.

vDefend contributes the network security policy layer for alternate site scenarios. Broader alternate site infrastructure provisioning, data replication, physical facility requirements, and the organizational governance needed to establish a fully equivalent alternate processing site fall outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the orchestration platform for establishing and operating an alternate processing site for disaster recovery. In a typical PNR installation, the protected site provides business-critical datacenter services and the recovery site is an alternative infrastructure to which PNR can migrate these services. The Protection and Recovery Appliance must be deployed on both the primary site and the recovery site to enable replication and recovery capabilities.

PNR supports both planned migration and unplanned disaster recovery to the alternate processing site. Planned migration validates orderly workload evacuation between sites. Disaster recovery handles unplanned site failures by starting protected virtual machines at the recovery site. After a disaster recovery operation, a planned migration must be executed when both sites are running again to re-establish the normal operational state.

Bidirectional protection allows each site to serve as both a protected and recovery location for different sets of virtual machines, so both sites operate as fully capable processing environments. Each site must have at least one datacenter configured for protection and recovery. Placeholder datastores must be configured on both sites to support planned migration and reprotect workflows, reinforcing the requirement for equivalent storage infrastructure at the alternate site.

vSphere Replication maintains current copies of protected workloads at the alternate site through continuous host-based replication. In a typical vSphere Replication installation, the local site provides business-critical datacenter services and the remote site is an alternative facility to which services can be migrated.

PNR supports shared recovery site configurations where multiple protected sites share a single recovery site, with concurrent recoveries from multiple sites supported simultaneously.

In PNR, the VCF Operations orchestrator plug-in for Protection and Recovery provides workflow automation for site configuration tasks. The Configure Local Sites workflow validates the PNR connection, imports the site certificate, and registers local sites on both the protected and recovery sites. When both sites are registered as local sites, the plug-in can verify all resource mappings across the site pair, supporting consistent configuration validation.

The security measures at the alternate site, including equivalent network policies, access controls, and security baselines, are provided by the underlying VCF platform infrastructure at each site. PNR provides the workload migration and recovery orchestration that operates within those environments.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 12.5(a)

The secondary processing site shall be located at a geographical distance from the primary site to ensure a distinct risk profile and prevent it from being affected by the same event.

SCF Controls: BCD-09, BCD-09.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several infrastructure capabilities that support the establishment and operation of alternate processing sites with consistent security and operational controls, though the organizational decisions around site selection, physical facility provisioning, and operational procedures fall outside the platform's scope.

VCF supports stretched compute clusters across two geographically separated sites. This architecture allows workloads to run across both locations simultaneously, providing a foundation for alternate site processing. Administrators configure a stretched compute cluster when hosts are available at two sites, with hosts placed in separate sites. Both availability zones must contain an equal number of hosts to allow failover if either zone goes down. vSAN stretched clusters extend a single logical cluster across the two sites, with data mirrored between them. When the site disaster tolerance storage policy is configured for site mirroring, the cluster can tolerate a complete site failure while keeping data accessible. A witness host provides quorum for split-brain scenarios when one site becomes unavailable.

For workload mobility between sites, VCF Operations HCX provides bi-directional migration technologies that move virtual machines between data centers. Workloads can be migrated between private and public cloud sites depending on the deployment model. HCX establishes site pairs where both the source and destination sites work together to provide migration and network extension services, and the destination site can also act as the source of a site pair in bi-directional installations. This allows flexible failover and failback workflows. The HCX Compute Profile configuration with a dedicated Deployment Cluster provides control over site-to-site migration egress traffic, and administrators can customize services between paired sites through the Compute Profile. VMware vMotion provides live migration of powered-on virtual machines to new hosts without service interruption, supporting workload redistribution within and between sites.

NSX Federation provides centralized network configuration across multiple locations. A Global Manager component manages multiple locations, propagating configurations to Local Managers at each site while allowing overrides at individual locations when needed. Active and Standby Global Manager clusters at separate locations synchronize network configuration across sites. In a disaster recovery deployment, NSX at the primary site handles networking for the enterprise, and the secondary site stands by to take over if a catastrophic failure occurs at the primary site. NSX Federation supports recovery of stretched tier-0 and tier-1 gateways to a secondary site using a network recovery workflow. NSX Edge Availability Zone fault-tolerant configurations provide fast network failover across availability zones with no dependency on the physical fabric.

To help maintain consistent security posture across multiple sites, VCF Operations supports single-source configuration for identity and access management across VCF components and multiple geolocations. This capability allows organizations to apply uniform authentication and authorization policies at both primary and alternate sites, reducing the risk of configuration drift between locations. The VCF security baseline can be applied to both default and non-default configurations at any site, helping organizations maintain equivalent security measures across deployments. VCF Operations also includes compliance and security dashboard capabilities that surface core aspects of VCF security in a centralized view. These tools can be used to monitor and compare the security posture of primary and alternate sites, helping administrators identify discrepancies in configuration or policy enforcement. vSphere Host Profiles allow administrators to capture a reference host's configuration, including storage, networking, and security settings, and apply it consistently to all hosts across both sites, so that any drift from the security baseline can be detected and remediated.

vSphere HA with admission control policies helps ensure that clusters have sufficient resources to recover virtual machines when a host fails. For vSAN stretched clusters, admission control should be configured with CPU and memory reservations set to 50% each, reserving capacity at each site to accommodate workload restart during a site failure. Network redundancy through NIC teaming and LACP load balancing provides resilient connectivity at both sites.

VCF provides the infrastructure capabilities for running workloads at alternate sites with consistent security configurations and automated failover, but establishing the physical alternate processing facility, selecting the site, and defining the associated operational agreements remain organizational responsibilities.

VMware vDefend (Contributes)

VMware vDefend (DFW) with Federation supports scoping security and network policies across multiple locations using Security Services Platform (SSP) region-based grouping. In a multi-site deployment, SSP regions can be associated with Security and Network policies to control policy scope across those locations, and each location can belong to one customized region. This allows consistent DFW policy enforcement at both primary and alternate processing sites as workloads operate or migrate across them.

When SSP flow processing capacity at a site is insufficient, administrators can scale out worker nodes based on available storage capacity, or add control plane and worker node resources to the deployment, supporting capacity planning for alternate site configurations. These mechanisms allow the vDefend network security layer to be sized appropriately at the alternate site so that distributed firewall, IDS/IPS, and related enforcement operate with equivalent policy coverage.

vDefend contributes the network security policy layer for alternate site scenarios. Broader alternate site infrastructure provisioning, data replication, physical facility requirements, and the organizational governance needed to establish a fully equivalent alternate processing site fall outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) builds its disaster recovery model on the separation of protected and recovery sites. In a typical installation, the protected site provides business-critical datacenter services and the recovery site is an alternative infrastructure to which PNR can migrate these services. This two-site architecture supports the operational separation between distinct environments needed to reduce susceptibility to threats that affect a single location. The placement of the recovery site at a physically separate facility is an organizational decision that PNR documentation recommends rather than enforces, with guidance that recovery sites be located in a facility unlikely to be affected by the same environmental, infrastructure, or other disturbances as the protected site.

PNR supports logical isolation between sites at the storage layer. Array-based replication can be configured with two separate storage arrays for two PNR instances to achieve full logical isolation. Host-based replication operates independently of the storage array, so the two sites do not share storage failure domains.

Bidirectional protection configurations reinforce operational independence: each site can serve as the recovery site for the other's workloads, and each site must include at least one datacenter for protection and recovery. Each site maintains its own infrastructure and can function as an alternate processing environment.

PNR supports topologies where the same VM is protected to two different sites simultaneously, enabling physical isolation of the disaster recovery site from the clean room site when an organization wants dedicated environments for different recovery scenarios.

Network isolation between sites is supported through isolated test networks during recovery plan exercises, separating test operations from production networks at each site.

In shared recovery site configurations, PNR implements resource isolation to enforce separation between different organizations' virtual machines. Each organization's protected site resources are mapped to dedicated datacenters, networks, folders, and datastores on the shared recovery site, and the service controller manages multi-tenant isolation across protection components. Virtual machines belonging to different customer organizations should be kept separate from each other.

The Cyber Recovery feature provides a clean room as an additional separation model for ransomware recovery. The clean room is configured with dedicated compute resources and isolated networks. PNR supports VCF deployment topologies for cyber recovery where the workload domain is isolated from the management domain, providing strict separation between

management and user workloads in the clean room environment. Private connections between production environments and the clean room should be avoided to preserve isolation.

For VCF Automation deployments, PNR supports a topology with separate management domains for each region, designed to contain the impact of a disaster event to a single region. PNR deployments can span multiple cloud regions and include both on-premises and cloud-based site pairs.

PNR detects split-brain scenarios where production virtual machines are running on both the protected site and recovery site after the protected site comes back online following disaster recovery.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 12.5(b)

The site shall be capable of ensuring the continuity of critical or important functions identically to the primary site, or providing the necessary service level within the recovery objectives.

SCF Controls: BCD-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several infrastructure capabilities that support the establishment and operation of alternate processing sites with consistent security and operational controls, though the organizational decisions around site selection, physical facility provisioning, and operational procedures fall outside the platform's scope.

VCF supports stretched compute clusters across two geographically separated sites. This architecture allows workloads to run across both locations simultaneously, providing a foundation for alternate site processing. Administrators configure a stretched compute cluster when hosts are available at two sites, with hosts placed in separate sites. Both availability zones must contain an equal number of hosts to allow failover if either zone goes down. vSAN stretched clusters extend a single logical cluster across the two sites, with data mirrored between them. When the site disaster tolerance storage policy is configured for site mirroring, the cluster can tolerate a complete site failure while keeping data accessible. A witness host provides quorum for split-brain scenarios when one site becomes unavailable.

For workload mobility between sites, VCF Operations HCX provides bi-directional migration technologies that move virtual machines between data centers. Workloads can be migrated between private and public cloud sites depending on the deployment model. HCX establishes site pairs where both the source and destination sites work together to provide migration and network extension services, and the destination site can also act as the source of a site pair in bi-directional installations. This allows flexible failover and failback workflows. The HCX Compute Profile configuration with a dedicated Deployment Cluster provides control over site-to-site migration egress traffic, and administrators can customize services between paired sites through the Compute Profile. VMware vMotion provides live migration of powered-on virtual machines to new hosts without service interruption, supporting workload redistribution within and between sites.

NSX Federation provides centralized network configuration across multiple locations. A Global Manager component manages multiple locations, propagating configurations to Local Managers at each site while allowing overrides at individual locations when needed. Active and Standby Global Manager clusters at separate locations synchronize network configuration across sites. In a disaster recovery deployment, NSX at the primary site handles networking for the enterprise, and the secondary site stands by to take over if a catastrophic failure occurs at the primary site. NSX Federation supports recovery of stretched tier-0 and tier-1 gateways to a secondary site using a network recovery workflow. NSX Edge Availability Zone fault-tolerant configurations provide fast network failover across availability zones with no dependency on the physical fabric.

To help maintain consistent security posture across multiple sites, VCF Operations supports single-source configuration for identity and access management across VCF components and multiple geolocations. This capability allows organizations to apply uniform authentication and authorization policies at both primary and alternate sites, reducing the risk of configuration drift between locations. The VCF security baseline can be applied to both default and non-default configurations at any site, helping organizations maintain equivalent security measures across deployments. VCF Operations also includes compliance and security dashboard capabilities that surface core aspects of VCF security in a centralized view. These tools can be used to monitor and compare the security posture of primary and alternate sites, helping administrators identify discrepancies in configuration or policy enforcement. vSphere Host Profiles allow administrators to capture a reference host's configuration, including storage, networking, and security settings, and apply it consistently to all hosts across both sites, so that any drift from the security baseline can be detected and remediated.

vSphere HA with admission control policies helps ensure that clusters have sufficient resources to recover virtual machines when a host fails. For vSAN stretched clusters, admission control should be configured with CPU and memory reservations set to 50% each, reserving capacity at each site to accommodate workload restart during a site failure. Network redundancy through NIC teaming and LACP load balancing provides resilient connectivity at both sites.

VCF provides the infrastructure capabilities for running workloads at alternate sites with consistent security configurations and automated failover, but establishing the physical alternate processing facility, selecting the site, and defining the associated operational agreements remain organizational responsibilities.

VMware vDefend (Contributes)

VMware vDefend (DFW) with Federation supports scoping security and network policies across multiple locations using Security Services Platform (SSP) region-based grouping. In a multi-site deployment, SSP regions can be associated with Security and Network policies to control policy scope across those locations, and each location can belong to one customized region. This allows consistent DFW policy enforcement at both primary and alternate processing sites as workloads operate or migrate across them.

When SSP flow processing capacity at a site is insufficient, administrators can scale out worker nodes based on available storage capacity, or add control plane and worker node resources to the deployment, supporting capacity planning for alternate site configurations. These mechanisms allow the vDefend network security layer to be sized appropriately at the alternate site so that distributed firewall, IDS/IPS, and related enforcement operate with equivalent policy coverage.

vDefend contributes the network security policy layer for alternate site scenarios. Broader alternate site infrastructure provisioning, data replication, physical facility requirements, and the organizational governance needed to establish a fully equivalent alternate processing site fall outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the orchestration platform for establishing and operating an alternate processing site for disaster recovery. In a typical PNR installation, the protected site provides business-critical datacenter services and the recovery site is an alternative infrastructure to which PNR can migrate these services. The Protection and Recovery Appliance must be deployed on both the primary site and the recovery site to enable replication and recovery capabilities.

PNR supports both planned migration and unplanned disaster recovery to the alternate processing site. Planned migration validates orderly workload evacuation between sites. Disaster recovery handles unplanned site failures by starting protected virtual machines at the recovery site. After a disaster recovery operation, a planned migration must be executed when both sites are running again to re-establish the normal operational state.

Bidirectional protection allows each site to serve as both a protected and recovery location for different sets of virtual machines, so both sites operate as fully capable processing environments. Each site must have at least one datacenter configured for protection and recovery. Placeholder datastores must be configured on both sites to support planned migration and reprotect workflows, reinforcing the requirement for equivalent storage infrastructure at the alternate site.

vSphere Replication maintains current copies of protected workloads at the alternate site through continuous host-based replication. In a typical vSphere Replication installation, the local site provides business-critical datacenter services and the remote site is an alternative facility to which services can be migrated.

PNR supports shared recovery site configurations where multiple protected sites share a single recovery site, with concurrent recoveries from multiple sites supported simultaneously.

In PNR, the VCF Operations orchestrator plug-in for Protection and Recovery provides workflow automation for site configuration tasks. The Configure Local Sites workflow validates the PNR connection, imports the site certificate, and registers local sites on both the protected and recovery sites. When both sites are registered as local sites, the plug-in can verify all resource mappings across the site pair, supporting consistent configuration validation.

The security measures at the alternate site, including equivalent network policies, access controls, and security baselines, are provided by the underlying VCF platform infrastructure at each site. PNR provides the workload migration and recovery orchestration that operates within those environments.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 12.5(c)

The site shall be immediately accessible to the financial entity's staff.

SCF Controls: BCD-09, BCD-09.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support alternate processing site accessibility planning, though the organizational processes of identifying physical site risks, selecting alternate locations, and developing mitigation plans remain outside the platform's scope.

VCF includes application disaster recovery functionality that enables failover to a secondary site to maintain operations during major disruptions. This capability allows workloads to be redirected to an alternate processing location when the primary site becomes unavailable due to an area-wide event. The platform recommends combining real-time high availability with sitewide disaster recovery for maximum resilience, which directly supports maintaining access to alternate processing resources during extended outages. Disaster recovery may also be implemented for fleet-level components, extending protection beyond individual workloads to the management infrastructure itself. For large clusters, VCF documentation recommends having a disaster recovery plan in place, as an unexpected cluster-wide outage can impact many virtual machines simultaneously.

For environments requiring continuous availability across geographically separated locations, vSAN stretched clusters provide site-level disaster tolerance. A vSAN stretched cluster consists of two data sites and a witness host, with ESX hosts distributed evenly between sites. Each site resides in a separate fault domain, and the site disaster tolerance storage policy rule can be set to site mirroring so that data remains accessible even when one entire site fails. Stretched clusters require independent routing and connectivity between the data sites and the witness host. When a site goes down or loses network connectivity, the surviving site can continue to serve workloads and perform component repairs locally. If one site goes down due to maintenance or failure and the witness host also fails, objects become non-compliant but remain accessible at the surviving site, preserving workload availability during partial failures. Administrators should be aware that selecting the "Ensure accessibility" evacuation mode does not reprotect data during failure, and unexpected data loss may occur under certain conditions. vSAN monitors connectivity between sites and provides monitoring capabilities that allow administrators to examine cluster performance and virtual machine accessibility to diagnose problems. This visibility into object accessibility status helps identify when workloads may be at risk and supports proactive mitigation before a full site failure occurs.

VCF supports distributing compute resources across different fault domains, which helps manage workload placement during site failure. This fault domain architecture allows administrators to map infrastructure to physical locations, making the relationship between compute resources and site accessibility visible and manageable.

NSX supports multisite networking deployments where a secondary site stands by to take over if a catastrophic failure occurs at the primary site. NSX Federation allows stretched tier-0 and tier-1 gateways to be moved between sites using a network recovery workflow, maintaining network connectivity for recovered workloads. This networking layer is important for alternate site accessibility because workloads recovered at a secondary site need functioning network paths to remain reachable.

VCF Operations HCX provides workload mobility capabilities, supporting migrations between sites through Mobility Groups. The Migration interface allows administrators to select sets of virtual machines, configure transfer and placement, and monitor migration progress and history. This supports planned migrations to alternate processing sites and can assist with workload redistribution during disruption scenarios.

VCF Operations offers what-if analysis that can model workload planning scenarios for capacity changes, including traditional and hyperconverged deployments. By committing a scenario, administrators can determine capacity requirements before implementing actual changes. Saved scenarios can be edited and run again cumulatively, providing an iterative planning capability. This helps identify potential accessibility problems at recovery sites before a disruption occurs, such as whether the alternate site has sufficient compute, memory, and storage resources to absorb relocated workloads.

VCF provides monitoring, multi-site architecture, workload mobility, and capacity planning tools that collectively help identify and mitigate accessibility problems at alternate processing sites. However, the organizational activities of site risk assessment, alternate site selection, physical accessibility evaluation, and mitigation plan development require processes and decision-making that fall outside VCF's scope.

VMware vDefend (Contributes)

VMware vDefend (DFW) with Federation supports scoping security and network policies across multiple locations using Security Services Platform (SSP) region-based grouping. In a multi-site deployment, SSP regions can be associated with Security and Network policies to control policy scope across those locations, and each location can belong to one customized region. This allows consistent DFW policy enforcement at both primary and alternate processing sites as workloads operate or migrate across them.

When SSP flow processing capacity at a site is insufficient, administrators can scale out worker nodes based on available storage capacity, or add control plane and worker node resources to the deployment, supporting capacity planning for alternate site configurations. These mechanisms allow the vDefend network security layer to be sized appropriately at the alternate site so that distributed firewall, IDS/IPS, and related enforcement operate with equivalent policy coverage.

vDefend contributes the network security policy layer for alternate site scenarios. Broader alternate site infrastructure provisioning, data replication, physical facility requirements, and the organizational governance needed to establish a fully equivalent alternate processing site fall outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides mechanisms that help identify and mitigate accessibility problems at the alternate processing site before and during area-wide disruptions.

PNR supports recovery plan execution under both planned and unplanned circumstances. Planned migration exercises let organizations validate that the recovery site is accessible and replication infrastructure is functioning before an actual disruption occurs. Recovery plans can be configured with different steps for emergency scenarios versus planned migration of services from one site to another, allowing administrators to account for the distinct operational conditions of each. When the protected site goes offline unexpectedly during disaster recovery operations, failures on the protected site are reported but otherwise ignored, allowing recovery to proceed without requiring both sites to be simultaneously available. PNR documentation also acknowledges that connectivity between sites can be lost, preventing status determination; administrators should account for this when designing recovery procedures.

PNR's multi-region topology design addresses area-wide disruption containment. Deploying with separate management domains for each region is designed to contain the impact of a disaster event to one particular region. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so users can recover workloads. This cross-domain recovery capability extends accessibility mitigation beyond individual site failover.

The recovery site must have hardware, network, and storage resources capable of supporting the same virtual machines and workloads as the protected site. PNR documentation states that recovery sites should be located in a facility unlikely to be affected by environmental, infrastructure, or other disturbances that affect the protected site, directly addressing area-wide disruption scenarios. In shared recovery site configurations, users with appropriate permissions must be able to access the site to create, test, and run recovery plans. Advanced configuration options let administrators customize PNR to support a broader range of site recovery requirements beyond the default configuration.

Broader accessibility planning, including physical network path redundancy, physical site selection, and capacity modeling for large-scale disruption scenarios, is provided by the underlying VCF platform or remains an organizational planning responsibility.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 12.6

In determining the recovery time and recovery point objectives for each function, financial entities shall take into account whether it is a critical or important function and the potential overall impact on market efficiency. Such time objectives shall ensure that, in extreme scenarios, the agreed service levels are met.

SCF Controls: BCD-01.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple recovery technologies with configurable Recovery Time Objective (RTO) and Recovery Point Objective (RPO) settings, enabling organizations to align disaster recovery operations with their specific continuity requirements.

VCF natively provides vSphere Replication, which allows administrators to configure RPO targets, enable network compression, enable multiple point-in-time (MPIT) instances with configurable retention periods, and control automatic replication of new disks. For lower recovery point objectives and orchestrated site failover, Live Site Recovery, part of VCF Protection and Recovery and licensed separately within the Protection and Recovery portfolio, supports replication with an RPO as low as 60 seconds. These granular settings allow recovery configurations to be tuned to match organizational RTO and RPO requirements for protected workloads. VCF Protection and Recovery also supports periodic test runs to verify that existing recovery plans function correctly with the underlying infrastructure, allowing organizations to validate that their RTO and RPO targets are realistic and achievable before an actual disruption occurs.

vSAN stretched clusters extend a single logical cluster across two availability zones with synchronous data mirroring between sites. When the site disaster tolerance parameter is set to site mirroring, the cluster can tolerate one site failure and data remains accessible from the surviving site. This architecture provides near-zero RPO for site-level events, since data is written to both sites before acknowledging the write. When a site fails, vSphere HA restarts any virtual machines that require restart on the remaining active site, providing both minimal RPO and RTO for site-level failures.

vSAN Data Protection provides snapshot-based recovery with configurable retention duration and scheduling intervals. Protection groups define snapshot policies with retention periods and snapshot intervals, giving administrators fine-grained control over recovery point granularity. For example, protection groups can be configured for hourly snapshots with hour-based retention. Snapshots can be replicated to external targets for offsite protection.

vSphere Replication provides an additional replication mechanism with configurable RPO parameters set through the replication specification. For VCF Operations for Networks deployments, replication can be configured for each node that requires protection, with recommended RPO values varying by deployment size. A medium-size deployment with single platform and collector nodes uses a recommended RPO of 45 minutes.

For workloads stored on Virtual Volumes (vVols), Storage Policy Based Management (SPBM) rules can define the maximum RPO as part of the VM storage policy for replication, along with replication schedule and replication frequency. This allows RPO targets to be expressed as storage policy requirements and automatically applied to any workload assigned that policy.

vSphere High Availability (HA) automatically restarts virtual machines on surviving hosts when a host failure is detected, providing fast recovery times for host-level failures. Admission control policies can be specified in vCenter to reserve capacity and set failover share thresholds, coordinated with corresponding vSAN failure tolerance policy settings. For storage failure scenarios, VM Component Protection (VMCP) provides a configurable response when a datastore encounters an All Paths Down (APD) condition; the VMCP Response recovery setting specifies the number of minutes vSphere HA waits before taking action, giving administrators control over how quickly the environment responds to storage inaccessibility events. vSphere Fault Tolerance provides continuous availability for individual workloads in the event of a hardware failure by maintaining a live shadow instance of a virtual machine on a separate host.

At the fleet level, VCF supports disaster recovery for fleet-level components, and Application Disaster Recovery enables failover to a secondary site to maintain operations during major disruptions. Organizations should be aware that Application

Disaster Recovery may result in some data loss during failover depending on the configured RPO. For VCF Operations HCX, a delta synchronization with a two-hour RPO runs while waiting for a scheduled switchover after the initial synchronization completes.

Changed Block Tracking (CBT) tracks modified disk sectors to enable incremental backups through VADP-integrated backup solutions. This reduces backup windows and supports tighter RPO targets by allowing backup tools to capture only the blocks that have changed since the last backup rather than performing full copies each time.

The Consumption layer of the VCF platform extends these capabilities to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. Kubernetes self-healing mechanisms continuously maintain the declared replica count for Deployments and ReplicaSets: when a pod terminates or a node becomes unavailable, the scheduler places replacement pods on healthy nodes, helping reduce RTO for pod-level failures. The NodeOutOfServiceVolumeDetach feature gate allows volumes to be detached from out-of-service nodes and reattached to healthy nodes, which can reduce the time needed to recover stateful pods. Readiness and liveness probes detect container-level faults and trigger pod restarts or traffic removal so that services recover from transient conditions without manual intervention. For batch Job workloads, Kubernetes podFailurePolicy allows administrators to define rules based on container exit codes and pod conditions that distinguish retrievable failures from non-retrievable ones, preventing redundant restart attempts and allowing Jobs to fail fast when the failure type is permanent rather than transient. At the node level, node re-registration drains and reschedules all pods when a node is modified or re-added to a cluster.

VKS cluster health status is surfaced through structured conditions reported by the VKS Controller, including Ready and ControlPlaneReady indicators, and through machine-level health conditions that classify severity as Info, Warning, or Error. These signals give operations teams the visibility needed to detect degraded states and initiate recovery workflows. VKS clusters also support MachineHealthCheck, a Cluster API resource that specifies unhealthy node conditions as an array of condition types, status values, and timeout durations; when a node's conditions match the configured thresholds, MachineHealthCheck triggers automated machine remediation, reducing the manual intervention required to restore node capacity and helping lower RTO for node-level failures. MachineHealthCheck can be applied to control plane and worker node pools and patched at runtime using kubectl. When VKS clusters span multiple availability zones, Kubernetes distributes workloads across zones so that a zone-level failure affects only a subset of running pods; administrators configure topology spread constraints and pod anti-affinity rules to align workload distribution with their RTO targets for individual services.

For backup and restore of containerized workloads, VKS Cluster Management provides data protection capabilities through Velero and native management tooling. Velero backup schedules can be configured to run at defined intervals, allowing organizations to align backup frequency with RPO targets. Restore operations support file system-based backup by default, with optional CSI volume snapshot restoration; restore scope can be specified to select which Kubernetes resources to recover from a backup. Cross-cluster restore allows a backup from one VKS cluster to be applied to a different cluster, accessible through the Data Protection tab in VKS Cluster Management or through the VCF Automation Tenant Portal. VKS Backup and Restore Hooks allow execution of pre- and post-operation scripts to achieve application-consistent backups and automate steps during recovery. Restore progress is tracked through the Data Protection tab, and the CloneFromSnapshot custom resource exposes a status.phase field that reports progress through each phase of a volume restore operation. The Velero backupRepository.config.fullMaintenanceInterval parameter controls repository maintenance behavior. ControllerRevision provides immutable snapshots of state data for DaemonSet and StatefulSet controllers, supporting rollback to a prior configuration. Third-party backup tools can capture point-in-time volume snapshots through the Kubernetes CSI snapshot API, and periodic snapshots of API server backing storage provide a recovery path for storage loss scenarios.

VCF Operations monitors infrastructure health and reports capacity and availability metrics through dashboards, including capacity remaining widgets and capacity summary views across all monitored environments. These give operations teams visibility into whether the environment is meeting its availability targets. Organizations should plan and test their recovery strategies regularly to confirm that actual recovery performance aligns with their stated objectives.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) includes backup and restore capabilities that contribute to recovery operations for the network security enforcement layer. SSP backup and restore functionality allows restoration of a platform instance with the same configuration when the current instance is in a non-recoverable state; a backup must be available before restoration can proceed. During recovery, the SSP instance may remain unhealthy until all VMs are restored, a process that can take up to 30 to 45 minutes. Restore operations may also fail if persistent volume claims cannot be attached to cluster nodes, producing ContainerCreating status and pod initialization delays that extend the recovery window.

SSP backup and restore operations enter a failed state after 30 minutes if internal services are restarted manually or due to failure. Organizations should account for this timeout in RTO calculations and validate recovery procedures through regular testing.

SSP cluster health monitoring defines NetworkUnavailable, DiskPressure, and Ready conditions with a 5-minute timeout threshold for remediation. The MachineHealthCheck mechanism provides a 7-minute recovery window when an SSP VM experiences a network issue; if the issue is not resolved within that window, the VM is deleted and replaced with a new one. These automated health management mechanisms provide concrete timing inputs for RTO planning for the security services layer.

For host-level resilience, vSphere High Availability (HA) should be configured with sufficient Admission Control resources for SSP deployments. When a host running SSP components fails, vSphere HA restarts those components on surviving hosts. Deploying SSP on a vSAN stretched configuration can reduce downtime during site failures by facilitating quick recovery from host or site-level events.

For NDR sensor resilience, a rollback mechanism allows switching the NDR Sensor appliance to a previously saved OS or snapshot and rebooting the sensor to restore the prior state.

While the primary RTO/RPO recovery capabilities for protected workloads reside in VCF components such as Protection and Recovery and vSAN Data Protection, vDefend contributes by providing its own recovery mechanisms with documented timing characteristics. Network security policy enforcement is a dependency for many workloads, so the time required to recover vDefend firewall rules, IDS/IPS configurations, and SSP-hosted analytics directly affects the overall recovery timeline for protected workloads.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable Recovery Point Objective (RPO) and Recovery Time Objective (RTO) mechanisms as its core function.

vSphere Replication supports per-VM RPO configuration using a slider with a range from 1 minute to 24 hours, with a default value of one hour. PNR with vSAN snapshots and replication supports the same 1-minute minimum RPO. The configured RPO determines the maximum acceptable data loss interval; during a disaster recovery event, PNR server attempts a storage synchronization before failover and uses the resulting storage state to recover virtual machines to their most recent available state according to the configured RPO.

PNR introduces replication classes for VCF Automation environments. Replication classes are preconfigured with a specific RPO and allow administrators and tenants to select a protection tier by name. The Platinum replication class defines a 1-minute RPO. Organizations managing multiple workload tiers can assign replication classes that align protection levels with per-application RTO and RPO targets without requiring manual per-VM RPO configuration.

Recovery plans in PNR automate the failover sequence, directly affecting achievable RTO. Recovery plans are flexible and customizable, allowing administrators to define the actions of the PNR server during recovery operations. Adjusting step sequences and understanding step order and execution context are important when tuning actual recovery performance to RTO targets. When the protected site is offline and the PNR server cannot complete its tasks in a timely manner, forced recovery allows a recovery plan to proceed without waiting for a normal handshake with the protected site, bounding RTO in site-loss scenarios. To avoid data loss during forced recovery, administrators should wait until the end of the configured RPO period before initiating the plan.

After failover, the reprotect workflow restores replication in the reverse direction. The reprotect process passes through observable states that can be monitored in the recovery plan within the PNR interface, providing visibility into progress back to a protected state.

PNR also introduces Protection and Recovery dashboards within VCF Operations. These dashboards display vSAN snapshots and replication RPO status and vSphere Replication incoming and outgoing replication usage, providing a centralized view of replication health relative to configured objectives.

Defining RTO and RPO targets per business unit, application tier, and regulatory requirement is an organizational business-continuity-planning decision. PNR provides the mechanisms to achieve configured targets, but the targets themselves originate above the platform.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides technical mechanisms that support an organization's ability to meet defined Recovery Time Objectives and Recovery Point Objectives for database workloads.

Point-in-time recovery. DSM supports point-in-time recovery (PITR) for PostgreSQL, MySQL, and SQL Server databases, allowing administrators to restore data to a specific moment within the configured backup retention period. When initiating a restore, administrators identify a restore point and choose either the most recent timestamp or a user-specified date and time, and the restored database is created as a new database instance. The granularity of recovery is bounded by the configured backup schedule and retention settings, and PITR can only restore data from within the configured retention period. PITR requires the source database to be operational, the required backup to be available, and connectivity to the S3 storage repository. SQL Server PITR can restore onto the same or a different SQL Server cluster. PostgreSQL restore can also target a different DSM control plane by specifying a time value; if the time field is omitted, DSM restores the latest available state. For SQL Server, DSM automatically manages the recovery model based on backup status, using Full Recovery Model when automated backups are enabled and Simple Recovery Model otherwise. PITR may fail or be incomplete if binary log files are missing from the source database, which administrators should account for in operational procedures.

Log backup frequency and RPO. DSM exposes a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes. The log backup frequency is directly related to the achievable RPO for both PostgreSQL and SQL Server databases, and administrators should configure this value based on their RPO requirements.

Database cloning. DSM can clone a MySQL or PostgreSQL database to create an identical database. Cloning is functionally equivalent to PITR to the latest available time and can act as a recovery mechanism when the most recent consistent state is the desired recovery target.

Provider VM recovery and restore duration. DSM documents a recovery procedure for a single Provider VM failure, and the Provider VM restoration must complete fully before proceeding to subsequent recovery steps. This is a relevant consideration for control plane RTO planning. Database restoration duration depends on data volume and underlying infrastructure performance, and administrators should account for this when planning restore operations against an RTO target.

Defining and formally documenting RTO and RPO targets is an organizational process outside DSM's scope. DSM provides the backup, restore, and cloning mechanisms that technical teams configure and test against those targets. Organizations must establish their RTO and RPO requirements, configure DSM backup policies accordingly, test recovery procedures, and verify operational results align with those targets.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several application-layer mechanisms that support an organization's RTO and RPO objectives for the application delivery tier.

At the control-plane level, Avi Controller cluster deployments can span two availability zones, with defined failure scenarios and documented recovery actions for each. When a Controller cluster becomes non-operational, the `recover_cluster.py` script provides a structured recovery path: one node must be recovered with its configuration and become the Controller leader, while other nodes are added as followers. The script requires double confirmation before proceeding unless the `--proceed`

flag is used for non-interactive automation. If all three nodes are permanently unavailable, recovery requires a backup and restore procedure.

Configuration data is the primary RPO-relevant element of the Avi control plane. Enabling periodic external configuration backups is mandatory for single-node Controller deployments, including when deploying Avi Load Balancer within VCF environments using a single-node Controller. The Avi Controller backup and restore capability supports disaster recovery and configuration migration across Controller instances. After a storage failure, the Controller must be restored from the configuration archive. The restore process follows a defined sequence of tasks: cloud discovery, post-restore validation, configuration unblocking, and placement resumption. Factory reset recovery is irreversible and deletes all configuration, making backup-based recovery the preferred path. After a disaster recovery operation, at least one Service Engine controller IP must match a previous controller IP from before the event to enable Service Engines to reconnect to Controllers.

At the data-plane level, in vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, reducing the time to restore application traffic delivery.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling DNS-based traffic steering across sites during a site failure. The GSLB adaptive replication mode prevents faulty configuration objects from replicating to follower sites, protecting against configuration errors that could cause application failure across multiple data centers. GSLB pools configured with the priority algorithm support a manual resume option for controlled failover and recovery management.

Organizations must define RTO and RPO targets for their application delivery tier, configure backup schedules aligned with those targets, and periodically test restore procedures to verify that recovery objectives are achievable in practice.

Control 12.7

When recovering from an ICT-related incident, financial entities shall perform necessary checks, including any multiple checks and reconciliations, in order to ensure that the highest level of data integrity is maintained. These checks shall also be performed when reconstructing data from external stakeholders, in order to ensure that all data is consistent between systems.

SCF Controls: BCD-11.1, BCD-11.5

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides backup and restore capabilities for its management components and workload layers, along with monitoring features that support organizations in verifying backup reliability. Routine backup testing itself requires organizational processes beyond what the platform automates.

VCF supports file-based and image-based backup methods for its core management components, including VMware vCenter, VCF Operations, and NSX Manager. VCF Operations automatically configures NSX Manager backup during the initial bring-up process, while file-based backup jobs for VCF Operations and vCenter must be configured separately. vCenter file-based daily backups are configured through the vCenter Management Interface of each vCenter instance. File-based backups can be stored on FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB servers, and the backup can optionally include Stats, Events, and Tasks data from the vCenter database to preserve historical audit records. Backup files support optional encryption with a password that must be provided again during the restore procedure. The platform recommends creating coordinated backup jobs that capture the state of related management components at a common point in time, so that restores can proceed from a consistent baseline. Scheduled backups should be implemented to prepare for critical failure scenarios, component upgrades, or certificate updates. vSphere Supervisor control plane backup and restore is activated through the vCenter backup feature in the vCenter Management Interface, which also protects VMware Kubernetes Service (VKS) cluster node VMs; this backup is accessible from the Workload Management UI. VKS cluster backup and restore operations for workloads and namespaces are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. This interface supports backup and restore of the entire cluster, selected namespaces from a backup, or specific resources identified by a label, and provides a "Restore from another cluster" function that allows a backup from a source cluster to be applied to a different target cluster. For Kubernetes workloads running on VKS, volume backup status and failures can be confirmed using the Velero CLI with the details flag.

Workload data on VKS clusters is protected through Velero integration. Velero supports two backup strategies: vSphere Plugin Snapshot, which captures persistent volumes at the block level and writes data directly to object storage without requiring a backup repository, and CSI Snapshot combined with File System Backup, which captures data at the file-system level with support for deduplication, compression, and encryption when those repository features are required. The CSI Snapshot and File System Backup methods also support incremental backup, where files that have not changed since the last backup are not re-uploaded. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. Third-party backup software can integrate with the CSI snapshot API to perform volume backup and restore operations against VKS clusters. Velero supports scheduled backup operations, enabling organizations to automate regular backup cadences as a foundation for routine testing.

Velero provides inspection capabilities that support backup verification. The `velero backup describe` command with the details flag reports completed and failed Restic volume backup entries along with source file references and pod identifiers, allowing administrators to diagnose backup failures before depending on a given backup for recovery. VKS cluster backup logs record backup failures with detailed error messages that include the process ID, user ID, group ID, and timestamp of the lock holder when a backup cannot proceed due to an existing exclusive lock. Scheduled backups relying on a deleted data protection account credential will fail on their next execution, and this failure creates a detectable gap in backup execution history visible in the backup monitoring interfaces.

For Kubernetes cluster state, etcd serves as the backing store for all cluster configuration and API objects. etcd supports two backup methods: built-in snapshot via the `etcdctl snapshot save` command (specifying the endpoint, CA certificate, client certificate, and client key) and volume snapshots. Snapshots can be restored from a previous backup file or from a remaining data directory, with cross-patch-version restore supported for the same major.minor etcd version. During `kubeadm` upgrades, VKS automatically writes time-stamped backup folders for etcd data and control plane manifests to `/etc/kubernetes/tmp`, providing a rollback point that can be exercised as part of upgrade validation. Kubernetes guidance recommends that clusters verify backup restorability at regular intervals.

The platform includes built-in integrity verification as part of the restore process. Before restoring a vCenter instance from a file-based backup, the administrator must verify that the vCenter version retrieved from VCF Operations matches the version associated with the backup file. The backup must be of the same version as the vCenter appliance on which the restore will be performed. These version-matching checks help confirm that the backup data is consistent and compatible before a restore operation proceeds. Management component restore operations for VCF Operations, vCenter, and NSX can be tested by performing actual restores to validate backup data integrity.

VCF Operations provides monitoring capabilities that track backup success and failure across the environment. Backup failures are counted over time and grouped by error code, giving administrators visibility into recurring issues. Successful and failed inventory backups are also monitored. NSX tracks the total number of times backup configuration was updated, as well as backup successes and failures for both cluster backups and inventory backups. Alert notifications can be configured for backup failures under Platform Health Alerts, and administrators can track backup and restore process failures on the Infrastructure page under Settings, Infrastructure and Support, Overall Health section. NSX generates a `BackupFailure` alert when a scheduled backup operation fails. After resolving errors in VCF components, administrators can take on-demand manual backups to verify that the backup process is functioning correctly.

The VCF documentation recommends performing an initial on-demand backup after configuring VCF Operations to verify that backups complete successfully. This practice of performing a test backup after configuration is a form of validation, but it is a one-time recommendation rather than an automated recurring test.

For workload-level data protection, vSAN Data Protection allows snapshots to be managed through protection groups with configurable retention policies (duration and time units) and scheduling intervals. Native snapshots in vSAN Express Storage Architecture (ESA) use a B-tree structure instead of a chain structure, allowing more frequent backups and faster recovery than traditional vSphere snapshots. The native Snapshot Service is supported by vSAN ESA but not by vSAN Original Storage Architecture (OSA). Snapshot restore operations can be tested to validate data integrity.

VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions. VADP-based backup partner solutions can automatically perform backup, full restore, and registration of VM Service VMs on a Supervisor. These partner solutions typically include their own backup verification and integrity checking capabilities.

The vCenter API provides the `RecoveryBackupJobBackupRequest` data structure for programmatic backup operations, specifying backup location, protocol, and authorization details. The `com.vmware.appliance.recovery.backup.validate` appliance API command validates backup job parameters without starting the job, allowing administrators to confirm that backup configuration is correct before execution. This API access enables organizations to build automated backup testing workflows that trigger backups and verify completion status programmatically.

VCF directly provides backup scheduling, backup monitoring with failure alerting, on-demand backup testing, version-matching integrity checks, restore capabilities, workload-level snapshot management, and VKS cluster backup and restore through the VCF Automation Tenant Portal. Establishing a routine cadence for testing backup reliability and validating restore procedures requires organizational processes, runbooks, and scheduling that go beyond the platform's built-in automation.

VMware vDefend (Contributes)

VMware vDefend Security Services Platform (SSP) provides backup and restore capabilities for the security platform itself, offering several mechanisms that support routine verification of the backup process.

SSP includes a configurable backup schedule that supports recurring backups, which can be toggled on or off. Backup frequency can be set as weekly on a selected day and time, or as an interval-based schedule ranging from a minimum of 6 hours to a maximum of 720 hours. The SSP Backup History section displays backup operation status, showing Completed when a backup operation is successful, giving operators direct visibility into whether scheduled backups are completing. When a scheduled backup fails, SSP generates a Scheduled Backup Error alarm to notify operators of the failure.

Backup and restore operations generate pod logs that record detailed error messages, including database query failures and volume attachment errors, supporting diagnosis of backup failures. If an operation becomes stuck in a FAILED or QUEUED state, operators can inspect cluster-api pods and backup pod status to troubleshoot the condition.

The SSP Installer data backup produces duplicate platform configuration data that can be restored in the event of hardware malfunctions, software malfunctions, data corruption, malware incidents, or unintentional data deletion. Restore operations require adequate storage on the target server, the same NSX instance that was onboarded at the time of backup, and the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored SSP environments is required to avoid service disruptions, including disruptions to NDR Sensors.

vDefend's contribution is to the operational health and backup completion visibility of the security platform itself. The control asks whether the organization routinely tests backups for reliability and integrity; vDefend provides the scheduling, status tracking, and alerting mechanisms that support such testing, but automated restoration testing and integrity validation of backup content require supplemental organizational procedures.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides non-disruptive testing capabilities that exercise the recovery process and verify the integrity and availability of replicated data at the recovery site. The cadence and scope of routine testing remain an organizational practice.

Recovery plan tests run virtual machines on a test network and against a temporary snapshot of replicated data at the recovery site, isolating test execution from production data and from ongoing operations at either site. Tests can be run as often as needed and cancelled at any time without impacting production systems. Testing exercises nearly every aspect of a recovery plan to validate disaster recovery readiness. PNR documentation recommends testing recovery plans before use for planned migration or disaster recovery to validate functionality before production execution, as failure to test may result in data loss during an actual disaster recovery. After a reprotect operation completes, running a test recovery verifies that errors are resolved before running a planned migration or disaster recovery. After testing completes, the cleanup capability removes test artifacts so they do not persist in the recovery environment.

Recovery plan testing can be configured to replicate recent changes to the recovery site so that the test exercises the latest copy of protected virtual machines, though this may increase synchronization time. PNR can generate and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup for audit trail purposes, providing a record of testing activity that administrators can reference.

PNR monitors protection group and recovery plan health, detecting critical issues including loss of connectivity to protected or destination sites, snapshot replication failure, and recovery plan malfunction. The Protection and Recovery management pack integrates with VCF Operations to enable data collection from PNR Cloud instances and provide centralized dashboarding of recovery telemetry.

Traditional backup testing capabilities, including platform component backup validation and VADP-based third-party backup verification, are provided by the underlying VCF platform (see VCF Coverage). Establishing a routine test schedule, defining acceptance criteria, and recording test outcomes for audit are organizational responsibilities that sit outside PNR's automated scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides automated backup capabilities, backup health monitoring, integrity-verification mechanisms, and on-demand restore tooling that support an organization's routine backup verification practices. A formal backup testing program itself requires organizational process.

DSM supports automated backups for databases with configurable backup schedules and retention periods. PostgreSQL databases use configurable settings for backup location, retention period, and backup schedule, controlled by the Enable Automated Backups setting during database creation or through database settings afterward. DSM data service policies can be configured to require automated backups, allow them as optional, or disallow them, giving administrators a way to enforce backup coverage on databases under a policy. High Availability clusters require automated backups to be enabled before databases can be provisioned. Backup chain integrity depends on retaining the last full backup and all subsequent incrementals. If any incremental in the chain is deleted, DSM cannot restore the full data, which is a consideration when designing retention policy and backup chain management procedures.

Backup health is actively monitored. DSM validates the connection and operational status of the backup storage repository, verifies the bucket name, checks credential expiration, confirms certificate expiration dates, and validates that there is sufficient available repository space. Scheduled backup failure alerts notify administrators when a scheduled backup operation fails, and the monitoring framework supports metrics-based and status-condition alerts that identify critical failure conditions including database engine degradation, non-operational status, and automated or transaction log backup failure. Webhook payloads triggered by data service operation failures can be validated using the TEST function before deployment so that failure notifications reach the intended target. A trusted root certificate must be configured for each backup location used by a data service policy that requires or allows automated backups.

For data integrity verification, DSM PostgreSQL distributions include the amcheck extension at versions 1.2, 1.3, and 1.4 across the supported PostgreSQL builds, which provides functions for verifying relation integrity directly inside the database. Administrators can use amcheck to spot-check that a restored database's internal structures are sound after a recovery exercise, giving the testing program a database-engine-level data integrity check.

Administrators have several mechanisms to verify recoverability. DSM supports point-in-time recovery (PITR) that restores a backup at a specific point in time to a new database instance, with restoration possible to any point within the configured backup retention period. The restore creates a new database VM with a user-specified name and datastore location, so the test restore does not affect the source database. Deleted database backups remain available and can be restored to a newly created database VM at the most recent timestamp or to a specific point in time, supporting test restores of historic state. On-demand backups can be triggered manually for primary PostgreSQL databases to capture a known-good state before a planned change or verification exercise. DSM Provider VM recovery from backup is supported through the restore-provider command with the pgbackrest.conf path, which restores the Provider VM to the latest timestamp after a terminal failure during non-upgrade operations. The Provider VM requires a Provider Backup Repo to be configured before recovery is possible. Tenants can also restore a database to a specified restore point through the VCF Automation UI when DSM is consumed through VCF Automation.

While DSM provides the backup infrastructure, monitoring, validation, integrity-verification, and restore capabilities that form the technical foundation of a backup testing program, the organization must conduct scheduled restore tests against non-production environments to validate actual data recoverability, document the results, and maintain a formal testing cadence. DSM does not automate test restores to a separate environment, so these organizational procedures are required to fully satisfy this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides backup and restore capabilities for the Avi Controller configuration, including automated scheduling, multiple storage destinations, pre-restore integrity validation, and post-restore verification.

The Controller backup scheduler automates periodic backup operations. Configuration data can be written to local storage on the Controller with a configurable retention count, or to a remote backup destination. Configuring a remote backup destination is recommended to protect against scenarios where the Controller cluster fails in a non-recoverable fashion. In VCF-integrated deployments, VCF Operations is used to configure the external backup server and storage path; by default, Avi Load Balancer backups are stored on the same server where VCF Operations appliance backups are stored. For single-node Controller deployments and when recovering from a complete VM or disk failure, enabling periodic external configuration backups is mandatory. Administrators can use the `show backups` CLI command to list available backup files,

and the `export` command to capture a full system configuration or individual virtual service configurations. A backup must be verified as taken prior to initiating any upgrade operation. After upgrades, backups should be stored with clear labeling that includes version and date.

Restore operations can be initiated through the CLI using the `import` command with the `keep_uuid` option to restore to an empty Controller, or through the REST API by attaching a configuration backup file and providing the decryption passphrase. Before any restore proceeds, the Avi Controller performs pre-restore validation checks that verify Controller Cluster readiness, upgrade operation status, ServiceEngineGroup upgrade status, backup configuration version compatibility, FIPS mode alignment between the backup and the target environment, the presence of required file objects, and configuration validity. These checks are logged with timestamps, including FIPS configuration status and image validation state. In VCF-integrated environments, the restored Controller instance must remain synchronized with the VCF Operations lifecycle.

After a restore completes, the Controller performs post-restore validation tasks that verify the successful restoration of configuration objects, including counts of restored Clouds and ServiceEngineGroups. This confirms that backup data has been correctly applied before the system returns to service.

Organizations should establish a defined process to periodically execute test restores, verify that recovered configurations are complete, and record results as evidence of backup program effectiveness.

Control 13.1

Financial entities shall have capabilities and staff to gather information on vulnerabilities and cyber threats, ICT-related incidents, and analyze their likely impact.

SCF Controls: THR-01, THR-03

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend contributes to this control through its threat intelligence consumption and detection infrastructure. The IDS/IPS engine applies knowledge-based signatures that encode specific patterns corresponding to known attack types, detecting intrusions based on known malicious instruction sequences at distributed and gateway enforcement points within vDefend-protected segments. Threat metadata feeds for Network Detection and Response are distributed and can be refreshed from online sources, or downloaded and applied manually in air-gapped environments through NSX Manager or a workstation connected to the Security Services Platform.

Network Detection and Response (NDR) correlates related detection events into campaigns and organizes them into a chronological timeline for security analyst review and triage. The Campaign view displays total detections and threats identified under Malicious Activity, and Campaign Correlation Rules provide structured visibility into how individual detections relate to broader attack patterns.

Security Intelligence maps detected suspicious events to adversarial tactics and techniques from the MITRE ATT&CK framework, recording the count of each tactic and technique observed during a selected time period. This TTP-level categorization supports the situational awareness the control describes for traffic traversing vDefend-protected segments. The threat visualization canvas aids rapid containment, identification of compromised assets, and adjustment of microsegmentation policies in response to detected activity. The blast radius analysis capability displays which communication paths a threat has affected, helping analysts determine whether an attack targets specific systems or represents a wider campaign.

Security Intelligence also collects related IDS events across the same source and destination hosts to connect relevant events and build a fuller picture of an attack sequence. The vDefend Security Assessment generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows to support protection planning. Security teams investigate individual events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take mitigation actions.

While vDefend delivers technical mechanisms for consuming threat intelligence feeds and mapping observed behavior to adversarial TTPs at the network layer, the broader organizational threat intelligence program, including sourcing intelligence from external providers, integrating with threat sharing platforms, and disseminating findings to other teams and tools, requires complementary processes and tooling outside the product.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to situational awareness of evolving threats at the application delivery layer through its Live Security Threat Intelligence service, which delivers security threat feeds for multiple attack vectors in real time to protect applications from continuously changing threats. The Live Security Threat Intelligence service encompasses four components: an IP Reputation Service, an Application Rules Service, a WAF Signatures Service, and a Bot Management Service. The service is opt-in and must be explicitly enabled through Cloud Services configuration on the Avi Controller.

The IP Reputation Service classifies incoming client IP addresses against a regularly updated database, covering threat categories including botnets, phishing, spam sources, and DoS/DDoS attack sources. The service performs real-time automatic IP Reputation updates and operates across globally distributed Avi Load Balancer Controller clusters.

Administrators attach an IP Reputation database to virtual services, and enforcement actions such as blocking or rate-limiting are applied per classification result.

The Application Rules Service provides rules specifically designed to block attacks on known application vulnerabilities, many of them mapped to CVEs, covering protection for over 5,000 applications including WordPress, Drupal, and Apache. Application Rules are automatically updated on the Avi Controller, and administrators can enable auto-sync to receive Application Rules Database updates automatically when new rules are published.

The WAF Signatures Service allows Avi to receive notifications when new Core Rule Set (CRS) data is available and to automatically download updated WAF CRS rules. This keeps application-layer defenses aligned with current vulnerability intelligence without requiring manual administrator action.

The Bot Management Service delivers a real-time feed for the User-Agent database, a core bot detection component. User Agent Database Sync can be enabled to receive continuous User-Agent updates for threat detection. Traffic is classified into categories including Bad Bot, Dangerous Bot, Good Bot, Human, Unknown, and User-defined Bot, and HTTP security policy rules apply enforcement actions including connection termination for dangerous bot classifications.

When Avi detects security events such as SYN flood or DDoS conditions, its alerting and ControlScript framework supports automated compensating responses. Alert actions can invoke a ControlScript that adds offending client IP addresses to a blocklist IP group attached to a network security policy for rate shaping or blocking. ControlScripts receive alert parameters including attack count, event ID, and alert level, and can execute automated remediation in response to system events rather than requiring manual intervention. The DDoS Policy within the Network Security policy detects and mitigates a range of Layer 4 through Layer 7 network attacks.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.2

Financial entities shall put in place post ICT-related incident reviews after a major ICT-related incident disrupts their core activities, analyzing causes and identifying required improvements.

SCF Controls: BCD-05, IRO-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.2(a)

Reviews shall determine the promptness in responding to security alerts and determining the impact/severity of incidents.

SCF Controls: BCD-05, IRO-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.2(b)

Reviews shall determine the quality and speed of performing a forensic analysis, where deemed appropriate.

SCF Controls: BCD-05, IRO-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.2(c)

Reviews shall determine the effectiveness of incident escalation within the financial entity.

SCF Controls: BCD-05, IRO-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.2(d)

Reviews shall determine the effectiveness of internal and external communication.

SCF Controls: BCD-05, IRO-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.3

Lessons derived from digital operational resilience testing, real life incidents, challenges in plan activation, and information exchanged with counterparts/supervisory reviews shall be duly incorporated into the ICT risk assessment process and form the basis for appropriate reviews of the ICT risk management framework.

SCF Controls: BCD-05, IRO-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.4

Financial entities shall monitor the effectiveness of their digital operational resilience strategy, map the evolution of ICT risk over time, and analyze the frequency, types, magnitude and evolution of incidents to enhance cyber maturity and preparedness.

SCF Controls: GOV-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.5

Senior ICT staff shall report at least yearly to the management body on the findings referred to in paragraph 3 and put forward recommendations.

SCF Controls: GOV-01.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.6

Financial entities shall develop ICT security awareness programmes and digital operational resilience training as compulsory modules applicable to all employees and senior management staff.

SCF Controls: SAT-01, SAT-02, SAT-03, SAT-03.6

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.7

Financial entities, other than microenterprises, shall monitor relevant technological developments on a continuous basis to understand their possible impact on ICT security and digital operational resilience, and keep up-to-date with the latest ICT risk management processes.

SCF Controls: TDA-01, TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 14.1

As part of the ICT risk management framework, financial entities shall have in place crisis communication plans enabling a responsible disclosure of, at least, major ICT-related incidents or vulnerabilities to clients and counterparts as well as to the public, as appropriate.

SCF Controls: IRO-01, IRO-02, IRO-07, IRO-10, IRO-11

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 14.2

Financial entities shall implement communication policies for internal staff and for external stakeholders, differentiating between staff roles (e.g., those involved in response vs. those needing information).

SCF Controls: IRO-01, IRO-02, IRO-07, IRO-10, IRO-11

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 14.3

At least one person in the financial entity shall be tasked with implementing the communication strategy for ICT-related incidents and fulfill the public and media function.

SCF Controls: IRO-01, IRO-02, IRO-07, IRO-10, IRO-11

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.1(a)

Entities shall put in place and maintain a sound and documented ICT risk management framework that details the mechanisms and measures aimed at a quick, efficient and comprehensive management of ICT risk.

SCF Controls: GOV-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.1(b)

Entities shall continuously monitor the security and functioning of all ICT systems.

SCF Controls: GOV-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.1(c)

Entities shall minimize the impact of ICT risk through the use of sound, resilient and updated ICT systems, protocols and tools.

SCF Controls: GOV-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.1(d)

Entities shall allow sources of ICT risk and anomalies to be promptly identified and detected and ICT-related incidents to be swiftly handled.

SCF Controls: GOV-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.1(e)

Entities shall identify key dependencies on ICT third-party service providers.

SCF Controls: GOV-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.1(f)

Entities shall ensure the continuity of critical or important functions, through business continuity plans and response and recovery measures, which include, at least, back-up and restoration measures.

SCF Controls: GOV-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.1(g)

Entities shall test, on a regular basis, the plans and measures referred to in point (f), as well as the effectiveness of the controls.

SCF Controls: GOV-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.1(h)

Entities shall implement relevant operational conclusions resulting from the tests and post-incident analysis, and develop, according to needs, ICT security awareness programmes and digital operational resilience training for staff and management.

SCF Controls: GOV-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 16.2

The simplified ICT risk management framework shall be documented and reviewed periodically and upon the occurrence of major ICT-related incidents, and continuously improved. A report on the review shall be submitted to the competent authority upon request.

SCF Controls: GOV-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 17.1

Financial entities shall define, establish and implement an ICT-related incident management process to detect, manage and notify ICT-related incidents.

SCF Controls: IRO-01, IRO-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides data protection incident response capabilities through structured recovery plans, non-disruptive testing, and automated failover orchestration. Recovery plans define documented, repeatable response procedures that specify VM recovery sequences and reprotect operations following a recovery event, with reprotect process states displayed in the recovery plan user interface so operators can observe operation status. Test failover and planned migration operations validate response readiness before an incident, and disaster recovery failover handles unplanned events when the protected site is unavailable.

PNR's event logging and alarm framework detects conditions that may indicate a data protection incident, including site connectivity loss, replication failures, and interrupted reprotect operations. PNR captures audit events that record user actions, including configuration changes and recovery plan executions, with the event name, user identity, and source IP address where the event was initiated. The PlanExecReprotectEnd event is signaled on the recovery site when a reprotect operation completes, supporting closure of the response lifecycle. Protection and Recovery Dashboards in VCF Operations provide consolidated visibility across vCenters, vSAN snapshot and replication sites, VCF Protection and Recovery Cloud regions, and protection and recovery site pairs to help incident responders see protection status at a glance.

For cyber-incident scenarios, PNR includes Cyber Recovery with a clean room at the recovery site to isolate recovered workloads during ransomware analysis. Cyber Recovery integrates with Carbon Black and CrowdStrike for security and vulnerability analysis; results include risk score details, environmental impact, CrowdScore severity (a CrowdScore of 100 indicates a critical threat level), and recommended remediation actions to support response decisions. When a disaster affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so organization users can return to running their workloads.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 17.2

Financial entities shall record all ICT-related incidents and significant cyber threats, and establish procedures to ensure consistent monitoring, handling, and follow-up to prevent recurrence.

SCF Controls: IRO-01, IRO-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides data protection incident response capabilities through structured recovery plans, non-disruptive testing, and automated failover orchestration. Recovery plans define documented, repeatable response procedures that specify VM recovery sequences and reprotect operations following a recovery event, with reprotect process states displayed in the recovery plan user interface so operators can observe operation status. Test failover and planned migration operations validate response readiness before an incident, and disaster recovery failover handles unplanned events when the protected site is unavailable.

PNR's event logging and alarm framework detects conditions that may indicate a data protection incident, including site connectivity loss, replication failures, and interrupted reprotect operations. PNR captures audit events that record user actions, including configuration changes and recovery plan executions, with the event name, user identity, and source IP address where the event was initiated. The PlanExecReprotectEnd event is signaled on the recovery site when a reprotect operation completes, supporting closure of the response lifecycle. Protection and Recovery Dashboards in VCF Operations provide consolidated visibility across vCenters, vSAN snapshot and replication sites, VCF Protection and Recovery Cloud regions, and protection and recovery site pairs to help incident responders see protection status at a glance.

For cyber-incident scenarios, PNR includes Cyber Recovery with a clean room at the recovery site to isolate recovered workloads during ransomware analysis. Cyber Recovery integrates with Carbon Black and CrowdStrike for security and vulnerability analysis; results include risk score details, environmental impact, CrowdScore severity (a CrowdScore of 100 indicates a critical threat level), and recommended remediation actions to support response decisions. When a disaster affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so organization users can return to running their workloads.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 17.3

The ICT-related incident management process shall:

SCF Controls: IRO-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides data protection incident response capabilities through structured recovery plans, non-disruptive testing, and automated failover orchestration. Recovery plans define documented, repeatable response procedures that specify VM recovery sequences and reprotect operations following a recovery event, with reprotect process states displayed in the recovery plan user interface so operators can observe operation status. Test failover and planned migration operations validate response readiness before an incident, and disaster recovery failover handles unplanned events when the protected site is unavailable.

PNR's event logging and alarm framework detects conditions that may indicate a data protection incident, including site connectivity loss, replication failures, and interrupted reprotect operations. PNR captures audit events that record user actions, including configuration changes and recovery plan executions, with the event name, user identity, and source IP address where the event was initiated. The PlanExecReprotectEnd event is signaled on the recovery site when a reprotect operation completes, supporting closure of the response lifecycle. Protection and Recovery Dashboards in VCF Operations provide consolidated visibility across vCenters, vSAN snapshot and replication sites, VCF Protection and Recovery Cloud regions, and protection and recovery site pairs to help incident responders see protection status at a glance.

For cyber-incident scenarios, PNR includes Cyber Recovery with a clean room at the recovery site to isolate recovered workloads during ransomware analysis. Cyber Recovery integrates with Carbon Black and CrowdStrike for security and vulnerability analysis; results include risk score details, environmental impact, CrowdScore severity (a CrowdScore of 100 indicates a critical threat level), and recommended remediation actions to support response decisions. When a disaster affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so organization users can return to running their workloads.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 17.3(a)

Put in place early warning indicators.

SCF Controls: IRO-01, IRO-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides data protection incident response capabilities through structured recovery plans, non-disruptive testing, and automated failover orchestration. Recovery plans define documented, repeatable response procedures that specify VM recovery sequences and reprotect operations following a recovery event, with reprotect process states displayed in the recovery plan user interface so operators can observe operation status. Test failover and planned migration operations validate response readiness before an incident, and disaster recovery failover handles unplanned events when the protected site is unavailable.

PNR's event logging and alarm framework detects conditions that may indicate a data protection incident, including site connectivity loss, replication failures, and interrupted reprotect operations. PNR captures audit events that record user actions, including configuration changes and recovery plan executions, with the event name, user identity, and source IP address where the event was initiated. The PlanExecReprotectEnd event is signaled on the recovery site when a reprotect operation completes, supporting closure of the response lifecycle. Protection and Recovery Dashboards in VCF Operations provide consolidated visibility across vCenters, vSAN snapshot and replication sites, VCF Protection and Recovery Cloud regions, and protection and recovery site pairs to help incident responders see protection status at a glance.

For cyber-incident scenarios, PNR includes Cyber Recovery with a clean room at the recovery site to isolate recovered workloads during ransomware analysis. Cyber Recovery integrates with Carbon Black and CrowdStrike for security and vulnerability analysis; results include risk score details, environmental impact, CrowdScore severity (a CrowdScore of 100 indicates a critical threat level), and recommended remediation actions to support response decisions. When a disaster affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so organization users can return to running their workloads.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 17.3(b)

Establish procedures to identify, track, log, categorise and classify ICT-related incidents according to their priority, severity, and criticality of services impacted.

SCF Controls: IRO-01, IRO-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides data protection incident response capabilities through structured recovery plans, non-disruptive testing, and automated failover orchestration. Recovery plans define documented, repeatable response procedures that specify VM recovery sequences and reprotect operations following a recovery event, with reprotect process states displayed in the recovery plan user interface so operators can observe operation status. Test failover and planned migration operations validate response readiness before an incident, and disaster recovery failover handles unplanned events when the protected site is unavailable.

PNR's event logging and alarm framework detects conditions that may indicate a data protection incident, including site connectivity loss, replication failures, and interrupted reprotect operations. PNR captures audit events that record user actions, including configuration changes and recovery plan executions, with the event name, user identity, and source IP address where the event was initiated. The PlanExecReprotectEnd event is signaled on the recovery site when a reprotect operation completes, supporting closure of the response lifecycle. Protection and Recovery Dashboards in VCF Operations provide consolidated visibility across vCenters, vSAN snapshot and replication sites, VCF Protection and Recovery Cloud regions, and protection and recovery site pairs to help incident responders see protection status at a glance.

For cyber-incident scenarios, PNR includes Cyber Recovery with a clean room at the recovery site to isolate recovered workloads during ransomware analysis. Cyber Recovery integrates with Carbon Black and CrowdStrike for security and vulnerability analysis; results include risk score details, environmental impact, CrowdScore severity (a CrowdScore of 100 indicates a critical threat level), and recommended remediation actions to support response decisions. When a disaster affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so organization users can return to running their workloads.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 17.3(c)

Assign roles and responsibilities that need to be activated for different incident types.

SCF Controls: IRO-01, IRO-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides data protection incident response capabilities through structured recovery plans, non-disruptive testing, and automated failover orchestration. Recovery plans define documented, repeatable response procedures that specify VM recovery sequences and reprotect operations following a recovery event, with reprotect process states displayed in the recovery plan user interface so operators can observe operation status. Test failover and planned migration operations validate response readiness before an incident, and disaster recovery failover handles unplanned events when the protected site is unavailable.

PNR's event logging and alarm framework detects conditions that may indicate a data protection incident, including site connectivity loss, replication failures, and interrupted reprotect operations. PNR captures audit events that record user actions, including configuration changes and recovery plan executions, with the event name, user identity, and source IP address where the event was initiated. The PlanExecReprotectEnd event is signaled on the recovery site when a reprotect operation completes, supporting closure of the response lifecycle. Protection and Recovery Dashboards in VCF Operations provide consolidated visibility across vCenters, vSAN snapshot and replication sites, VCF Protection and Recovery Cloud regions, and protection and recovery site pairs to help incident responders see protection status at a glance.

For cyber-incident scenarios, PNR includes Cyber Recovery with a clean room at the recovery site to isolate recovered workloads during ransomware analysis. Cyber Recovery integrates with Carbon Black and CrowdStrike for security and vulnerability analysis; results include risk score details, environmental impact, CrowdScore severity (a CrowdScore of 100 indicates a critical threat level), and recommended remediation actions to support response decisions. When a disaster affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so organization users can return to running their workloads.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 17.3(d)

Set out plans for communication to staff, external stakeholders, and media, notification to clients, for internal escalation, and provision of information to counterparts.

SCF Controls: IRO-01, IRO-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 17.3(e)

Ensure that at least major ICT-related incidents are reported to relevant senior management and inform the management body.

SCF Controls: IRO-01, IRO-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 17.3(f)

Establish ICT-related incident response procedures to mitigate impacts and ensure that services become operational and secure in a timely manner.

SCF Controls: IRO-01, IRO-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides data protection incident response capabilities through structured recovery plans, non-disruptive testing, and automated failover orchestration. Recovery plans define documented, repeatable response procedures that specify VM recovery sequences and reprotect operations following a recovery event, with reprotect process states displayed in the recovery plan user interface so operators can observe operation status. Test failover and planned migration operations validate response readiness before an incident, and disaster recovery failover handles unplanned events when the protected site is unavailable.

PNR's event logging and alarm framework detects conditions that may indicate a data protection incident, including site connectivity loss, replication failures, and interrupted reprotect operations. PNR captures audit events that record user actions, including configuration changes and recovery plan executions, with the event name, user identity, and source IP address where the event was initiated. The PlanExecReprotectEnd event is signaled on the recovery site when a reprotect operation completes, supporting closure of the response lifecycle. Protection and Recovery Dashboards in VCF Operations provide consolidated visibility across vCenters, vSAN snapshot and replication sites, VCF Protection and Recovery Cloud regions, and protection and recovery site pairs to help incident responders see protection status at a glance.

For cyber-incident scenarios, PNR includes Cyber Recovery with a clean room at the recovery site to isolate recovered workloads during ransomware analysis. Cyber Recovery integrates with Carbon Black and CrowdStrike for security and vulnerability analysis; results include risk score details, environmental impact, CrowdScore severity (a CrowdScore of 100 indicates a critical threat level), and recommended remediation actions to support response decisions. When a disaster affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so organization users can return to running their workloads.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 18.1

Financial entities shall classify ICT-related incidents and shall determine their impact based on the following criteria:

SCF Controls: IRO-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require

zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 18.1(a)

The number and/or relevance of clients or financial counterparts affected, amount/number of transactions affected, and reputational impact.

SCF Controls: IRO-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 18.1(b)

The duration of the ICT-related incident, including the service downtime.

SCF Controls: IRO-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 18.1(c)

The geographical spread with regard to the areas affected by the ICT-related incident, particularly if it affects more than two Member States.

SCF Controls: IRO-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 18.1(d)

The data losses that the ICT-related incident entails, in relation to availability, authenticity, integrity or confidentiality of data.

SCF Controls: IRO-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as `callerId`, `propagateAlertUpdates`, `retrieveIncidentUpdates`, and `incidentReopenState`, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require

zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 18.1(e)

The criticality of the services affected, including the financial entity's transactions and operations.

SCF Controls: IRO-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 18.1(f)

The economic impact, in particular direct and indirect costs and losses.

SCF Controls: IRO-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 18.2

Financial entities shall classify cyber threats as significant based on the criticality of the services at risk, including transactions and operations, number/relevance of clients targeted, and geographical spread.

SCF Controls: IRO-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 19.1

Financial entities shall report major ICT-related incidents to the relevant competent authority as referred to in Article 46 in accordance with paragraph 4 of this Article. Where a financial entity is subject to supervision by more than one national competent authority referred to in Article 46, Member States shall designate a single competent authority as the relevant competent authority responsible for carrying out the functions and duties provided for in this Article. Credit institutions classified as significant, in accordance with Article 6(4) of Regulation (EU) No 1024/2013, shall report major ICT-related incidents to the relevant national competent authority designated in accordance with Article 4 of Directive 2013/36/EU, which shall immediately transmit that report to the ECB. For the purpose of the first subparagraph, financial entities shall produce, after collecting and analysing all relevant information, the initial notification and reports referred to in paragraph 4 of this Article using the templates referred to in Article 20 and submit them to the competent authority. In the event that a technical impossibility prevents the submission of the initial notification using the template, financial entities shall notify the competent authority about it via alternative means. The initial notification and reports referred to in paragraph 4 shall include all information necessary for the competent authority to determine the significance of the major ICT-related incident and assess possible cross-border impacts. Without prejudice to the reporting pursuant to the first subparagraph by the financial entity to the relevant competent authority, Member States may additionally determine that some or all financial entities shall also provide the initial notification and each report referred to in paragraph 4 of this Article using the templates referred to in Article 20 to the competent authorities or the computer security incident response teams (CSIRTs) designated or established in accordance with Directive (EU) 2022/2555.

SCF Controls: IRO-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 19.2

Financial entities may, on a voluntary basis, notify significant cyber threats to the relevant competent authority when they deem the threat to be of relevance to the financial system, service users or clients. The relevant competent authority may provide such information to other relevant authorities referred to in paragraph 6. Credit institutions classified as significant, in accordance with Article 6(4) of Regulation (EU) No 1024/2013, may, on a voluntary basis, notify significant cyber threats to relevant national competent authority, designated in accordance with - Article 4 of Directive 2013/36/EU, which shall immediately transmit the notification to the ECB. Member States may determine that those financial entities that on a voluntary basis notify in accordance with the first subparagraph may also transmit that notification to the CSIRTs designated or established in accordance with Directive (EU) 2022/2555.

SCF Controls: IRO-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 19.3

Where a major ICT-related incident occurs and has an impact on the financial interests of clients, financial entities shall, without undue delay as soon as they become aware of it, inform their clients about the major ICT-related incident and about the measures that have been taken to mitigate the adverse effects of such incident. In the case of a significant cyber threat, financial entities shall, where applicable, inform their clients that are potentially affected of any appropriate protection measures which the latter may consider taking.

SCF Controls: IRO-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 19.4

Financial entities shall, within the time limits to be laid down in accordance with Article 20, first paragraph, point (a), point (ii), submit the following to the relevant competent authority:

SCF Controls: IRO-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 19.4(a)

| An initial notification.

SCF Controls: IRO-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 19.4(b)

An intermediate report after the initial notification referred to in point (a), as soon as the status of the original incident has changed significantly or the handling of the major ICT-related incident has changed based on new information available, followed, as appropriate, by updated notifications every time a relevant status update is available, as well as upon a specific request of the competent authority.

SCF Controls: IRO-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 19.4(c)

A final report, when the root cause analysis has been completed, regardless of whether mitigation measures have already been implemented, and when the actual impact figures are available to replace estimates.

SCF Controls: IRO-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 19.5

Financial entities may outsource, in accordance with Union and national sectoral law, the reporting obligations under this Article to a third-party service provider. In case of such outsourcing, the financial entity remains fully responsible for the fulfilment of the incident reporting requirements.

SCF Controls: IRO-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 23

The requirements in Chapter III also apply to operational or security payment-related incidents and to major operational or security payment-related incidents, where they concern credit institutions, payment institutions, account information service providers, and electronic money institutions.

SCF Controls: CPL-01.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 24.1

Financial entities, other than microenterprises, shall establish, maintain and review a sound and comprehensive digital operational resilience testing programme as an integral part of the ICT risk-management framework.

SCF Controls: BCD-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several infrastructure-level capabilities that support an organization's contingency plan testing and exercise program, though the planning, scheduling, execution, and evaluation of formal contingency tests remains an organizational responsibility.

VCF includes built-in recovery and high-availability mechanisms that organizations can exercise during contingency tests. vSAN stretched clusters can be exercised by simulating site failures through host maintenance mode operations, validating that the surviving availability zone continues storage and compute operations. A vSAN stretched cluster continues to function if a failure or scheduled maintenance occurs at one zone, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSphere HA can be tested by deliberately failing hosts to observe VM restart behavior and confirm that admission control policies reserve sufficient capacity. vSphere HA uses admission control so that a cluster has sufficient resources to support virtual machine recovery when a host fails.

VCF Operations HCX supports workload migrations between sites through Mobility Groups, allowing organizations to exercise mobility procedures and validate that workloads can be moved to alternate processing locations. Migration activity, progress, and history are tracked through the Migration Planning interface, providing visibility into the results of migration exercises.

Management component backup and restore procedures can be tested by performing restore operations for VCF Operations, VMware vCenter, and NSX components. VCF documents the prerequisites and sequencing for file-based restore of these components, allowing organizations to validate their recovery procedures against documented expectations. Changed Block Tracking (CBT) enables incremental backups through VADP-integrated solutions that can be tested independently, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

VCF Operations includes a What-If Analysis capability under its capacity planning module that allows administrators to model hypothetical scenarios against current infrastructure. Administrators can create, save, and run scenarios cumulatively to evaluate the demand and supply for capacity on resources and assess potential risk to current capacity. This supports both Traditional and Hyperconverged deployment models. Scenarios can be committed as planning tools for capacity analysis, helping organizations with separate capacity management and operations teams understand current capacity and upcoming capacity requirements. These what-if scenarios can be used as part of contingency testing to model failover capacity needs, validate that sufficient resources exist to absorb relocated workloads, and verify that planned recovery configurations are viable before an actual event occurs.

To support the separation of test and production environments during contingency exercises, VCF Operations allows administrators to configure custom groups with differentiated alert thresholds and capacity calculations. This allows a test environment to operate under different operational policies than production, which is useful when conducting DR drills or failover exercises that temporarily shift workloads between sites or clusters.

VCF also provides built-in pre-check and validation capabilities that verify component connectivity, version compatibility, and component status among other environment readiness checks. These pre-checks run automatically during lifecycle operations such as upgrades and remediation, and they help confirm that the environment is in a known-good state before changes are applied. While these are not contingency plan tests in themselves, they contribute to readiness assessment by confirming that infrastructure components are healthy and correctly configured before and after contingency exercises.

Organizations deploying VCF should establish a formal contingency plan testing program that includes scheduled DR drills, failover exercises, backup restoration validation, and tabletop exercises. VCF's recovery mechanisms, what-if analysis, and

pre-check capabilities can inform and support these activities, but the test plan itself, its schedule, success criteria, scenario design, evaluation criteria, and after-action review process must be defined and managed by the organization.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides non-disruptive testing of disaster recovery plans as a core operational capability. Recovery plans organize protected workloads into sequenced, dependency-aware execution groups, and these plans can be tested without affecting production operations on either the protected or recovery site.

Testing a recovery plan in PNR validates that virtual machines recover correctly to the recovery site and exercises nearly every aspect of a recovery plan to validate disaster recovery readiness. Testing has no lasting effects on either the protected or recovery site, which means exercises can be repeated at any frequency without risk to production workloads. PNR requires that recovery plans be tested before use for planned migration or disaster recovery operations. Recovery plan tests can be canceled at any time; however, a successful cleanup operation must be completed before running a failover or initiating another test.

Recovery plan test execution is tracked through the Test task in Recent Tasks, which monitors overall progress of the test operation. Recovery plans support two types of custom steps: Test Steps that run during recovery plan testing, and Recovery Steps that run during planned migration or disaster recovery operations. The Configure Test Networks step in the recovery plan workflow supports using a separate test network at the recovery site to keep test VMs isolated from production network segments during testing.

Recovery plan testing can be automated through the VCF Operations orchestrator Plug-In for Protection and Recovery. The Initiate Test Recovery Plan workflow starts a test of a selected recovery plan and performs a state check to verify the recovery plan is in ready state before allowing test execution. The Initiate Cleanup Recovery Plan workflow cleans up a test when the recovery plan is in needsCleanup state.

The organizational elements of contingency plan testing, including exercise scheduling, scenario design, evaluation criteria, and after-action reviews, are outside PNR's scope. Recovery plan testing supports two distinct pre-production rehearsal modes: test recovery, which validates failover into an isolated environment without disrupting production, and planned migration, which performs an orderly, validated move of workloads. Tests can be used to verify that recovery time and recovery point objectives are met, and can be run unattended through the VCF Operations Orchestrator plug-in and the REST API for scheduled or scripted execution.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 24.2

The testing programme shall include a range of assessments, tests, methodologies, practices and tools to be applied in accordance with Articles 25 and 26.

SCF Controls: BCD-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several infrastructure-level capabilities that support an organization's contingency plan testing and exercise program, though the planning, scheduling, execution, and evaluation of formal contingency tests remains an organizational responsibility.

VCF includes built-in recovery and high-availability mechanisms that organizations can exercise during contingency tests. vSAN stretched clusters can be exercised by simulating site failures through host maintenance mode operations, validating that the surviving availability zone continues storage and compute operations. A vSAN stretched cluster continues to function if a failure or scheduled maintenance occurs at one zone, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSphere HA can be tested by deliberately failing hosts to observe VM restart behavior and confirm that admission control policies reserve sufficient capacity. vSphere HA uses admission control so that a cluster has sufficient resources to support virtual machine recovery when a host fails.

VCF Operations HCX supports workload migrations between sites through Mobility Groups, allowing organizations to exercise mobility procedures and validate that workloads can be moved to alternate processing locations. Migration activity, progress, and history are tracked through the Migration Planning interface, providing visibility into the results of migration exercises.

Management component backup and restore procedures can be tested by performing restore operations for VCF Operations, VMware vCenter, and NSX components. VCF documents the prerequisites and sequencing for file-based restore of these components, allowing organizations to validate their recovery procedures against documented expectations. Changed Block Tracking (CBT) enables incremental backups through VADP-integrated solutions that can be tested independently, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

VCF Operations includes a What-If Analysis capability under its capacity planning module that allows administrators to model hypothetical scenarios against current infrastructure. Administrators can create, save, and run scenarios cumulatively to evaluate the demand and supply for capacity on resources and assess potential risk to current capacity. This supports both Traditional and Hyperconverged deployment models. Scenarios can be committed as planning tools for capacity analysis, helping organizations with separate capacity management and operations teams understand current capacity and upcoming capacity requirements. These what-if scenarios can be used as part of contingency testing to model failover capacity needs, validate that sufficient resources exist to absorb relocated workloads, and verify that planned recovery configurations are viable before an actual event occurs.

To support the separation of test and production environments during contingency exercises, VCF Operations allows administrators to configure custom groups with differentiated alert thresholds and capacity calculations. This allows a test environment to operate under different operational policies than production, which is useful when conducting DR drills or failover exercises that temporarily shift workloads between sites or clusters.

VCF also provides built-in pre-check and validation capabilities that verify component connectivity, version compatibility, and component status among other environment readiness checks. These pre-checks run automatically during lifecycle operations such as upgrades and remediation, and they help confirm that the environment is in a known-good state before changes are applied. While these are not contingency plan tests in themselves, they contribute to readiness assessment by confirming that infrastructure components are healthy and correctly configured before and after contingency exercises.

Organizations deploying VCF should establish a formal contingency plan testing program that includes scheduled DR drills, failover exercises, backup restoration validation, and tabletop exercises. VCF's recovery mechanisms, what-if analysis, and

pre-check capabilities can inform and support these activities, but the test plan itself, its schedule, success criteria, scenario design, evaluation criteria, and after-action review process must be defined and managed by the organization.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides non-disruptive testing of disaster recovery plans as a core operational capability. Recovery plans organize protected workloads into sequenced, dependency-aware execution groups, and these plans can be tested without affecting production operations on either the protected or recovery site.

Testing a recovery plan in PNR validates that virtual machines recover correctly to the recovery site and exercises nearly every aspect of a recovery plan to validate disaster recovery readiness. Testing has no lasting effects on either the protected or recovery site, which means exercises can be repeated at any frequency without risk to production workloads. PNR requires that recovery plans be tested before use for planned migration or disaster recovery operations. Recovery plan tests can be canceled at any time; however, a successful cleanup operation must be completed before running a failover or initiating another test.

Recovery plan test execution is tracked through the Test task in Recent Tasks, which monitors overall progress of the test operation. Recovery plans support two types of custom steps: Test Steps that run during recovery plan testing, and Recovery Steps that run during planned migration or disaster recovery operations. The Configure Test Networks step in the recovery plan workflow supports using a separate test network at the recovery site to keep test VMs isolated from production network segments during testing.

Recovery plan testing can be automated through the VCF Operations orchestrator Plug-In for Protection and Recovery. The Initiate Test Recovery Plan workflow starts a test of a selected recovery plan and performs a state check to verify the recovery plan is in ready state before allowing test execution. The Initiate Cleanup Recovery Plan workflow cleans up a test when the recovery plan is in needsCleanup state.

The organizational elements of contingency plan testing, including exercise scheduling, scenario design, evaluation criteria, and after-action reviews, are outside PNR's scope. Recovery plan testing supports two distinct pre-production rehearsal modes: test recovery, which validates failover into an isolated environment without disrupting production, and planned migration, which performs an orderly, validated move of workloads. Tests can be used to verify that recovery time and recovery point objectives are met, and can be run unattended through the VCF Operations Orchestrator plug-in and the REST API for scheduled or scripted execution.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 24.3

Financial entities, other than microenterprises, shall follow a risk-based approach taking into account the proportionality criteria (Article 4(2)), evolving ICT risk, specific risks, and criticality of assets/services.

SCF Controls: BCD-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 24.4

Financial entities, other than microenterprises, shall ensure that tests are undertaken by independent parties, whether internal or external; if internal, sufficient resources and avoidance of conflicts of interest are required.

SCF Controls: BCD-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 24.5

Financial entities, other than microenterprises, shall establish procedures and policies to prioritise, classify and remedy all issues revealed throughout the tests, and establish internal validation methodologies.

SCF Controls: BCD-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 24.6

Financial entities, other than microenterprises, shall ensure, at least yearly, that appropriate tests are conducted on all ICT systems and applications supporting critical or important functions.

SCF Controls: BCD-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several infrastructure-level capabilities that support an organization's contingency plan testing and exercise program, though the planning, scheduling, execution, and evaluation of formal contingency tests remains an organizational responsibility.

VCF includes built-in recovery and high-availability mechanisms that organizations can exercise during contingency tests. vSAN stretched clusters can be exercised by simulating site failures through host maintenance mode operations, validating that the surviving availability zone continues storage and compute operations. A vSAN stretched cluster continues to function if a failure or scheduled maintenance occurs at one zone, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSphere HA can be tested by deliberately failing hosts to observe VM restart behavior and confirm that admission control policies reserve sufficient capacity. vSphere HA uses admission control so that a cluster has sufficient resources to support virtual machine recovery when a host fails.

VCF Operations HCX supports workload migrations between sites through Mobility Groups, allowing organizations to exercise mobility procedures and validate that workloads can be moved to alternate processing locations. Migration activity, progress, and history are tracked through the Migration Planning interface, providing visibility into the results of migration exercises.

Management component backup and restore procedures can be tested by performing restore operations for VCF Operations, VMware vCenter, and NSX components. VCF documents the prerequisites and sequencing for file-based restore of these components, allowing organizations to validate their recovery procedures against documented expectations. Changed Block Tracking (CBT) enables incremental backups through VADP-integrated solutions that can be tested independently, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

VCF Operations includes a What-If Analysis capability under its capacity planning module that allows administrators to model hypothetical scenarios against current infrastructure. Administrators can create, save, and run scenarios cumulatively to evaluate the demand and supply for capacity on resources and assess potential risk to current capacity. This supports both Traditional and Hyperconverged deployment models. Scenarios can be committed as planning tools for capacity analysis, helping organizations with separate capacity management and operations teams understand current capacity and upcoming capacity requirements. These what-if scenarios can be used as part of contingency testing to model failover capacity needs, validate that sufficient resources exist to absorb relocated workloads, and verify that planned recovery configurations are viable before an actual event occurs.

To support the separation of test and production environments during contingency exercises, VCF Operations allows administrators to configure custom groups with differentiated alert thresholds and capacity calculations. This allows a test environment to operate under different operational policies than production, which is useful when conducting DR drills or failover exercises that temporarily shift workloads between sites or clusters.

VCF also provides built-in pre-check and validation capabilities that verify component connectivity, version compatibility, and component status among other environment readiness checks. These pre-checks run automatically during lifecycle operations such as upgrades and remediation, and they help confirm that the environment is in a known-good state before changes are applied. While these are not contingency plan tests in themselves, they contribute to readiness assessment by confirming that infrastructure components are healthy and correctly configured before and after contingency exercises.

Organizations deploying VCF should establish a formal contingency plan testing program that includes scheduled DR drills, failover exercises, backup restoration validation, and tabletop exercises. VCF's recovery mechanisms, what-if analysis, and

pre-check capabilities can inform and support these activities, but the test plan itself, its schedule, success criteria, scenario design, evaluation criteria, and after-action review process must be defined and managed by the organization.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides non-disruptive testing of disaster recovery plans as a core operational capability. Recovery plans organize protected workloads into sequenced, dependency-aware execution groups, and these plans can be tested without affecting production operations on either the protected or recovery site.

Testing a recovery plan in PNR validates that virtual machines recover correctly to the recovery site and exercises nearly every aspect of a recovery plan to validate disaster recovery readiness. Testing has no lasting effects on either the protected or recovery site, which means exercises can be repeated at any frequency without risk to production workloads. PNR requires that recovery plans be tested before use for planned migration or disaster recovery operations. Recovery plan tests can be canceled at any time; however, a successful cleanup operation must be completed before running a failover or initiating another test.

Recovery plan test execution is tracked through the Test task in Recent Tasks, which monitors overall progress of the test operation. Recovery plans support two types of custom steps: Test Steps that run during recovery plan testing, and Recovery Steps that run during planned migration or disaster recovery operations. The Configure Test Networks step in the recovery plan workflow supports using a separate test network at the recovery site to keep test VMs isolated from production network segments during testing.

Recovery plan testing can be automated through the VCF Operations orchestrator Plug-In for Protection and Recovery. The Initiate Test Recovery Plan workflow starts a test of a selected recovery plan and performs a state check to verify the recovery plan is in ready state before allowing test execution. The Initiate Cleanup Recovery Plan workflow cleans up a test when the recovery plan is in needsCleanup state.

The organizational elements of contingency plan testing, including exercise scheduling, scenario design, evaluation criteria, and after-action reviews, are outside PNR's scope. Recovery plan testing supports two distinct pre-production rehearsal modes: test recovery, which validates failover into an isolated environment without disrupting production, and planned migration, which performs an orderly, validated move of workloads. Tests can be used to verify that recovery time and recovery point objectives are met, and can be run unattended through the VCF Operations Orchestrator plug-in and the REST API for scheduled or scripted execution.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 25.1

The digital operational resilience testing programme shall provide for the execution of appropriate tests, such as vulnerability assessments and scans, network security assessments, end-to-end testing and penetration testing.

SCF Controls: VPM-01, VPM-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides patch management and monitoring capabilities that support an organization's vulnerability management program as it applies to the database services DSM manages.

For patch management, DSM exposes a Maintenance Policy that administrators configure in the vSphere Client. The Maintenance Policy controls when and for how long the platform applies automatic minor software updates to DSM appliances. Configurable settings include the start date (maintenance-policy-start-date), start time in hours and minutes (maintenance-policy-start-time), and duration of the update window (maintenance-policy-duration). The default maintenance window starts each Saturday at 23:59 with a six-hour duration, and administrators should always set a future date and time when configuring the policy. Upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements. Per-database maintenance windows follow the same structure and can be adjusted during database creation or subsequent operations.

DSM requires that at least one complete chain of software updates for appliances be attempted, irrespective of the configured maintenance window duration. Patch cycles cannot be indefinitely deferred through policy configuration alone. Within the configured maintenance duration, plug-in software updates attempt up to three times with a 10-minute interval between attempts. The maintenance policy can be edited during the 10-minute interval between attempts, which cancels the next scheduled attempt and applies the newly configured policy. Administrators can view available upgrades and the upgrade history through the Version & Upgrade interface, accessible from the vSphere Client under the VMware vCenter Configure tab. The vSphere Administrator role is explicitly responsible for managing DSM VM updates and creating and managing

infrastructure policies, which supports assigning patch management responsibilities to designated personnel. Both a vSphere administrator and a DSM user in the admin role can manage plug-in and database template software updates.

The DSM controller manages feature dependencies through status monitoring and automated remediation. When an upgrade requires resolution of VKS release dependencies, the controller automatically resumes the provisioning process after those dependencies are resolved, helping maintain patch state consistency during VCF environment upgrades.

DSM also provides monitoring capabilities that help identify conditions requiring remediation. The Global Alerts page, accessible in both the plug-in UI and the standalone UI, displays non-catastrophic alerts and system status. The Administrator UI Dashboard surfaces the same Global Alerts view for environment-wide visibility. DSM generates alerts for authentication failures, backup and restore corruptions, and certificate errors. The monitoring framework supports metrics-based and status-condition-based alerts covering conditions such as database engine degradation, non-operational status, and backup failure. Administrators and database users can configure alert thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections, each with separate warning and critical thresholds. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations. DSM also provides mitigation suggestions alongside database alerts to help administrators resolve issues without disrupting database services. SQL Server administrators can define maintenance windows for operating system patching of SQL Server instances.

For diagnostics, DSM generates system support bundles containing system logs and diagnostic information, with a configurable retention duration before the system automatically deletes them. The Monitoring tab in the DSM UI displays monitoring data for individual database instances, including an Alerts pane and an Operations view for tracking operations targeted on database VMs. DSM can also be monitored using VCF Operations for troubleshooting and status visibility, with VCF Operations providing a view of PostgreSQL and MySQL cluster health within the DSM environment.

The overall vulnerability management program, including scanning, prioritization, remediation timelines, and organizational governance, is an organizational responsibility outside DSM's scope. DSM contributes by providing the update scheduling mechanisms and monitoring visibility needed to act on vulnerability management decisions within the scope of the database services it manages.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 25.2

Central securities depositories and central counterparties shall perform vulnerability assessments before any deployment or redeployment of new or existing applications and infrastructure components, and ICT services supporting critical or important functions of the financial entity.

SCF Controls: VPM-01, VPM-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides patch management and monitoring capabilities that support an organization's vulnerability management program as it applies to the database services DSM manages.

For patch management, DSM exposes a Maintenance Policy that administrators configure in the vSphere Client. The Maintenance Policy controls when and for how long the platform applies automatic minor software updates to DSM appliances. Configurable settings include the start date (maintenance-policy-start-date), start time in hours and minutes (maintenance-policy-start-time), and duration of the update window (maintenance-policy-duration). The default maintenance window starts each Saturday at 23:59 with a six-hour duration, and administrators should always set a future date and time when configuring the policy. Upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements. Per-database maintenance windows follow the same structure and can be adjusted during database creation or subsequent operations.

DSM requires that at least one complete chain of software updates for appliances be attempted, irrespective of the configured maintenance window duration. Patch cycles cannot be indefinitely deferred through policy configuration alone. Within the configured maintenance duration, plug-in software updates attempt up to three times with a 10-minute interval between attempts. The maintenance policy can be edited during the 10-minute interval between attempts, which cancels the next scheduled attempt and applies the newly configured policy. Administrators can view available upgrades and the upgrade history through the Version & Upgrade interface, accessible from the vSphere Client under the VMware vCenter Configure tab. The vSphere Administrator role is explicitly responsible for managing DSM VM updates and creating and managing

infrastructure policies, which supports assigning patch management responsibilities to designated personnel. Both a vSphere administrator and a DSM user in the admin role can manage plug-in and database template software updates.

The DSM controller manages feature dependencies through status monitoring and automated remediation. When an upgrade requires resolution of VKS release dependencies, the controller automatically resumes the provisioning process after those dependencies are resolved, helping maintain patch state consistency during VCF environment upgrades.

DSM also provides monitoring capabilities that help identify conditions requiring remediation. The Global Alerts page, accessible in both the plug-in UI and the standalone UI, displays non-catastrophic alerts and system status. The Administrator UI Dashboard surfaces the same Global Alerts view for environment-wide visibility. DSM generates alerts for authentication failures, backup and restore corruptions, and certificate errors. The monitoring framework supports metrics-based and status-condition-based alerts covering conditions such as database engine degradation, non-operational status, and backup failure. Administrators and database users can configure alert thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections, each with separate warning and critical thresholds. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations. DSM also provides mitigation suggestions alongside database alerts to help administrators resolve issues without disrupting database services. SQL Server administrators can define maintenance windows for operating system patching of SQL Server instances.

For diagnostics, DSM generates system support bundles containing system logs and diagnostic information, with a configurable retention duration before the system automatically deletes them. The Monitoring tab in the DSM UI displays monitoring data for individual database instances, including an Alerts pane and an Operations view for tracking operations targeted on database VMs. DSM can also be monitored using VCF Operations for troubleshooting and status visibility, with VCF Operations providing a view of PostgreSQL and MySQL cluster health within the DSM environment.

The overall vulnerability management program, including scanning, prioritization, remediation timelines, and organizational governance, is an organizational responsibility outside DSM's scope. DSM contributes by providing the update scheduling mechanisms and monitoring visibility needed to act on vulnerability management decisions within the scope of the database services it manages.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 25.3

Microenterprises shall perform the tests referred to in paragraph 1 by combining a risk-based approach with a strategic planning of ICT testing, by duly considering the need to maintain a balanced approach between the scale of resources and the time to be allocated to the ICT testing provided for in this Article, on the one hand, and the urgency, type of risk, criticality of information assets and of services provided, as well as any other relevant factor, including the financial entity's ability to take calculated risks, on the other hand.

SCF Controls: VPM-01, VPM-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides integrated vulnerability and patch management capabilities across its infrastructure stack, addressing both the implementation and monitoring aspects of this control.

VCF includes built-in lifecycle management that automates the process of applying updates and patches to software components within the stack. Patch releases provide time-sensitive fixes to security and critical issues and can be applied selectively to individual components without requiring synchronized updates across all VCF components. VCF Operations includes a patch planner that identifies available updates for VCF core components, downloads binaries from online depots (or stages them for offline environments), and orchestrates installation across the stack. Pre-update validation runs health checks and compatibility verification before applying changes. VCF Operations automatically backs up components during the patch process to provide a recovery point in case of failure. For vCenter appliance patching, an LVM snapshot is automatically created before the patching process begins; if patching fails, the orchestrator offers the option to roll back to that snapshot or continue after addressing the underlying issue. Lifecycle management also provides tools for planning updates so that administrators can schedule maintenance windows and coordinate changes with minimal disruption to services.

vSphere Lifecycle Manager (vLCM) manages the desired-state configuration for ESX hosts, including firmware and drivers through Hardware Support Manager (HSM) plugins provided by OEM vendors. vLCM images consist of a base image, vendor add-ons, components, and firmware add-ons that can be independently retrieved and applied to hosts. vLCM scans hosts against the desired image specification, flags deviations, and remediates non-compliant hosts. vSphere Lifecycle Manager also supports Live Patch for applicable updates, enabling patches to be applied to ESX hosts without requiring them to enter maintenance mode. It works with three types of software depots (online, offline, and UMDS) to provide flexibility in how patches are sourced and distributed. Update Manager supports dynamic baselines that automatically adjust their patch data based on specified criteria each time new patches are downloaded, allowing administrators to define patching policies that stay current without manual intervention. The Update Manager PowerCLI module provides cmdlets for downloading software patches, creating and modifying baselines, and scanning and remediating virtual machines and hosts, enabling automation of patching workflows.

For the VMware Kubernetes Service (VKS) and vSphere Supervisor layer, Security Technical Implementation Guides (STIGs) are available for Supervisor and VMware Kubernetes Release (VKr) components through Tanzu STIG Hardening, providing a structured security configuration baseline against which VKS deployments can be assessed and remediated. VKr components and Standard Packages are updated using the VCF CLI ``vcf package installed update`` command, which upgrades a package installation to a newer version and applies new configuration values, giving administrators a structured mechanism for applying package-level updates to components running in the Supervisor environment. VCF building-block services have independent lifecycles, enabling components to be updated individually without affecting the broader environment. The Node Problem Detector can be deployed within VKS clusters to monitor node health and report infrastructure-level problems through configurable detection rules, supporting the monitoring dimension of vulnerability management at the workload tier.

For container workloads running on VKS, Harbor is available as a deployable Standard Package with built-in vulnerability scanning using the Trivy database, which can be configured to use a custom or mirrored repository for air-gapped deployments. Harbor also provides content trust features that support image signing and policy-based replication, giving

operations teams mechanisms to detect and restrict deployment of images containing known vulnerabilities. Harbor packages are updated using the ``vcf package installed update harbor`` command. Kubernetes guidance recommends that container images be regularly scanned during creation and in deployment, with known vulnerable software patched before workloads reach the runtime environment. Kubernetes security vulnerabilities are tracked and announced through the Kubernetes Security Response Committee, which maintains an official list of known CVEs and publishes security-related announcements to the `kubernetes-announce` mailing list. For CI/CD pipelines running on VCF, Harness CI/CD is available as a Supervisor Service with integrated Security Testing Orchestration (STO) that incorporates the Wiz CLI to automate vulnerability management throughout the pipeline, performing infrastructure-as-code (IaC) and secret detection scans and container image scans against artifacts stored in JFrog Artifactory. Vulnerability scan findings from Wiz are reported to the Harness security dashboard, and Harness STO automatically deduplicates findings and displays them on the vulnerabilities tab of each pipeline execution for review.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing detailed descriptions, root cause insights, and actionable remediation steps. The Security Operations dashboard in VCF Operations provides a consolidated view of security posture, helping administrators identify areas requiring attention. VCF Operations compliance management continuously monitors infrastructure for policy violations, highlights risk areas, and provides actionable remediation recommendations. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity of the non-compliance, automated remediation actions can be configured to bring the object back into compliance.

Configuration drift monitoring provides an additional layer of ongoing assurance. VCF Operations provides unified configuration management that supports scheduled drift detection for vCenter and cluster objects. It detects deviations from assigned configuration template values, displays drift results across all configuration templates, and allows administrators to compare changes against desired values. This helps identify unauthorized or unintended changes to the infrastructure that could introduce vulnerabilities.

Patching operations are governed by role-based access controls. Editing remediation settings in vSphere Lifecycle Manager requires specific privileges (`VcIntegrity.lifecycleSettings.Read` and `VcIntegrity.lifecycleSettings.Write`), and image remediation operations require a separate set of API privileges.

Broadcom publishes security advisories (VMSAs) for VCF vulnerabilities and releases patches to address them.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability management through network-layer detection, virtual patching, and security posture monitoring capabilities that complement traditional patch management workflows.

vDefend Distributed IDS/IPS provides signature-based detection of vulnerability exploitation attempts across east-west traffic within the data center. When a new vulnerability is disclosed, administrators can deploy custom IDS/IPS signatures to detect and block exploitation attempts before official patches are available, a practice commonly referred to as virtual patching. In 9.1, IDS/IPS event monitoring displays Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by exploits, giving security teams direct visibility into which specific vulnerabilities are being actively targeted in their environment. The IDS/IPS dashboard provides monitoring and analysis of intrusion events, and Security Services Platform collects metrics to monitor IDS/IPS readiness and performance across the environment. Malicious IP reputation feeds, managed centrally through the Global Manager, automatically update threat intelligence so that known attacker infrastructure is blocked without manual intervention.

The Threat Event Monitoring dashboard in Security Services Platform displays the top IPs on which an intrusion was attempted and the top VMs based on Vulnerability Severity criteria. The Threat Event Monitoring tab on the Security Overview dashboard surfaces key insights about the current state of various security issues in the data center, helping security teams understand network activity and prioritize focus areas.

Security Intelligence, a feature within Security Services Platform, provides posture assessment and segmentation monitoring capabilities. Administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment traffic. The Security Posture dashboard presents information that can be used to

plan and implement additional security policies. The Security Explorer provides a visual representation of workloads, their traffic flows, and connection status, which helps identify workloads that may be exposed to unpatched vulnerabilities. Security Services Platform also generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and traffic flows, providing the visibility needed to plan subsequent protection stages. The Security Operator role in Security Services Platform is designated to monitor security systems and respond to security incidents, supporting the operational dimension of vulnerability management monitoring.

vDefend Advanced Threat Prevention extends detection capabilities to include behavioral analysis and sandboxing, identifying malware and exploit attempts that signature-based detection might miss. The Security Overview dashboard in Security Services Platform displays file inspection statistics organized by different ranges of threat score, giving security teams a quantitative view of file-based threats detected in their environment. This provides an additional layer of protection for systems awaiting patches.

These capabilities address the detection and monitoring dimensions of vulnerability management. Patch deployment and software lifecycle management are handled by other VCF components such as VCF Operations and vSphere Lifecycle Manager.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides patch management and monitoring capabilities that support an organization's vulnerability management program as it applies to the database services DSM manages.

For patch management, DSM exposes a Maintenance Policy that administrators configure in the vSphere Client. The Maintenance Policy controls when and for how long the platform applies automatic minor software updates to DSM appliances. Configurable settings include the start date (maintenance-policy-start-date), start time in hours and minutes (maintenance-policy-start-time), and duration of the update window (maintenance-policy-duration). The default maintenance window starts each Saturday at 23:59 with a six-hour duration, and administrators should always set a future date and time when configuring the policy. Upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements. Per-database maintenance windows follow the same structure and can be adjusted during database creation or subsequent operations.

DSM requires that at least one complete chain of software updates for appliances be attempted, irrespective of the configured maintenance window duration. Patch cycles cannot be indefinitely deferred through policy configuration alone. Within the configured maintenance duration, plug-in software updates attempt up to three times with a 10-minute interval between attempts. The maintenance policy can be edited during the 10-minute interval between attempts, which cancels the next scheduled attempt and applies the newly configured policy. Administrators can view available upgrades and the upgrade history through the Version & Upgrade interface, accessible from the vSphere Client under the VMware vCenter Configure tab. The vSphere Administrator role is explicitly responsible for managing DSM VM updates and creating and managing infrastructure policies, which supports assigning patch management responsibilities to designated personnel. Both a vSphere administrator and a DSM user in the admin role can manage plug-in and database template software updates.

The DSM controller manages feature dependencies through status monitoring and automated remediation. When an upgrade requires resolution of VKS release dependencies, the controller automatically resumes the provisioning process after those dependencies are resolved, helping maintain patch state consistency during VCF environment upgrades.

DSM also provides monitoring capabilities that help identify conditions requiring remediation. The Global Alerts page, accessible in both the plug-in UI and the standalone UI, displays non-catastrophic alerts and system status. The Administrator UI Dashboard surfaces the same Global Alerts view for environment-wide visibility. DSM generates alerts for authentication failures, backup and restore corruptions, and certificate errors. The monitoring framework supports metrics-based and status-condition-based alerts covering conditions such as database engine degradation, non-operational status, and backup failure. Administrators and database users can configure alert thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections, each with separate warning and critical thresholds. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations. DSM also provides mitigation suggestions alongside database alerts to

help administrators resolve issues without disrupting database services. SQL Server administrators can define maintenance windows for operating system patching of SQL Server instances.

For diagnostics, DSM generates system support bundles containing system logs and diagnostic information, with a configurable retention duration before the system automatically deletes them. The Monitoring tab in the DSM UI displays monitoring data for individual database instances, including an Alerts pane and an Operations view for tracking operations targeted on database VMs. DSM can also be monitored using VCF Operations for troubleshooting and status visibility, with VCF Operations providing a view of PostgreSQL and MySQL cluster health within the DSM environment.

The overall vulnerability management program, including scanning, prioritization, remediation timelines, and organizational governance, is an organizational responsibility outside DSM's scope. DSM contributes by providing the update scheduling mechanisms and monitoring visibility needed to act on vulnerability management decisions within the scope of the database services it manages.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 26.1

Financial entities, other than entities referred to in Article 16(1), first subparagraph, and other than microenterprises, which are identified in accordance with paragraph 8, third subparagraph, of this Article, shall carry out at least every 3 years advanced testing by means of TLPT. Based on the risk profile of the financial entity and taking into account operational circumstances, the competent authority may, where necessary, request the financial entity to reduce or increase this frequency.

SCF Controls: VPM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 26.2

Each threat-led penetration test shall cover several or all critical or important functions of a financial entity, and shall be performed on live production systems supporting such functions. Financial entities shall identify all relevant underlying ICT systems, processes and technologies supporting critical or important functions and ICT services, including those supporting the critical or important functions which have been outsourced or contracted to ICT third-party service providers. Financial entities shall assess which critical or important functions need to be covered by the TLPT. The result of this assessment shall determine the precise scope of TLPT and shall be validated by the competent authorities.

SCF Controls: VPM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 26.3

Where ICT third-party service providers are included in the scope of TLPT, the financial entity shall take the necessary measures and safeguards to ensure the participation of such ICT third-party service providers in the TLPT and shall retain at all times full responsibility for ensuring compliance with this Regulation.

SCF Controls: VPM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 26.4

Without prejudice to paragraph 2, first and second subparagraphs, where the participation of an ICT third-party service provider in the TLPT, referred to in paragraph 3, is reasonably expected to have an adverse impact on the quality or security of services delivered by the ICT third-party service provider to customers that are entities falling outside the scope of this Regulation, or on the confidentiality of the data related to such services, the financial entity and the ICT third-party service provider may agree in writing that the ICT third-party service provider directly enters into contractual arrangements with an external tester, for the purpose of conducting, under the direction of one designated financial entity, a pooled TLPT involving several financial entities (pooled testing) to which the ICT third-party service provider provides ICT services. That pooled testing shall cover the relevant range of ICT services supporting critical or important functions contracted to the respective ICT third-party service provider by the financial entities. The pooled testing shall be considered TLPT carried out by the financial entities participating in the pooled testing. The number of financial entities participating in the pooled testing shall be duly calibrated taking into account the complexity and types of services involved.

SCF Controls: VPM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 26.5

Financial entities shall, with the cooperation of ICT third-party service providers and other parties involved, including the testers but excluding the competent authorities, apply effective risk management controls to mitigate the risks of any potential impact on data, damage to assets, and disruption to critical or important functions, services or operations at the financial entity itself, its counterparts or to the financial sector.

SCF Controls: VPM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 26.6

At the end of the testing, after reports and remediation plans have been agreed, the financial entity and, where applicable, the external testers shall provide to the authority, designated in accordance with paragraph 9 or 10, a summary of the relevant findings, the remediation plans and the documentation demonstrating that the TLPT has been conducted in accordance with the requirements.

SCF Controls: VPM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 26.7

Authorities shall provide financial entities with an attestation confirming that the test was performed in accordance with the requirements as evidenced in the documentation in order to allow for mutual recognition of threat led penetration tests between competent authorities. The financial entity shall notify the relevant competent authority of the attestation, the summary of the relevant findings and the remediation plans. - Without prejudice to such attestation, financial entities shall remain at all times fully responsible for the impact of the tests referred to in paragraph 4.

SCF Controls: VPM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 26.8

Financial entities shall contract testers for the purposes of undertaking TLPT in accordance with Article 27. When financial entities use internal testers for the purposes of undertaking TLPT, they shall contract external testers every three tests. Credit institutions that are classified as significant in accordance with Article 6(4) of Regulation (EU) No 1024/2013, shall only use external testers in accordance with Article 27(1), points (a) to (e). Competent authorities shall identify financial entities that are required to perform TLPT taking into account the criteria set out in Article 4(2), based on an assessment of the following:

SCF Controls: VPM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 26.8(a)

Impact-related factors, in particular the extent to which the services provided and activities undertaken by the financial entity impact the financial sector.

SCF Controls: VPM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 26.8(b)

Possible financial stability concerns, including the systemic character of the financial entity at Union or national level, as applicable.

SCF Controls: VPM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 26.8(c)

Specific ICT risk profile, level of ICT maturity of the financial entity or technology features involved.

SCF Controls: VPM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 27.1

Financial entities shall only use testers for the carrying out of TLPT, that:

SCF Controls: VPM-07.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 27.1(a)

Are of the highest suitability and reputability.

SCF Controls: VPM-07.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 27.1(b)

Possess technical and organisational capabilities and demonstrate specific expertise in threat intelligence, penetration testing and red team testing.

SCF Controls: VPM-07.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 27.1(c)

Are certified by an accreditation body in a Member State or adhere to formal codes of conduct or ethical frameworks.

SCF Controls: VPM-07.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 27.1(d)

Provide an independent assurance, or an audit report, in relation to the sound management of risks associated with the carrying out of TLPT, including the due protection of the financial entity's confidential information and redress for the business risks of the financial entity.

SCF Controls: VPM-07.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 27.1(e)

Are duly and fully covered by relevant professional indemnity insurances, including against risks of misconduct and negligence.

SCF Controls: VPM-07.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 27.2

When using internal testers, financial entities shall ensure that, in addition to the requirements in paragraph 1, the following conditions are met:

SCF Controls: VPM-07.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 27.2(a)

Such use has been approved by the relevant competent authority or by the single public authority designated in accordance with Article 26(9) and (10).

SCF Controls: VPM-07.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 27.2(b)

The relevant competent authority has verified that the financial entity has sufficient dedicated resources and ensured that conflicts of interest are avoided throughout the design and execution phases of the test.

SCF Controls: VPM-07.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 27.2(c)

| The threat intelligence provider is external to the financial entity.

SCF Controls: VPM-07.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 27.3

Financial entities shall ensure that contracts concluded with external testers require a sound management of the TLPT results and that any data processing thereof, including any generation, store, aggregation, draft, report, communication or destruction, do not create risks to the financial entity.

SCF Controls: VPM-07.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.1

Financial entities shall manage ICT third-party risk as an integral component of ICT risk within their framework, in accordance with the following principles:

SCF Controls: RSK-09, TPM-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.1(a)

Financial entities shall, at all times, remain fully responsible for compliance with, and the discharge of, all obligations.

SCF Controls: RSK-09, TPM-01.1, TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.1(b)

Management of ICT third-party risk shall be implemented in light of the proportionality principle.

SCF Controls: RSK-09, TPM-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.1(b)(i)

The proportionality principle considers the nature, scale, complexity and importance of ICT-related dependencies.

SCF Controls: RSK-09, TPM-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.1(b)(ii)

The proportionality principle considers the risks arising from contractual arrangements, taking into account the criticality or importance of the service, process or function, and the potential impact on continuity and availability.

SCF Controls: RSK-09, TPM-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.2

Financial entities (other than those referred to in Article 16(1) and microenterprises) shall adopt, and regularly review, a strategy on ICT third-party risk.

SCF Controls: RSK-09, TPM-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.3

Financial entities shall maintain and update at entity, sub-consolidated, and consolidated levels, a register of information in relation to all contractual arrangements on the use of ICT services. They shall report at least yearly to the competent authorities on the number of new arrangements and inform the competent authority in a timely manner about any planned arrangements supporting critical or important functions.

SCF Controls: RSK-09, TPM-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.4

Before entering into a contractual arrangement on the use of ICT services, financial entities shall:

SCF Controls: RSK-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.4(a)

Assess whether the contractual arrangement covers the use of ICT services supporting a critical or important function.

SCF Controls: RSK-09, RSK-09.1, TPM-01.1, TPM-04.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.4(b)

Assess if supervisory conditions for contracting are met.

SCF Controls: RSK-09, RSK-09.1, TPM-01.1, TPM-04.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.4(c)

Identify and assess all relevant risks, including the possibility that such arrangement may contribute to reinforcing ICT concentration risk.

SCF Controls: RSK-09, RSK-09.1, TPM-01.1, TPM-04.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.4(d)

Undertake all due diligence on prospective ICT third-party service providers and ensure the provider is suitable.

SCF Controls: RSK-09, RSK-09.1, TPM-01.1, TPM-04.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.4(e)

Identify and assess conflicts of interest that the contractual arrangement may cause.

SCF Controls: RSK-09, RSK-09.1, TPM-01.1, TPM-04.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.5

Financial entities may only enter into contractual arrangements with ICT third-party service providers that comply with appropriate information security standards; for critical/important functions, they must take due consideration of the use of the most up-to-date and highest quality standards.

SCF Controls: RSK-09, TPM-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.6

In exercising access, inspection and audit rights, financial entities shall, on a risk-based approach, pre-determine the frequency of audits and inspections, and the areas to be audited.

SCF Controls: RSK-09, TPM-01.1, TPM-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.7

Financial entities shall ensure that contractual arrangements on the use of ICT services may be terminated in any of the following circumstances:

SCF Controls: TPM-05.7

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.7(a)

Significant breach by the ICT third-party service provider of applicable laws, regulations or contractual terms.

SCF Controls: RSK-09, TPM-01.1, TPM-05.7

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.7(b)

Circumstances identified throughout the monitoring that are deemed capable of altering the performance of the functions.

SCF Controls: RSK-09, TPM-01.1, TPM-05.7

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.7(c)

ICT third-party service provider's evidenced weaknesses pertaining to its overall ICT risk management.

SCF Controls: RSK-09, TPM-01.1, TPM-05.7

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.7(d)

Where the competent authority can no longer effectively supervise the financial entity as a result of the conditions of, or circumstances related to, the contractual arrangement.

SCF Controls: RSK-09, TPM-01.1, TPM-05.7

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.8

For ICT services supporting critical or important functions, financial entities shall put in place exit strategies.

SCF Controls: RSK-09, TPM-01.1, TPM-05.7

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.8(a)

Financial entities shall ensure that they are able to exit contractual arrangements without disruption to their business activities.

SCF Controls: RSK-09, TPM-01.1, TPM-05.7

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.8(b)

Financial entities shall ensure that they are able to exit contractual arrangements without limiting compliance with regulatory requirements.

SCF Controls: RSK-09, TPM-01.1, TPM-05.7

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.8(c)

Financial entities shall ensure that they are able to exit contractual arrangements without detriment to the continuity and quality of services provided to clients.

SCF Controls: RSK-09, TPM-01.1, TPM-05.7

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 28.8 (end)

Exit plans shall be comprehensive, documented and, in accordance with the criteria set out in Article 4(2), shall be sufficiently tested and reviewed periodically. Financial entities shall identify alternative solutions and develop transition plans enabling them to remove the contracted ICT services and the relevant data from the ICT third-party service provider and to securely and integrally transfer them to alternative providers or reincorporate them in-house. Financial entities shall have appropriate contingency measures in place to maintain business continuity in the event of the circumstances referred to in the first subparagraph.

SCF Controls: TDA-17.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 29.1

When assessing risks, financial entities shall also take into account whether the arrangement would lead to:

SCF Controls: TPM-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 29.1(a)

Contracting an ICT third-party service provider that is not easily substitutable.

SCF Controls: TPM-04.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 29.1(b)

Having in place multiple contractual arrangements in relation to services supporting critical or important functions with the same or closely connected ICT third-party service providers.

SCF Controls: TPM-04.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 29.1 (end)

Financial entities shall weigh the benefits and costs of alternative solutions, such as the use of different ICT third-party service providers, taking into account if and how envisaged solutions match the business needs and objectives set out in their digital resilience strategy.

SCF Controls: TPM-03.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 29.2

Where the contractual arrangements on the use of ICT services supporting critical or important functions include the possibility that an ICT third-party service provider further subcontracts ICT services supporting a critical or important function to other ICT third-party service providers, financial entities shall weigh benefits and risks that may arise in connection with such subcontracting, in particular in the case of an ICT subcontractor established in a third-country. Where contractual arrangements concern ICT services supporting critical or important functions, financial entities shall duly consider the insolvency law provisions that would apply in the event of the ICT third-party service provider's bankruptcy as well as any constraint that may arise in respect to the urgent recovery of the financial entity's data. Where contractual arrangements on the use of ICT services supporting critical or important functions are concluded with an ICT third-party service provider established in a third country, financial entities shall, in addition to the considerations referred to in the second subparagraph, also consider the compliance with Union data protection rules and the effective enforcement of the law in that third country. Where the contractual arrangements on the use of ICT services supporting critical or important functions provide for subcontracting, financial entities shall assess whether and how potentially long or complex chains of subcontracting may impact their ability to fully monitor the contracted functions and the ability of the competent authority to effectively supervise the financial entity in that respect.

SCF Controls: TPM-05, TPM-05.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.1

The rights and obligations of the financial entity and of the ICT third-party service provider shall be clearly allocated and set out in writing. The full contract shall include the service level agreements and be documented in one written document which shall be available to the parties on paper, or in a document with another downloadable, durable and accessible format.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.2

The contractual arrangements on the use of ICT services shall include at least the following elements:

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.2(a)

A clear and complete description of all functions and ICT services to be provided by the ICT third-party service provider, indicating whether subcontracting of an ICT service supporting a critical or important function, or material parts thereof, is permitted and, when that is the case, the conditions applying to such subcontracting.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.2(b)

The locations, namely the regions or countries, where the contracted or subcontracted functions and ICT services are to be provided and where data is to be processed, including the storage location, and the requirement for the ICT third- party service provider to notify the financial entity in advance if it envisages changing such locations.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.2(c)

Provisions on availability, authenticity, integrity and confidentiality in relation to the protection of data, including personal data.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.2(d)

Provisions on ensuring access, recovery and return in an easily accessible format of personal and non-personal data processed by the financial entity in the event of the insolvency, resolution or discontinuation of the business operations of the ICT third-party service provider, or in the event of the termination of the contractual arrangements.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.2(e)

Service level descriptions, including updates and revisions thereof.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.2(f)

The obligation of the ICT third-party service provider to provide assistance to the financial entity at no additional cost, or at a cost that is determined ex-ante, when an ICT incident that is related to the ICT service provided to the financial entity occurs.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.2(g)

The obligation of the ICT third-party service provider to fully cooperate with the competent authorities and the resolution authorities of the financial entity, including persons appointed by them.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.2(h)

Termination rights and related minimum notice periods for the termination of the contractual arrangements, in accordance with the expectations of competent authorities and resolution authorities.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.2(i)

The conditions for the participation of ICT third-party service providers in the financial entities' ICT security awareness programmes and digital operational resilience training in accordance with Article 13(6).

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.3

The contractual arrangements on the use of ICT services supporting critical or important functions shall include, in addition to the elements referred to in paragraph 2, at least the following:

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.3(a)

Full service level descriptions, including updates and revisions thereof with precise quantitative and qualitative performance targets within the agreed service levels to allow effective monitoring by the financial entity of ICT services and enable appropriate corrective actions to be taken, without undue delay, when agreed service levels are not met.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.3(b)

Notice periods and reporting obligations of the ICT third-party service provider to the financial entity, including notification of any development that might have a material impact on the ICT third-party service provider's ability to effectively provide the ICT services supporting critical or important functions in line with agreed service levels.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.3(c)

Requirements for the ICT third-party service provider to implement and test business contingency plans and to have in place ICT security measures, tools and policies that provide an appropriate level of security for the provision of services by the financial entity in line with its regulatory framework.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.3(d)

The obligation of the ICT third-party service provider to participate and fully cooperate in the financial entity's TLPT as referred to in Articles 26 and 27.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.3(e)

The right to monitor, on an ongoing basis, the provider's performance, which entails:

SCF Controls: TPM-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.3(e)(i)

Unrestricted rights of access, inspection and audit by the financial entity, or an appointed third party, and by the competent authority, and the right to take copies of relevant documentation on-site if they are critical to the operations of the ICT third-party service provider, the effective exercise of which is not impeded or limited by other contractual arrangements or implementation policies.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.3(e)(ii)

The right to agree on alternative assurance levels if other clients' rights are affected.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.3(e)(iii)

The obligation of the ICT third-party service provider to fully cooperate during the onsite inspections and audits performed by the competent authorities, the Lead Overseer, financial entity or an appointed third party.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.3(e)(iv)

The obligation to provide details on the scope, procedures to be followed and frequency of such inspections and audits.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.3 (end)

By way of derogation from point (e), the ICT third-party service provider and the financial entity that is a microenterprise may agree that the financial entity's rights of access, inspection and audit can be delegated to an independent third party, appointed by the ICT third-party service provider, and that the financial entity is able to request information and assurance on the ICT third-party service provider's performance from the third party at any time.

SCF Controls: TPM-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.3(f)

Exit strategies, in particular the establishment of a mandatory adequate transition period:

SCF Controls: TPM-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.3(f)(i)

During which the ICT third-party service provider will continue providing the respective functions, or ICT services, with a view to reducing the risk of disruption at the financial entity or to ensure its effective resolution and restructuring.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 30.4

When negotiating contractual arrangements, financial entities and ICT third-party service providers shall consider the use of standard contractual clauses developed by public authorities for specific services.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 31.4

Critical ICT third-party service providers which are part of a group shall designate one legal person as a coordination point to ensure adequate representation and communication with the Lead Overseer.

SCF Controls: GOV-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 31.12

Financial entities shall only use the services of an ICT third-party service provider established in a third country and designated as critical if the latter has established a subsidiary in the Union within the 12 months following the designation.

SCF Controls: TPM-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 45.1

Financial entities may exchange cyber threat information and intelligence amongst themselves, to the extent that such sharing:

SCF Controls: GOV-07, THR-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 45.1(a)

Aims to enhance the digital operational resilience of financial entities, in particular through raising awareness, limiting spread of threats, and supporting defence capabilities.

SCF Controls: GOV-07, THR-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 45.1(b)

| Takes places within trusted communities of financial entities.

SCF Controls: GOV-07, THR-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 45.1(c)

Is implemented through information-sharing arrangements that protect the potentially sensitive nature of the information shared, and that are governed by rules of conduct in full respect of business confidentiality, data protection, and competition policy.

SCF Controls: GOV-07, THR-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 45.2

The information-sharing arrangements shall define the conditions for participation, and where appropriate, set out the details on the involvement of public authorities and ICT third-party service providers.

SCF Controls: GOV-07, THR-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 45.3

Financial entities shall notify competent authorities of their participation in the information-sharing arrangements upon validation of their membership, or cessation of membership.

SCF Controls: IRO-10, THR-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

